Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности
Кафедра Систем информационной безопасности
Направление подготовки (специальность) 10.05.03 Информационная безопасность автоматизированных систем
(код и наименование направления подготовки)
Профиль/программа/направленность Обеспечение информационной безопасности распределённых информационных систем

ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА

Дипломная работа
(вид выпускной квалификационной работы – бакалаврская работа, дипломная работа (проект), магистерская диссертация)

Казакова Андрея Викторовича
(фамилия, имя, отчество обучающегося)

Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Манипулирование временем и состоянием»

Состав выпускной квалификационной работы:

Расчетно-пояснительная записка на 197 страницах
Графическая часть на _____ листах

Расчетно-пояснительная записка к выпускной квалификационной работе:

Заведующий кафедрой _____ (подпись) (А.Г. Остапенко) (инициалы, фамилия)
Руководитель _____ (подпись) (А.С. Пахомова) (инициалы, фамилия)
Консультанты:
по _____ (наименование раздела, подпись) (_____) (инициалы, фамилия)
по _____ (наименование раздела, подпись) (_____) (инициалы, фамилия)
по _____ (наименование раздела, подпись) (_____) (инициалы, фамилия)
Обучающийся _____ (подпись) А.В. Казаков (инициалы, фамилия)
« » 2025 г.

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности
Кафедра Систем информационной безопасности
Направление подготовки (специальность) 10.05.03 Информационная безопасность автоматизированных систем
(код и наименование направления подготовки)
Профиль/программа/направленность Обеспечение информационной безопасности распределённых информационных систем

Утверждаю _____
(дата)
Зав.кафедрой _____
(подпись)

ЗАДАНИЕ
ПО ПОДГОТОВКЕ ВЫПУСКНОЙ КВАЛИФИКАЦИОННОЙ РАБОТЫ

Дипломная работа
дипломная работа (проект), бакалаврская работа, магистерская диссертация

Обучающемуся Казакову Андрею Викторовичу
фамилия, имя, отчество

1. Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Манипулирование временем и состоянием»

приказ № 01-1-10/3-2979 от 25.06.2025
утверждена приказом по университету

2. Срок сдачи обучающимся выпускной квалификационной работы 02.07.2025

3. Исходные данные

4. Краткое содержание выпускной квалификационной работы

Раздел 1. Агрегация сведений об атаках класса «Манипулирование временем и состоянием»

Раздел 2. Формирование сценариев шаблонов атак CAPEC как последовательности реализации техник MITRE ATT&CK

Раздел 3. Моделирование микромоделей сценариев шаблонов атак, оценка критичности уязвимостей и рисков успешности реализации сформированных сценариев атаки

Раздел 4. Разработка регламентов реагирования и ликвидации последствий инцидентов безопасности для наиболее опасных сценариев атак класса «Манипулирование временем и состоянием»

5. Перечень графического материала (с точным указанием обязательных чертежей по разделам

6. Консультанты (с указанием относящихся к ним разделов)

График выполнения выпускной квалификационной работы

№ п/п	Наименование разделов выпускной квалификационной работы	Срок выполнения этапов работы
1	Введение	22.03 – 22.05
2	Агрегация сведений об атаках класса «Манипулирование временем и состоянием»	22.03 – 22.05
3	Формирование сценариев шаблонов атак CAPEC как последовательности реализации техник MITRE ATT&CK	23.05 – 31.05
4	Моделирование микромоделей сценариев шаблонов атак, оценка критичности уязвимостей и рисков успешности реализации сформированных сценариев атаки	01.06 – 12.06
5	Разработка регламентов реагирования и ликвидации последствий инцидентов безопасности для наиболее опасных сценариев атак класса «Манипулирование временем и состоянием»	13.06 – 24.06
6	Заключение	25.06 – 02.07

Руководитель _____
(подпись)

Дата выдачи задания 22.03.2025

Задание принял к исполнению 22.03.2025

Подпись обучающегося _____

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение
высшего образования
«Воронежский государственный технический университет»

АННОТАЦИЯ
выпускной квалификационной работы

Обучающегося Казакова Андрея Викторовича
Тема ВКР: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Манипулирование временем и состоянием»

Характеристика выпускной квалификационной работы

Актуальность исследования

Исследование обусловлено отсутствием работ, посвященных анализу и противодействию атак класса «Манипулирование временем и состоянием», несмотря на непрерывный рост угроз компрометации автоматизированных информационных систем. В связи с этим актуальность данного исследования заключается в восполнении данного пробела, предлагая структурированную базу данных об атаках предметного класса, методику оценки рисков и регламенты реагирования, основанные на сценарном анализе жизненного цикла атак данного класса и комплексной оценке эксплуатируемых уязвимостей.

Задачи, решаемые в ВКР

– организация парсинга открытых интернет-источников и суммаризации данных относительно пар «атака – уязвимость» в отношении операционных систем защищаемых корпоративных систем;

– установление полного соответствия между атаками класса «Манипулирование состоянием и временем» и уязвимостями операционных систем защищаемых корпоративных систем, включая их сценарное описание и паспортизацию вредоносов;

– проведение оценки рисков нарушения информационной безопасности посредством кибератак класса «Манипулирование состоянием и временем» на уязвимости операционных систем защищаемых корпоративных систем, учитывающих критичности используемых ими уязвимостей;

– формирование регламентов реагирования и ликвидации последствий в отношении кибератак класса «Манипулирование состоянием и временем» на уязвимости операционных систем защищаемой корпоративной системы.

Структура ВКР

Введение – 7 страниц;

Глава 1. Агрегация сведений об атаках класса «Манипулирование временем и состоянием» – 11 страниц;

Глава 2. Формирование сценариев шаблонов атак CAPEC как последовательности реализации техник MITRE ATT&CK – 70 страниц;

Глава 3. Моделирование микромоделей сценариев шаблонов атак, оценка критичности уязвимостей и рисков успешности реализации сформированных сценариев атаки – 40 страниц;

Глава 4. Разработка регламентов реагирования и ликвидации последствий инцидентов безопасности для наиболее опасных сценариев атак класса «Манипулирование временем и состоянием» – 11 страниц;

Заключение – 2 страницы;

Список литературы – 11 страниц;

Приложение А – 4 страницы;

Приложение Б – 33 страницы.

Краткая характеристика полученных результатов *(по разделам ВКР)*

Раздел 1. Агрегация сведений об атаках класса «Манипулирование временем и состоянием».

Сформирована база данных кибератак класса «Манипулирование временем и состоянием» на АИС, аккумулирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников;

Раздел 2. Формирование сценариев шаблонов атак CAPEC как последовательности реализации техник MITRE ATT&CK.

Реализовано векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE и CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС;

Раздел 3. Моделирование микромоделей сценариев шаблонов атак, оценка критичности уязвимостей и рисков успешности реализации сформированных сценариев атаки.

Сформирована методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Манипулирование временем и состоянием», с учётом специфики используемых злоумышленников сценариев;

Раздел 4. Разработка регламентов реагирования и ликвидации последствий инцидентов безопасности для наиболее опасных сценариев атак класса «Манипулирование временем и состоянием».

Разработан комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Манипулирование временем и состоянием» на уязвимости АИС.

Автор ВКР _____ Казаков Андрей Викторович

(подпись)

СОДЕРЖАНИЕ

Введение 8

1 Агрегация сведений об атаках класса «Манипулирование временем и состоянием» 15

1.1 Применимость распространенных баз знаний в задаче агрегации сведений об атаках 15

1.2 Сравнительный анализ систем оценки критичности уязвимостей для задач риск-ориентированного моделирования 21

2 Формирование сценариев шаблонов атак CAPEC как последовательности реализации техник MITRE ATT&CK 26

2.1 Соответствие элементов множеств компьютерных уязвимостей и кибератак класса «Манипулирование временем и состоянием» 26

2.2 Разложение шаблонов CAPEC атаки на техники MITRE ATT&CK 47

2.2.1 Обоснование выбора тактик и техник MITRE ATT&CK для сценария по шаблону атаки CAPEC-25 56

2.2.2 Обоснование выбора тактик и техник MITRE ATT&CK для сценария по шаблону атаки CAPEC-27 67

2.2.3 Обоснование выбора тактик и техник MITRE ATT&CK для сценария по шаблону атаки CAPEC-140 80

2.2.4 Обоснование выбора тактик и техник MITRE ATT&CK для сценария по шаблону атаки CAPEC-696 87

3 Моделирование микромоделей сценариев шаблонов атак, оценка критичности уязвимостей и рисков успешности реализации сформированных сценариев атаки 96

3.1 Оценка критичности уязвимостей релевантных заданным шаблонам атак 96

3.2 Оценка вероятностей успешного использования уязвимостей и рисков успешности реализации различных вариантов сформированных сценариев атак 111

4 Разработка регламентов реагирования и ликвидации последствий инцидентов безопасности для наиболее опасных сценариев атак класса «Манипулирование временем и состоянием» 136

Заключение 147

Список литературы 149

Приложение А 160

Приложение Б 164

ВВЕДЕНИЕ

Современные реалии киберпространства характеризуются непрерывным ростом угроз, нацеленным на компрометацию информационных систем, хищение данных и дестабилизацию их работы, как следствие проблема безопансости киберпространства [1-9] неуклонно возрастает по своей актуальности.

Так киберугрозы в 2024 году продемонстрировали устойчивый рост как по количеству инцидентов, так и по уровню наносимого ущерба. Согласно данным аналитических отчетов, общее число успешных атак увеличилось на 28% по сравнению с предыдущим годом, при этом наиболее часто мишенями становились организации критической инфраструктуры, на которые пришлось 42% всех зафиксированных атак. Финансовые последствия также оказались значительными:

– средняя стоимость утечки данных превысила 5 млн долларов США;

– совокупные глобальные потери от киберпреступности достигли 12 трлн долларов, что на 35% выше показателей 2023 года.

В Российской Федерации динамика киберпреступности сохранила тенденцию к росту. Объем средств, похищенных с банковских счетов, составил 45 млрд рублей, что на 64% больше, чем годом ранее.

Основные векторы атак составила следующая четверка:

– 22% компании сталкиваются с угрозой утечки информации, из них 15% понесли серьезные ущербы в этой связи;

– 70% компаний испытали заражение вредоносным ПО;

– 73% компаний сталкиваются с несанкционированным доступом к информации;

– 62% компаний испытывают на себе DDoS-атаки.

Однако только 40% крупных компаний имеют отделы, обеспечивающих кибербезопасность, а в 55% компаний за информационную безопасность отвечают IT-службы. При этом 83% компаний хотят перейти на обслуживание во внешний центр мониторинга кибербезопасности.

Современные подходы к оценке критичности информационной инфраструктуры опираются на стандартизированные базы знаний [10-14] и автоматизированные инструменты анализа для количественной оценки критичности уязвимостей [15-20] и автоматизация процессов поиска и анализа уязвимостей [21-24]. Комплексное применение перечисленных методологий и инструментов позволяет организациям выявлять существующие уязвимости и прогнозировать потенциальные векторы атак.

При этом неоднородность и частичная ограниченность информационных возможностей указанных инструментов свидетельствуют о необходимости дальнейших научных изысканий, нацеленных на совершенствование и унификацию применяемых методик. [26-41]

Направленность перечисленных работ сосредоточена на организационно-правовых аспектах защиты корпоративных сетей [27-29, 31-32, 55-57], разработке нейросетевых методов противодействия кибератакам [33, 50-54, 62-64] и анализе угроз различного типа [34-39, 41-44, 58]. Значительная часть работ посвящена вопросам риск-анализа и моделированию угроз [36-39, 54, 60], а также картографированию киберпространства [28, 46-48]. Отдельное внимание уделяется методическим аспектам подготовки специалистов [27-29, 29, 49] и разработке автоматизированных систем анализа уязвимостей [50-53]. При этом отмечается, что существующие исследования охватывают различные объекты защиты: от отдельных предприятий [27-29, 31, 55] до телекоммуникационных сетей [36-37] и распределённых информационных систем [46, 52]. Объединяющим фактором выступает фокус на проблемах оценки и регулирования информационных рисков, что соответствует предмету настоящего исследования.

С развитием информационных технологий и усложнением архитектуры корпоративных сетей, обеспечение последовательности работы процессов программного обеспечения и, как следствие, надежности защищаемой системы зависит от согласованности состояний системы. Нарушение корректности выполнения операций может привести к серьезным сбоям в работе системы или даже к ее неработоспособности. Особенно уязвимы к таким атакам системы,

работающие в многозадачном режиме, где несколько процессов одновременно пытаются получить доступ к одному и тому же ресурсу. Из чего следует, что атаки, направленные на манипулирование временем и состоянием системы, представляют собой серьёзную угрозу, способную вывести из строя критические компоненты информационной инфраструктуры защищаемой сети.

В этом контексте, относительно атак класса «Манипулирование временем и состоянием», актуальна проблема агрегации разрозненных источников данных в единую семантическую модель, обогащенную мерами противодействия и оценками эффективности защитных мер. Отсутствие таких структурированных баз знаний является ключевым фактором, ограничивающим эффективность противодействия предметному классу атак.

Анализ существующих исследований показывает, что распространённые подходы к оценке угроз зачастую не учитывают таксономию MITRE ATT&CK, что ограничивает возможности анализа последовательности действий злоумышленника и контекстной критичности воздействия. Особенно заметен недостаток интеграции современных методов вероятностной оценки рисков с адаптивными коэффициентами критичности, что снижает практическую ценность предлагаемых защитных механизмов.

Настоящее исследование предлагает методику оценки успешности атак класса «Манипулирование временем и состоянием» в автоматизированных информационных системах, основанную на: сценарном подходе к анализу цикла жизни атаки, классифицирующий действия злоумышленника в соответствии с этапностью, предлагаемой таксономией MITRE ATT&CK; комплексной оценки критичности уязвимостей, эксплуатируемых злоумышленником в ходе атаки.

Таким образом, актуальность данного исследования заключается в разработке комплексной системы оценки и регулирования рисков успешности реализации кибератак класса «Манипулирование временем и состоянием» в автоматизированных информационных системах, включающей создание таксономии знаний об указанных атаках и уязвимостях операционных систем. Результаты работы, содержащие регламенты противодействия атакам данного

класса, позволяют не только внести значимый вклад в современную теорию кибербезопасности, но и повысить эффективность оперативного реагирования и устранения последствий инцидентов информационной безопасности на практике.

Целеполагание настоящего исследования предполагает, что:

Объектом исследования выступают автоматизированные информационные системы, подвергающиеся атакам класса «Манипулирование временем и состоянием».

Предметом исследования процессы обеспечения информационной безопасности автоматизированных информационных систем при воздействии кибератак класса «Манипулирование временем и состоянием», включающие анализ взаимосвязей между шаблонами атак, техниками и эксплуатируемыми уязвимостями, моделирование сценариев атак, оценку рисков с использованием различных метрик, а также разработку рекомендаций по противодействию подобным инцидентам на основе анализа вероятности эксплуатации уязвимостей и потенциального ущерба.

Цель исследования состоит в повышении защищенности автоматизированных информационных систем от атак класса «Манипулирование временем и состоянием».

Исследование аналогов показало наличие ряда **противоречий** между:

– необходимостью наличия достаточного объема данных и иных актуальных сведений относительно пар «атака – уязвимость» для атакуемых автоматизированных информационных систем и отсутствием такового для атак класса «Манипулирование временем и состоянием»;

– потребностью установления соответствия элементов множества рассматриваемого класса атак и уязвимостей, обусловленных отсутствием таковых в проектном пространстве обеспечения безопасности защищенных автоматизированных информационных систем;

– существующей методологией вероятностной оценки опасности кибератак класса «Манипулирование временем и состоянием» использующей

калькуляторы CVSS, EPSS, OWASP и необходимостью риск-анализа вторжений в автоматизированную информационную систему, которая отсутствует в сложившихся подходах;

– несовершенством процедур регламентации противодействия кибератакам класса «Манипулирование временем и состоянием» и необходимостью осуществлять такую проектную деятельность в соответствии с этапом реализации вторжения злоумышленника в автоматизированные информационные системы.

Для разрешения перечисленных противоречий и достижения поставленной цели необходимо решить следующие **задачи**:

– организация и сбор открытых интернет-источников и суммаризации данных относительно пар «атака – уязвимость» в отношении автоматизированных информационных систем;

– установление соответствия между кибератаками класса «Манипулирование временем и состоянием» и уязвимостями в автоматизированных информационных системах, включая их сценарное описание;

– оценка рисков нарушения информационной безопасности посредством кибератак класса «Манипулирование временем и состоянием» на уязвимости в автоматизированных информационных системах;

– формирование регламентов реагирования и ликвидации последствий в отношении кибератак класса «Манипулирование временем и состоянием» на уязвимости в автоматизированных информационных системах.

На защиту будут вынесены следующие **результаты**:

– структурированная база данных кибератак класса «Манипулирование временем и состоянием» на АИС, аккумулирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников;

– векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE и CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС;

– методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Манипулирование временем и состоянием», с учётом специфики используемых злоумышленников сценариев;

– комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Манипулирование временем и состоянием» на уязвимости АИС.

Новизна полученных результатов состоит в следующем:

– в отличие от аналогов, собранные данные с помощью предложенных выражений могут являться основой для вероятностного моделирования процесса реализации класса кибератак «Манипулирование временем и состоянием», используемых в автоматизированных информационных системах, что обеспечивает основу для комплексной оценки и регулирования рисков в сфере обеспечения кибербезопасности АИС;

– впервые для класса кибератак «Манипулирование временем и состоянием» была предложены обобщённая графическая модель сценариев атак, которые могут быть использованы злоумышленником для вторжения в АИС;

– в отличии от аналогов предложена методика оценки рисков сценариев нарушения информационной безопасности АИС при реализации кибератак класса «Манипулирование временем и состоянием», а также определены наиболее вероятные сценарии вторжения и сценарии максимального и минимального риска вторжения в АИС;

– для выявленных сценариев впервые предложены актуальные регламенты и методики противодействия кибератакам класса «Манипулирование временем и состоянием».

Практическая ценность полученных результатов видится в том, что:

– созданная база данных метрик кибератак класса «Манипулирование временем и состоянием» и уязвимостей АИС, является практической основой для риск-анализа единичных вторжений и имеет практическую возможность её расширения для соответствующих проектных ситуаций;

− сформированное множество сценариев и их рисканализ отражает практику реализации проектной деятельности защиты АИС от атак класса «Методы активного обнаружения уязвимостей и сервисов»;

− предоставленные оценки рисков представляют собой базу для их рецензирования при нарушении информационной безопасности АИС посредством кибератак класса «Манипулирование временем и состоянием», в том числе путём закрытия эксплуатируемых уязвимостей АИС;

− предложенная регламентация является инструментом практического управления риск-ландшафтом успешности кибератак класса «Манипулирование временем и состоянием» на защищаемые АИС.

Теоретическая значимость полученных результатов видится в том, что:

− сформированная база риск-метрик открыта для ее расширения на другие разновидности кибератак и прочие информационные системы, подверженные вторжению;

− разработанные сценарии атак класса «Манипулирование временем и состоянием» в ходе проектной деятельности могут быть расширены на другие используемые тактики, либо сужены до непосредственных уязвимостей конкретно защищаемой АИС;

− представленные оценки рисков нарушения информационной безопасности посредством кибератак класса «Манипулирование временем и состоянием», могут быть развиты для описания рисков многократных, поточных, множественных и лавинных сетевых вторжений при соответствующей модернизации методического обеспечения риск-анализа;

− в ходе развития методологии управления риск-ландшафтом успешности кибератак класса «Манипулирование временем и состоянием» на уязвимости защищаемых АИС предоставляется возможным формирование соответствующих инструкций для специалистов по защите информации, обеспечивающих безопасность конкретных АИС.

1 Агрегация сведений об атаках класса «Манипулирование временем и состоянием»

1.1 Применимость распространенных баз знаний в задаче агрегации сведений об атаках

Современные системы классификации вредоносов представляют собой стандартизированные системы описания распространенных шаблонов атак (CAPEC), типов ошибок программного обеспечения (CWE), уязвимостей (NVD и БДУ ФСТЭК) и классификации действий злоумышленника (MITRE ATT&CK), каждая из которых решает специфические задачи категоризации и систематизации знаний о киберугрозах. Предлагаемый подход основывается на принципах многоуровневой структуры данных, включающей табличное ядро, текстовый контекстный слой и нормализованные метаданные. Важным элементом методики является паспортизация данных с использованием стандартизированных форм представления информации об уязвимостях и шаблонах атак. Это позволяет унифицировать идентификаторы и классификаторы, а также создать механизмы связывания разнородных данных. [29, 34, 47, 48, 51-54]

CAPEC разработана для классификации паттернов атак на основе их базовых принципов функционирования. Это общедоступный каталог распространенных шаблонов атак, который помогает пользователям и специалистам по информационной безопасности понять, как злоумышленники используют слабые места в приложениях и другие возможности кибератак [10].

Шаблон атаки представляет собой описание общих атрибутов и методов, которые злоумышленники применяют для эксплуатации известных уязвимостей в системах. Он основывается на концепции шаблонов проектирования, но используется в деструктивном контексте. Создание шаблона атаки происходит на основе глубокого анализа реальных случаев.

Каждый шаблон атаки содержит информацию о том, как разрабатываются и выполняются конкретные части атаки, и дает рекомендации о способах снижения

эффективности атаки. Более подробная структура описания шаблонов атак представлена в таблице 1.

Таблица 1 – Структура описания шаблонов атак в каталоге CAPEC

Поле карточки шаблона атаки CAPEC	Описание
Идентификация и классификация шаблона атаки	Каждый шаблон имеет уникальный идентификатор (вида CAPEC-XXX) и название Атаки классифицируются по категориям детализации их представления
Описание шаблона атаки	Цель атаки – принцип воздействия на уязвимые системы Метод эксплуатации – концептуальный алгоритм атаки Предварительные условия реализации атаки
Связь с другими шаблонами атаки	Поле, где указана иерархия и взаимосвязи между шаблонами атаки
Рекомендации по защите	Рекомендации общего характера по противодействию предметному шаблону атаки
Примеры реальных инцидентов	Сведения общего характера о реализации предметного шаблона атаки
Связи с другими базами знаний	Помимо выделения связей с таксономией типов программных ошибок, могут быть указаны связи с таксономией техник и тактик MITRE ATT&CK

Национальная база данных уязвимостей (NVD) представляет собой стандартизированный каталог уязвимостей программного обеспечения, поддерживаемый Национальным институтом стандартов и технологий США (NIST). В ней содержатся технические описания уязвимостей, оценки их критичности по шкале CVSS, а также ссылки на соответствующие исправления. Однако структура NVD ориентирована преимущественно на западный рынок программного обеспечения и не всегда полно отражает специфику российских информационных систем. Основное ограничение NVD заключается в относительно кратких, формализованных описаниях, которые зачастую не содержат достаточного контекста для анализа паттернов уязвимостей. [[11, 16-18, 34]

База данных уязвимостей ФСТЭК России разработана с учетом особенностей отечественного информационно-технологического ландшафта и нормативных требований. Ее ключевое преимущество перед NVD заключается в более детализированных описаниях уязвимостей, включающих анализ условий эксплуатации, возможных векторов атаки и специфичных для российского рынка

программных продуктов (таблица 2). БДУ ФСТЭК обеспечивает инцидентность с NVD, сохраняя при этом дополнительную аналитическую информацию, что делает ее более предпочтительным источником для формирования базы данных для последующего анализа потенциальных действий злоумышленника. [11-12, 34]

Таблица 2 – Структура описания уязвимостей в базе данных уязвимостей БДУ ФСТЭК

Поле карточки уязвимости БДУ ФСТЭК	Описание
Идентификатор уязвимости	Каждой уязвимости присвоен идентификатор (вида BDU:XXXX-XXXXX)
Описание уязвимости	В данном поле указаны техническое описание уязвимости и негативное последствие, в случае ее эксплуатации
Уязвимое ПО	В данном поле указаны наименование уязвимого программного обеспечения и его версию
Тип ошибки	В данном поле указаны наименование и идентификатор типа ошибки программного обеспечения, на котором основана предметная уязвимость
Базовый вектор уязвимости	В данном поле указаны метрики системы CVSS, характеризующие возможности эксплуатации уязвимости, а также скалярное представление критичности уязвимости, дифференцированное по шкале от 0 до 10
Возможные меры по устранению уязвимости	В данном поле приведены сведения способствующие выработке мер противодействия эксплуатации предметной уязвимости
Статус уязвимости	В данном поле указан параметр, принимающий одно из следующих значений: "Подтверждена", "Требуется уточнение", "Устранена"
Наличие эксплойта	В данном поле указан параметр, принимающий три значения: "Да/Нет" или ссылка на публичный эксплойт
Способ эксплуатации	В данном поле указана задача на эксплуатацию предметной уязвимости
Способ устранения	В данном поле указано обобщенная рекомендация по устранению уязвимости
Способ устранения и информация об устранении	В данном поле указана информация по устранению уязвимости производителем программного обеспечения
Ссылки на источники	В данном поле указаны ссылки на источники, которые были использованы при классификации предметной уязвимости
Идентификаторы других систем описаний уязвимостей	В данном поле, как правило, указывается идентификатор уязвимости системы CVE, и в случае наличия, идентификаторы других систем классификации уязвимостей программного обеспечения
Эксплуатация в реальных атаках	В данном поле указаны отчеты об эксплуатации предметной уязвимости в реальных атаках, в случае наличия соответствующей информации

Таксономия MITRE ATT&CK представляет собой систематизированное описание тактик и техник, используемых злоумышленниками на различных этапах жизненного цикла кибератаки. Структурно она организована в виде матрицы, где тактики соответствуют целям атакующего, а техники и подтехники описывают конкретные методы достижения этих целей. [13]

Тактики в ATT&CK описывают стратегические цели атакующего на каждом этапе компрометации системы, такие как первоначальное проникновение, расширение привилегий или сбор данных. Эти описания позволяют структурировать данные о кибератаках по их функциональному назначению, что важно для построения комплексных моделей угроз. Техники и подтехники предоставляют более детализированную информацию о конкретных методах реализации атак, в связи с чем представляют ценность в формировании агрегации актуальных сведений для анализа потенциальных действий злоумышленника. [13, 51-52, 64-65]

Каждая техника и подтехника содержит детальное описание, включающее примеры реализации, рекомендуемые меры противодействия и методы обнаружения (таблица 3), что делает ATT&CK ценным источником для анализа моделей поведения злоумышленников.

Таблица 3 – Структура описания техник/подтехник в базе данных MITRE ATT&CK

Поле карточки техники/подтехники MITRE ATT&CK	Описание
Сведения о технике	В этом поле указаны: идентификатор; связь с объектами классификации данной таксономии; система (в рамках которой данная техника осуществима); дата создания и изменения
Описание техники/подтехники	В данном поле указаны цель на осуществление предметной техники/подтехники, принцип и характер действий на предметную технику/подтехнику, контекст в рамках которой осуществляется предметная техника

Продолжение таблицы 3

Поле карточки техники/подтехники MITRE ATT&CK	Описание
Примеры процедур	В данном поле зафиксированы примеры применения предметной техники/подтехники в рамках документированных инцидентов, где каждому примеру присвоен идентификатор и имеется описание действий злоумышленников в рамках предметной техники (каждый пример процедуры также задокументирован и классифицирован в рамках MITRE ATT&CK)
Меры противодействия предметной технике/подтехнике	В данном поле указаны меры противодействия осуществления предметной техники/подтехники, указаны идентификаторы и наименование групп мер по противодействию (такие объекты классифицированы также, как и примеры процедур, и имеют представление в системе ATT&CK Navigator)
Обнаружение	В данном поле указаны рекомендации по мониторингу и обнаружению факта реализации предметной техники/подтехники, по аналогии с мерами противодействия, объекты данного типа классифицированы в зависимости от контекста и вектора атаки, а также присвоены идентификаторы
Ссылки	В данном поле указаны ссылки на статьи на основании которых проводилась агрегация данных по предметной технике/подтехнике

При агрегации сведений об атаках необходимо учитывать характер указанных таксономий, т.к. содержащимся в них данным свойственна неполнота, что определяет их в категорию неразмеченных данных. CAPEC обеспечивает понимание фундаментальных принципов атак, CWE раскрывает их первопричины, БДУ ФСТЭК предоставляет данные о конкретных реализациях, а MITRE ATT&CK описывает оперативные аспекты проведения атак. Только комплексное использование таксономий с учетом их специфики и ограничений обеспечивает понимание причинно-следственную связь между отдельными действиями злоумышленника. [10, 12-14, 27-29, 34, 51-54]

Для преодоления проблемы формализации и унификации данных предлагается введение стандартизированных паспортов уязвимостей и шаблонов атак (таблица 4-5).

Таблица 4 – Структура формализации сведений о шаблоне атаки

Идентификатор системы CAPEC	CAPEC-XXX: …	
Описание шаблона атаки	…	
Тип атаки	…	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-XXX: …	…

Таблица 5 – Структура формализации сведений об уязвимости

Идентификатор уязвимости	CVE-XXXX-XXXXX
Описание уязвимости	…
Идентификатор типа ошибки	CWE-XXX
Базовый вектор уязвимости	…
Уровень опасности уязвимости	…
Статус уязвимости	…
Наличие эксплойта	…
Способ устранения	…
Участие в инцидентах	…

Паспорт шаблона атаки (таблица 4) содержит следующую информацию:

– идентификатор системы CAPEC – уникальный идентификатор и название шаблона атаки;

– описание вектора атаки – краткое описание вектора атаки, включая цель атаки;

– тип атаки – механизм атаки;

– соотношение типа ошибки CWE и статуса типа ошибки CWE – связанные с вектором атаки CWE и их статус.

Паспорт уязвимостей (таблица 5) содержит следующую информацию:

– уникальный идентификатор системы CVE;

– описание уязвимости – техническое описание уязвимости и негативное последствие, в случае ее эксплуатации;

– идентификатор типа ошибки – идентификатор типа ошибки программного обеспечения, на котором основана предметная уязвимость

– базовый вектор уязвимости –метрики системы CVSS, характеризующие возможности эксплуатации уязвимости;

– уровень опасности уязвимости – экспертная оценка критичности уязвимости в соответствии с системой CVSS версий 2.0 и 3.0, а также скалярное представление критичности уязвимости, дифференцированное по шкале от 0 до 10;

– статус уязвимости – параметр, принимающий одно из следующих значений: "Подтверждена", "Требуется уточнение", "Устранена";

– наличие эксплойта – параметр, принимающий три значения: "Да/Нет" или ссылка на публичный эксплойт;

– способ устранения – обобщенная рекомендация по устранению уязвимости;

– участие в инцидентах – количество упоминаний об эксплуатации в реальных инцидентах безопасности.

Предложенная паспортизация сведений (таблица 4-5) сохраняет все атрибуты исходных данных из таксономий и преобразует их в структурированную для формирования и анализа сценариев атак. Последующая паспортизация сведений о шаблонах атаки и уязвимостей, осуществлена в приложениях А и Б соответственно.

1.2 Сравнительный анализ систем оценки критичности уязвимостей для задач риск-ориентированного моделирования

Главный принцип в принятии решений по информационной безопасности заключается в зависимости уровня затрат на реализацию этих решений от

потенциального ущерба, в случае реализации угрозы. В рамках принципа минимакса осуществляется поиск оптимального решения, обеспечивающего максимальную эффективность защиты при минимальных ресурсных затратах. В этом контексте оценка критичности уязвимостей служит инструментом реализации этих принципов, позволяя количественно определить уровень угрозы и приоритетность ее устранения. В условиях ограниченности ресурсов на реализацию безопасности информации такая оценка обеспечивает рациональное распределение усилий по нейтрализации наиболее опасных уязвимостей. [35, 39, 55]

Существующие системы оценки предлагают различные методологические подходы к определению уровня опасности уязвимостей, каждый из которых обладает специфическими характеристиками и областью применения. В рамках настоящего исследования применен следующий инструментарий: CVSS v3.1/v4.0 (Common Vulnerability Scoring System), EPSS (Exploit Prediction Scoring System) и OWASP Risk Rating Methodology. [16-20, 27-29, 51-55]

CVSS – открытый стандарт, используемый для расчета количественных оценок уязвимости. Данная система обеспечивает комплексный подход к анализу уязвимостей через три группы метрик: базовые, временные и контекстные. Результатом расчета являются три числовые оценки: базовая, временная и контекстная. Каждая из оценок может принимать значение от 0 до 10, где: 0.0 (не критично); 0.1-3.9 (низкая критичность); 4.0-6.9 (средняя критичность); 7.0-8.9 (высокая критичность); 9.0-10.0 (критическая уязвимость). [16]

CVSS реализована в нескольких версиях, каждая из которых отражает эволюцию методологии оценки. Версия 2.0, выпущенная в 2007 году, заложила базовые принципы системы, но имела ограничения в части учета сетевых и локальных векторов атаки. Версия 3.0, представленная в 2015 году, ввела более детализированную систему оценки параметров атаки, включая требования к уровню привилегий и взаимодействию с пользователем. Версия 3.1, принятая в 2019 году, является развитием предыдущей версии 3.0 и сохраняет общую структуру метрик оценки и учитывая показатели сложности атаки и требований к взаимодействию с пользователем. Эти изменения повышают объективность оценки критичности

уязвимости. Последняя версия 4.0, выпущенная в 2023 году, представляет собой существенное развитие методологии оценки уязвимостей, учитывающая актуальность и распространенность эксплойтов оцениваемой уязвимости и возможность воздействия на другие узлы сети, актуальной для анализа каскадных эффектов при комплексных атаках. Эти изменения делают CVSS v4.0 более адаптивным инструментом для оценки современных киберугроз. [16-18, 61]

Система EPSS представляет собой вероятностную модель, разработанную для прогнозирования эксплуатации уязвимостей в течение определенного периода времени. В отличие от CVSS, фокусирующегося на технических характеристиках уязвимостей, EPSS основывается на статистическом анализе данных об эксплуатации, учитывая: наличие публичных эксплойтов, популярность уязвимого ПО и временные паттерны атак. В основе методологии лежат байесовские вероятностные модели и методы машинного обучения, которые выявляют корреляции между характеристиками уязвимостей и фактическими случаями их использования. [19]

EPSS предоставляет вероятностную оценку эксплуатации уязвимости в течение заданного периода времени. Оценка принимает значение в диапазоне от 0 до 100, где более высокие значения указывают на более вероятною эксплуатацию уязвимости в ближайшей перспективе. Применение данного инструмента в риск-ориентированном моделировании позволяет дополнить техническую оценку уязвимостей данными о вероятности их реального использования злоумышленниками.

Методология OWASP Risk Rating Methodology представляет собой систему оценки рисков, учитывающей два параметра: вероятность успешной эксплуатации уязвимости и потенциальное воздействие на бизнес-процессы. Результат оценки критичности по калькулятору OWASP может принимать значения в диапазоне от 0 до 10, где: 0-3 (низкая критичность); 3-6 (средняя критичность); 6-9 (высокая критичность); 9-10 (критическая уязвимость). Данная система отличается от CVSS и EPSS ориентацией на анализ контекстных факторов защищаемой системы, что обеспечивает более релевантную оценку рисков для конкретной организации. Такой

подход позволяет оценивать риски с точки зрения их реального влияния на функционирование информационной системы. [20]

В рамках риск-ориентированного моделирования сценариев атак методология OWASP предоставляет инструменты для учета специфики защищаемых активов и инфраструктуры целевой системы. Данный инструмент предполагает оценку таких параметров как ценность затронутых данных, критичность уязвимых систем и потенциальный ущерб, что позволяет ее адаптировать к конкретным условиям эксплуатации информационных систем.

Резюмируя вышесказанное, сравнительный анализ (таблица 6) показал, что рассмотренные системы оценки критичности уязвимостей демонстрируют принципиальные различия в методологических подходах и сферах применения:

– CVSS представляет собой технико-ориентированную систему, обеспечивающую стандартизированную оценку базовых характеристик уязвимости;

– EPSS фокусируется на прогнозировании вероятности эксплуатации уязвимости, используя статистические методы и машинное обучение;

– OWASP ориентирован на оценку бизнес-последствий эксплуатации уязвимости в конкретном организационном контексте.

Таблица 6 – Сравнительный анализ калькуляторов критичности

Критерий	CVSS	EPSS	OWASP
Цель	Оценка серьезности уязвимости	Прогнозирование эксплуатации уязвимости	Оценка критичности для безнес-процессов
Характер анализа	Влияние уязвимости на CIA-триаду и сложность ее эксплуатации	Наличие эксплойтов уязвимости и статистика эксплуатации уязвимости	Ценность уязвимого актива и зависимость от условий эксплуатации
Фокус	Уязвимости ПО	Эксплуатации уязвимости	Критичность эксплуатации для бизнес-процессов
Основные отличия	Статическая оценка уязвимости	Вероятность эксплуатации уязвимости (динамическая оценка)	Зависимость от условий эксплуатации узявимости

Проведенный анализ демонстрирует, что ни одна из рассмотренных методологий не способна в полной мере обеспечить комплексную оценку рисков,

связанных с уязвимостями информационных систем. Это обусловлено принципиальными различиями в их методологических подходах и фокусе анализа. В связи с этим возникает объективная необходимость в комбинированном использовании данных систем для достижения более точных и релевантных результатов оценки.

Таким образом, каждая из рассмотренных методологий обладает уникальными характеристиками, делающими её применение целесообразным в различных аспектах риск-ориентированного моделирования. CVSS обеспечивает техническую оценку уязвимости, EPSS дополняет её вероятностным прогнозом эксплуатации, а OWASP Risk Rating Methodology позволяет учесть контекстные факторы защищаемой системы. Комплексное использование этих инструментов позволяет получить наиболее точную и релевантную оценку критичности уязвимостей для оценки риска успешности атак. [27-29, 35-40, 51-55]

2 Формирование сценариев шаблонов атак CAPEC как последовательности реализации техник MITRE ATT&CK

2.1 Соответствие элементов множеств компьютерных уязвимостей и кибератак класса «Манипулирование временем и состоянием»

CAPEC представляет собой всестороннюю базу данных, предназначенную для классификации и описания различных шаблонов атак на программное обеспечение и системы информационной безопасности. Она была разработана с целью содействия специалистам по кибербезопасности в идентификации потенциальных угроз, понимании векторов атак и разработке эффективных методов защиты. Главной задачей CAPEC является детализированное описание методов осуществления атак, их целевых уязвимостей и возможных последствий для системы. Для каждой атаки, представленной в базе данных, содержится информация о том, каким образом она может быть выполнена, какие конкретные уязвимости используются злоумышленниками, а также рекомендации по предотвращению и смягчению последствий атаки. [10]

В CAPEC особое внимание уделено структуризации шаблонов атак. С этой целью введено понятие уровней абстракции, что позволяет из всего множества атак организовать несколько подмножеств и аналогичным образом далее разбивать множества на множества меньше. Таким образом, структура строится от общего к частному, т.е. от более общих паттернов атак к детальным и подробным. Причем множества организуются по общему свойству (или характеристике), что позволяет устанавливать взаимосвязанность между частностями.

Данная структуризация даёт возможность моделировать и анализировать векторы атак от наиболее общих категорий до специфичных шаблонов. Такой подход помогает выстраивать комплексные меры защиты, поскольку каждый уровень подробно освещает отдельные аспекты атак и позволяет ранжировать их по степени угрозы и необходимым методам противодействия. [31, 34-40, 53-54, 63]

Для ясности далее приведены ключевые термины, применяемые CAPEC для описания уровней атак: [10, 31]

– категория в CAPEC – это набор шаблонов атак, основанный на некоторой общей характеристике. Более конкретно, это совокупность шаблонов атак основанных на эффекте/намерении (в отличие от действий или механизмов, такая совокупность была бы шаблоном мета-атаки). Объединение, основанное на эффекте/намерении, не является атакой способной к действию, и, как таковое, не является модель поведения при атаке. Скорее, это группировка шаблонов на основе некоторых общих критериев.

– шаблон мета-атаки в CAPEC – это довольно абстрактная характеристика конкретной методологии или техники, используемой при атаке. Шаблон мета-атаки часто не содержит конкретной технологи или реализации и предназначен для обеспечения и понимания подхода высокого уровня. Шаблон атаки на метауровне – это обобщение связной группы шаблонов атак на стандартном уровне. Шаблоны атак на метауровне особенно полезны для моделирования угроз на уровне архитектуры и проектирования.

– схема атаки стандартного уровня в CAPEC ориентирована на конкретную методологию или технику, используемую при атаке. Ее часто рассматривают как отдельную часть полностью выполненной атаки. Стандартный шаблон атаки предназначен для предоставления достаточной информации, чтобы понять конкретную технику и то, как с ее помощью достигается желаемая цель. Шаблон атаки стандартного уровня – это особый тип более абстрактного шаблона атаки на метауровне.

– подробный шаблон атаки в CAPEC обеспечивает низкий уровень детализации, обычно использует определенную технику и нацелен на конкретную технологию, а также отражает полный ход выполнения, Подробные схемы атак более специфичны, чем шаблоны мета-атак и стандартные схемы атак, и часто требуют специального механизма защиты для предотвращения реальных атак. Подробная схема атаки часто использует несколько различных схем атаки на стандартном уровне, связанных вместе для достижения цели.

В контексте данной работы, CAPEC играет важную роль, так как в ней содержатся подробности об атаках, связанных с манипулированием временем и состоянием. На основании нее представляется возможным сформировать таксономию потенциальных векторов атак, актуальных для предметной области настоящего исследования, а также разработать соответствующие регламенты и инструкции.

Класс атак «Манипулирование временем и состоянием» описан в каталоге CAPEC с идентификатором CAPEC-172 и уровнем абстракции «категория». Адаптированное описание данной категории выглядит следующим образом: «Схемы атак в рамках этой категории сосредоточены на эксплуатации уязвимостей в механизмах синхронизации и сохранения состояния для выполнения действий, которые были бы невозможны при корректной работе системы. Эти атаки направлены на изменение последовательности выполнения кода и процессов в целевой системе. Примером атаки на состояние является изменение злоумышленником данных приложения, что позволяет манипулировать видимыми учётными записями или другими важными данными для получения несанкционированного доступа к ресурсам. В случае атаки на синхронизацию, например, атаки на состояние гонки, злоумышленник использует временное окно между проверкой состояния и выполнением операции для изменения условий выполнения действия. Это позволяет ему влиять на результат выполняемой операции в своих интересах.».[10]

В данной категории атак имеют членство следующее множество мета-шаблонов атак:

– CAPEC-25: Принудительная взаимоблокировка;
– CAPEC-26: Использование состояния гонки;
– CAPEC-74: Манипулирование состоянием.

Данную классификацию возможно представить в виде древовидной структуры (рисунок 1).

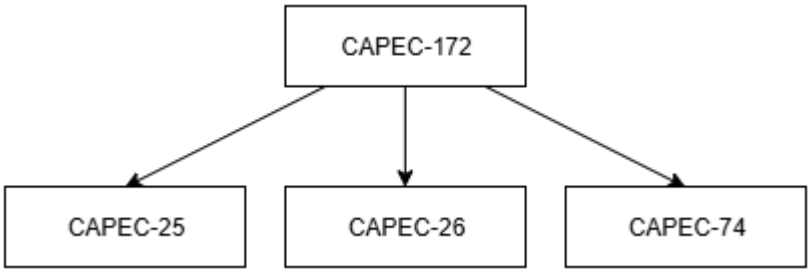


Рисунок 1 – Древо шаблонов атак CAPEC

Для дальнейшего моделирования полного множества векторов атак, целесообразно рассмотреть подробное описание приведенных шаблонов. Т.к. этот шаг позволит детальнее понять их природу и механизмы, что обеспечит более полное понимание сценариев атак, что критично для комплексного анализа.

Адаптированное описание шаблона CAPEC-25: «Злоумышленник вызывает и использует состояние взаимоблокировки в целевом программном обеспечении, чтобы вызвать отказ в обслуживании. Состояние взаимоблокировки может возникнуть, когда два или более конкурирующих процесса ожидают завершения друг друга, но ни одно из них не завершается. Состояние взаимоблокировки может быть трудно обнаружить.».[10]

Принудительная взаимоблокировка может происходить в многозадачных операционных системах, распределенных системах, базах данных и других средах, где доступ к общим ресурсам координируется через механизмы синхронизации, такие как семафоры, мьютексы или блокировки.

Адаптированный вид первого требования: «Целевой хост находится в состоянии тупика. Существует четыре условия возникновения тупика, известные как условия Коффмана.». Иными словами, данная атака возможна только, если целевая система находится в состоянии, при котором возможно возникновение тупика. Это означает, что система (приложение) допускает возможность блокировки, при которой процессы или потоки не могут завершиться из-за взаимозависимости. Тупик основывается на условиях Коффмана: [10]

– взаимное исключение: ресурсы, необходимые для выполнения задачи, не могут быть использованы другими процессами, если уже заняты.

– удержание и ожидание: процессы удерживают уже выделенные ресурсы, запрашивая дополнительные, что приводит к их ожиданию.

– невозможность принудительного освобождения: ресурс не может быть изъят принудительно у процесса до того, как он сам его освободит.

– циклическое ожидание: существует замкнутый цикл, в котором каждый процесс ожидает ресурс, удерживаемый другим процессом в этом цикле.

Адаптированный вид второго требования: «Целевой хост предоставляет пользователю API». Т.е. для этой атаки необходим доступ к приложению или системе через программный интерфейс (API), посредством которого злоумышленник может запрашивать ресурсы или иным образом взаимодействовать с системой.

Цикл жизни шаблона атаки CAPEC-25 можно представить в виде следующей последовательности:

1) разведка: Злоумышленник начинает с ознакомления с целевой системой, что включает в себя сбор информации о системе, её ресурсах и возможных способах взаимодействия с ними.

2) планирование и подготовка: На данном этапе противник планирует конкретные действия для создания состояния взаимоблокировки, которое приведет к отказу в обслуживании. Он подготавливает свои инструменты для управления ресурсами и манипуляции очередями запросов.

3) воздействие (создание состояния взаимоблокировки): Злоумышленник запускает процесс, посредством которого возможно захватить ресурс, необходимый для выполнения другого целевого легитимного процесса. Затем запускается целевой процесс, который должен дождаться освобождения ресурса, уже захваченного злоумышленником. В этот момент целевая программа окажется в состоянии тупика и будет пребывать в нем бесконечно долго, так как легитимный процесс не может завершиться до тех пор, пока первый не освободит ресурс. Эта ситуация вызывает отказ в обслуживании.

Результат реализации CAPEC-25 заключается в нарушении функционирования системы и возможных вторичных последствиях: значительное замедление работы ПО, сбои в обслуживании пользователей, потеря данных, нарушение их целостности или недоступности критических объектов.

В базе данных CAPEC, в описании рассматриваемого шаблона атаки, явно не указаны дочерние шаблоны атак и иные связи с другими шаблонами. Отсутствие таковых говорит о том, что «Принудительная взаимоблокировка» рассматривается как достаточно самостоятельный вид атаки. В этой связи, целесообразно привести множество программных ошибок, на которых зиждется данный шаблон атаки, и указать базирующиеся на них множества уязвимостей. [10]

В целях повышения актуальности результатов на выборки уязвимостей исследования наложены ограничения, а именно: из анализа исключены уже устраненные уязвимости и рассматриваются только уязвимости операционных систем. С учетом вышесказанного, данную структуру возможно представить в виде древовидного графа (рисунок 2) и таблицы 7.

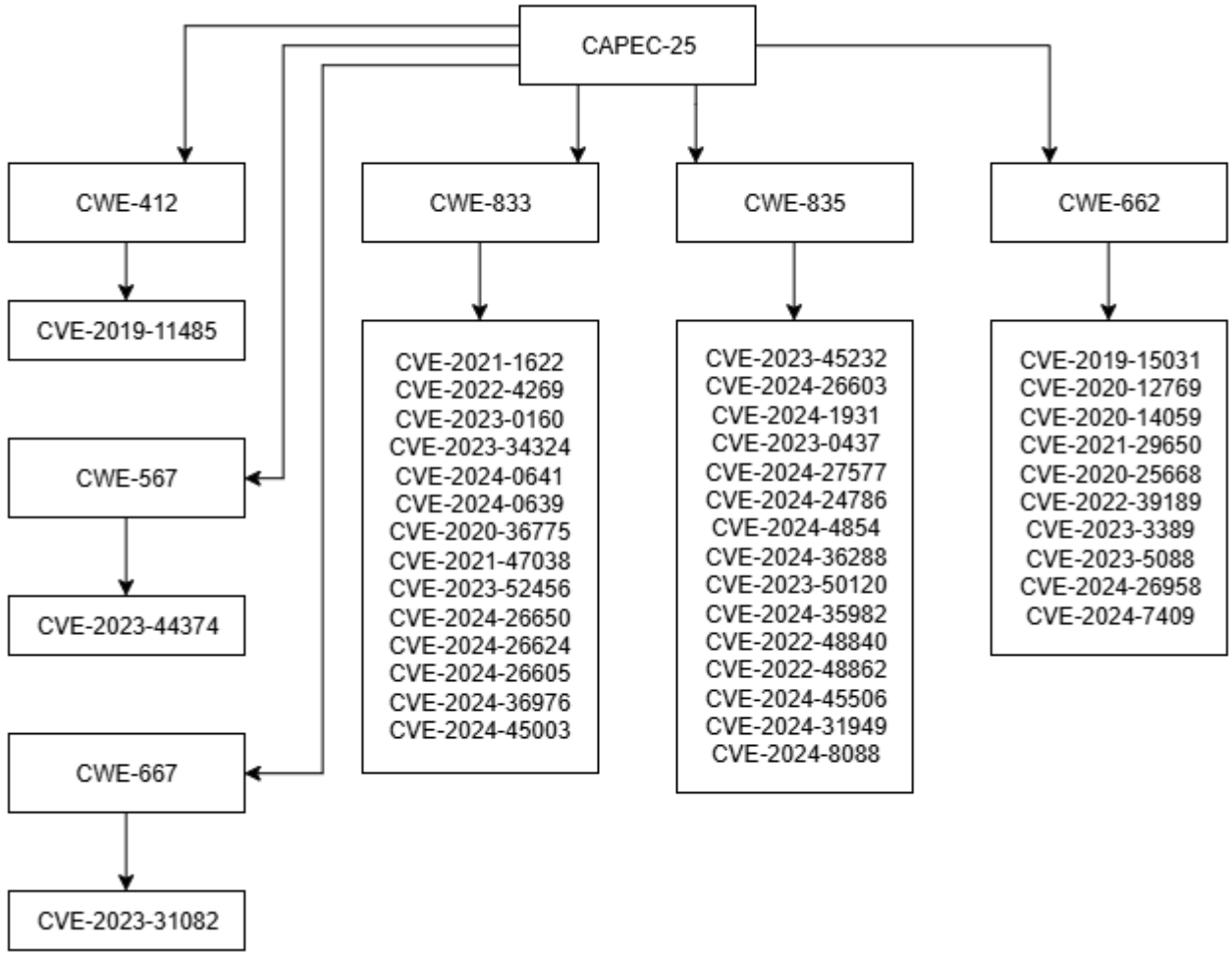


Рисунок 2 – Древо связей CAPEC-25, CWE и CVE

Таблица 7 – Соответствие CAPEC-25 с эксплуатируемыми уязвимостями

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок CWE	Связанные уязвимости CVE
CAPEC-25	Принудительная взаимоблокировка	CWE-412	CVE-2019-11485
		CWE-567	CVE-2023-44374
		CWE-667	CVE-2023-31082
		CWE-833	CVE-2021-1622
			CVE-2022-4269
			CVE-2023-0160
			CVE-2023-34324
			CVE-2024-0641
			CVE-2024-0639

Продолжение таблицы 7

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок CWE	Связанные уязвимости CVE
CAPEC-25	Принудительная взаимоблокировка	CWE-833	CVE-2020-36775
			CVE-2021-47038
			CVE-2023-52456
			CVE-2024-26650
			CVE-2024-26624
			CVE-2024-26605
			CVE-2024-36976
			CVE-2024-45003
		CWE-835	CVE-2023-45232
			CVE-2024-26603
			CVE-2024-1931
			CVE-2023-0437
			CVE-2024-27577
			CVE-2024-24786
			CVE-2024-4854
			CVE-2024-36288
			CVE-2023-50120
			CVE-2024-35982
			CVE-2022-48840
			CVE-2022-48862
			CVE-2024-45506
			CVE-2024-31949
			CVE-2024-8088
		CWE-662	CVE-2019-15031
			CVE-2020-12769
			CVE-2020-14059

Продолжение таблицы 7

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок CWE	Связанные уязвимости CVE
CAPEC-25	Принудительная взаимоблокировка	CWE-662	CVE-2021-29650
			CVE-2020-25668
			CVE-2022-39189
			CVE-2023-3389
			CVE-2023-5088
			CVE-2024-26958
			CVE-2024-7409

Выборки уязвимостей сформированы на основании каталога уязвимостей БДУ ФСТЭК. Главным критерием, по которому был выбран данный ресурс, стал удобный пользовательский интерфейс. Он выгодно отличается гибкостью настроек поиска и фильтрации результатов в сравнении с аналогами. Также следует отметить, что записи в базе данных БДУ ФСТЭК России предоставляют более подробную информацию о различных аспектах, связанных с уязвимостью, чем иностранные реестры уязвимостей CVE и NVD, предоставляемые американскими некоммерческими и государственными организациями. [10, 12, 14, 35-40, 66-67]

В каталоге CAPEC, в информации по меташаблону CAPEC-25 содержатся ссылки на вышеуказанные программные ошибки и если одна из уязвимостей, связанных с шаблоном, существует на атакуемом хосте, то атака считается успешной, а последствия успешной эксплуатации уязвимости (ущерб свойствам безопасности и/или полученные привилегии) – постусловиями шаблона атаки. В противном случае атака считается безуспешной. [10]

Адаптированное описание шаблона атаки CAPEC-26 выглядит следующим образом: «Злоумышленник эксплуатирует состояние гонки, возникающее при параллельном доступе нескольких процессов к общему ресурсу, когда результат операции зависит от последовательности выполнения операций доступа. Методика атаки основана на активном участии в гонке за ресурс с целью модификации его

состояния в момент между проверкой условий и фактическим выполнением операции. Типичным примером является атака на файловые операции, где злоумышленник заменяет целевой файл вредоносной версией после его проверки, но до момента использования системой.» [10]

Состояние гонки представляет собой специфическое условие параллельной обработки, при котором конфликтующие операции доступа к общему ресурсу выполняются без должной синхронизации. Критическим фактором является наличие временного окна «время поиска – время использования (time-of-check to time-of-use, TOCTOU)» между этапами проверки состояния ресурса и его фактического использования. Данное окно уязвимости позволяет злоумышленнику, действующему параллельно с легитимным процессом, модифицировать ресурс таким образом, что система продолжает выполнение, основываясь на устаревших или скомпрометированных данных проверки. Успешная эксплуатация требует строгой временной синхронизации атакующих действий с целевыми операциями системы. [10]

Мета-шаблон CAPEC-26 связан с более подробными шаблонами атак, базирующиеся на различных уязвимостях операционной системы, требованиях к их реализации и результатах эксплуатации:

– CAPEC-29: Использование условий гонки по времени проверки и использования (TOCTOU);

– CAPEC-27: Использование состояния гонки через символьные ссылки.

Данная детализация позволяет систематизировать и классифицировать тактики и техники атак, которые злоумышленники могут использовать для достижения своих целей.

Классификацию взаимосвязей CAPEC-26 с другими шаблонами можно представить в виде графа (рисунок 3).

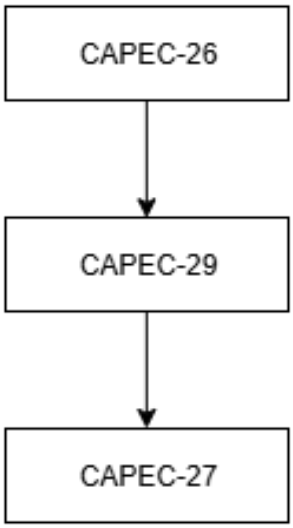


Рисунок 3 – Древо мета-шаблона CAPEC-26

Адаптированное описание шаблона атаки CAPEC-27: «Злоумышленник осуществляет компрометацию конфиденциальных данных посредством эксплуатации условий гонки при обработке символьных ссылок (symbolic links). Методика основана на создании символической ссылки, указывающей на целевой защищенный файл, доступ к которому ограничен правами привилегированного пользователя. Когда привилегированный процесс выполняет операции с временным файлом, имя которого совпадает с созданной злоумышленником символьной ссылкой, происходит перенаправление операций записи на защищенный ресурс. Успешная эксплуатация требует точной синхронизации между моментом проверки существования файла и фактическим созданием временного файла привилегированным процессом.» [10]

Принцип действия CAPEC-27 сводится к созданию злоумышленником состояния гонки, связанное с обработкой символьных ссылок в файловой системе, с целью нарушения целостности данных. Символьные ссылки представляют собой специальные файлы, которые указывают на другой файл или директорию, не содержащие реальных данных, но перенаправляющие операции ввода-вывода на указанный ресурс. Атака строится на моменте несоответствия между временем проверки состояния объекта (например, файла) и моментом его использования.

Существует три предварительных требования для реализации атаки типа «Использование состояния гонки через символьные ссылки»: [9]

– злоумышленник должен иметь права доступа, чтобы создавать символьные ссылки в файловой системе.

– вредоносные данные злоумышленника используются и копируются во временные файлы.

– целевой хост создает небезопасный временный файл, например, в общем каталоге с правами доступа, позволяющими другим пользователям модифицировать файлы.

Структура связей шаблона атаки с типами программных ошибок, и, как следствие, с уязвимостями имеет представление в виде древовидного графа (рисунок 4) и таблицы 8.

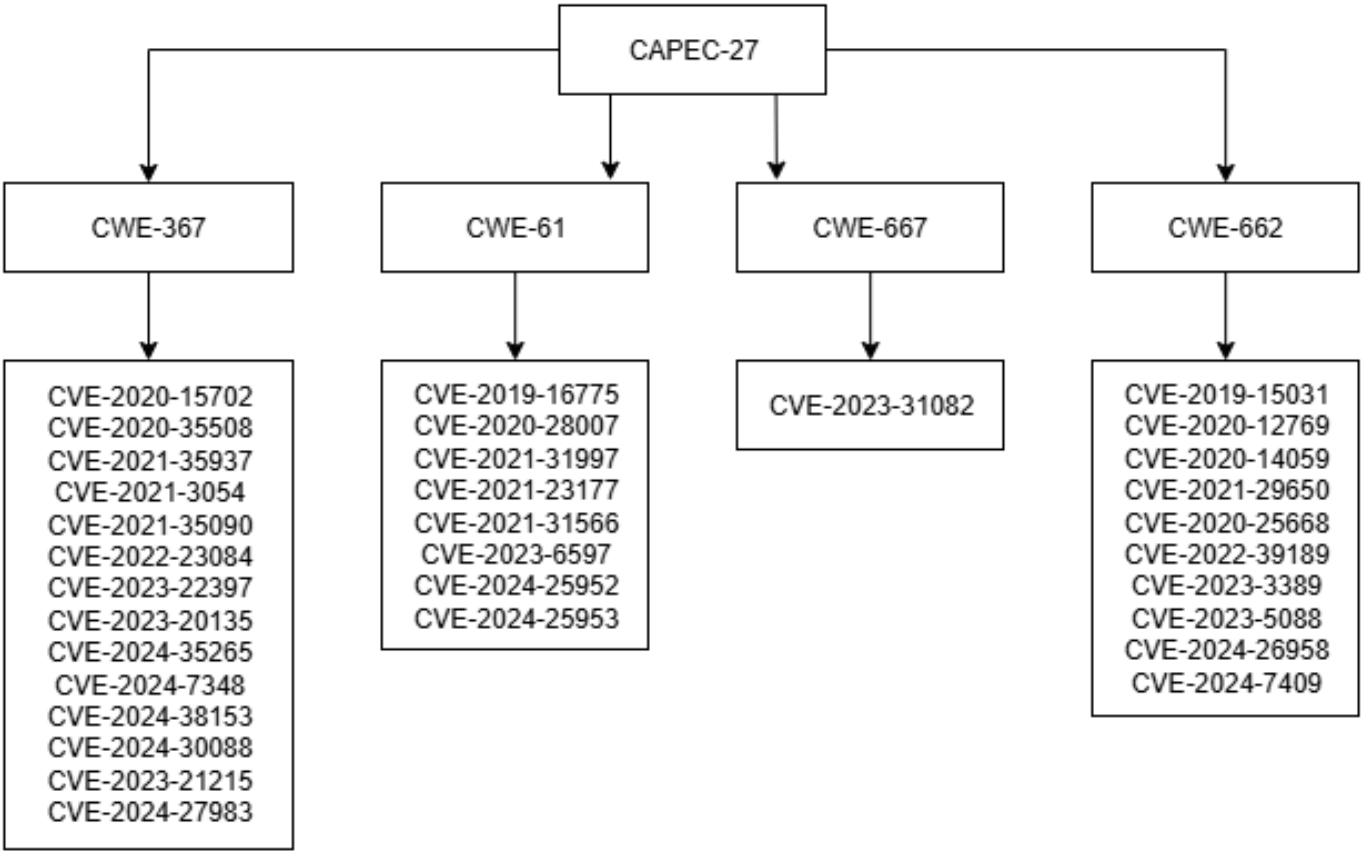


Рисунок 4 – Древо связей CAPEC-27, CWE и CVE

Таблица 8 – Соответствие CAPEC-27 с эксплуатируемыми уязвимостями

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок CWE	Связанные уязвимости CVE
CAPEC-27	Использование состояния гонки через символьные ссылки	CWE-367	CVE-2020-15702
			CVE-2020-35508
			CVE-2021-35937
			CVE-2021-3054
			CVE-2021-35090
			CVE-2022-23084
			CVE-2023-22397
			CVE-2023-20135
			CVE-2024-35265
			CVE-2024-7348
			CVE-2024-38153
			CVE-2024-30088
			CVE-2023-21215
			CVE-2024-27983
		CWE-61	CVE-2019-16775
			CVE-2020-28007
			CVE-2021-31997
			CVE-2021-23177
			CVE-2021-31566
			CVE-2023-6597
			CVE-2024-25952
			CVE-2024-25953
		CWE-667	CVE-2023-31082
		CWE-662	CVE-2019-15031
			CVE-2020-12769
			CVE-2020-14059

Продолжение таблицы 8

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок CWE	Связанные уязвимости CVE
CAPEC-27	Использование состояния гонки через символьные ссылки	CWE-662	CVE-2021-29650
			CVE-2020-25668
			CVE-2022-39189
			CVE-2023-3389
			CVE-2023-5088
			CVE-2024-26958
			CVE-2024-7409

Цикл жизни шаблона атак CAPEC-27 можно представить в виде следующей последовательности: [10]

– разведка: Злоумышленник проводит анализ поведения целевого приложения с целью выявления операций взаимодействия с файловой системой. Особое внимание уделяется процедурам, выполняющим проверку существования файлов перед их использованием. На данном этапе идентифицируются временные окна между операциями проверки (check) и использования (use), составляющие основу для эксплуатации TOCTOU-уязвимостей.

– подготовка: Атакующий создает символическую ссылку, первоначально указывающую на легитимный файл в доступной ему директории. Краеугольным камнем на этапе подготовки является обеспечение условий для быстрой замены целевого объекта файловой системы в момент уязвимого временного окна. Подготовительные действия включают получение минимальных привилегий, необходимых для манипуляции символическими ссылками в целевой директории.

– воздействие: В уязвимом временном интервале между проверкой и использованием файла привилегированным процессом, злоумышленник осуществляет атомарную замену легитимного файла на подготовленную символическую ссылку. В результате привилегированный процесс, выполняя операции с "файлом", фактически взаимодействует с объектом, на который

перенаправляет символическая ссылка. Особую опасность представляет случай, когда целевой объект находится в директории, недоступной для записи непривилегированному пользователю.

Результат реализации шаблона атаки CAPEC-27 заключается в получении злоумышленником несанкционированного доступа к конфиденциальным данным в системе (для определенных объектов), или в вызове отказа в обслуживании, если манипуляции с файлами нарушат функционирование системы. [10]

Адаптированное описание шаблона атаки «Манипулирование состоянием: CAPEC-74» выглядит следующим образом: «Злоумышленник изменяет информацию о состоянии, поддерживаемую целевым программным обеспечением, или вызывает переход состояния в аппаратном обеспечении. Если атака успешна, целевая система будет использовать это поврежденное состояние и выполнять действия ненадлежащим образом.

В программном контексте объектом манипуляции могут выступать различные элементы состояния приложения: учетные данные пользователей, параметры сессии, данные транзакций, элементы бизнес-логики (например, содержимое корзины покупок в e-commerce системах). Подобные манипуляции позволяют злоумышленнику осуществлять эскалацию привилегий, инициировать несанкционированные операции или изменять поток выполнения программы.

На аппаратном уровне атака направлена на эксплуатацию ошибок в конечных автоматах, что может привести к переводу системы в недопустимое состояние. Последствия включают отказы в обслуживании (DoS) или непреднамеренное раскрытие конфиденциальной информации через побочные каналы.» [10]

Мета-шаблон CAPEC-74 включает в себя другие, более подробные, шаблоны атак, базирующиеся на различных уязвимостях операционной системы, требованиях для реализации и результатах выполнения:

– CAPEC-140: Обход промежуточных форм в наборах с несколькими формами;

– CAPEC-663: Эксплуатация транзитного (временнного) выполнения команд;

– CAPEC-696: Инъекция значения загрузки.

Данную классификацию можно представить в виде графа (рисунок 5).

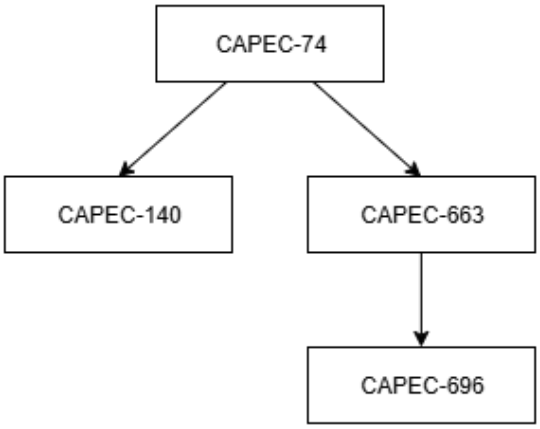


Рисунок 5 – Древо мета-шаблона CAPEC-74

Адаптированное описание шаблона атаки CAPEC-140: «Некоторые веб-приложения требуют, чтобы пользователи отправляли информацию через упорядоченную последовательность веб-форм. Это часто делается в том случае, если собирается очень большой объём информации или если информация из предыдущих форм используется для предварительного заполнения полей или определения того, какую дополнительную информацию необходимо собрать приложению. Злоумышленник, который знает названия различных форм в последовательности, может ввести название более поздней формы и перейти к ней, минуя предыдущие формы. Это может привести к неполному сбору информации, неверным предположениям о данных, предоставленных злоумышленником, или другим проблемам, которые могут нарушить работу приложения.» [10]

Главным образом CAPEC-140 базируется на уязвимостях многоэтапных форм веб-приложений для ввода данных, таких как формы регистрации или ввода конфиденциальной информации. В случае успеха, CAPEC-140 позволяет обойти промежуточные этапы, посредством компрометирующего запроса, переходя к конечной форме, минуя этапы аутентификации.

Но, не смотря на то, что CAPEC-140 чаще всего базируется на уязвимостях веб-приложений, в этом контексте также возможна эксплуатация некоторых уязвимостей, которым подвержены ОС. Это может происходить в тех случаях, когда в ОС или серверной инфраструктуре существуют промежуточные формы или проверки, которые также подвержены подобным манипуляциям. Например, если в ОС есть последовательные проверки доступа к компонентам, которые могут быть нарушены путем перехода к конечным этапам без выполнения промежуточных условий.

Далее представлены примеры уязвимостей ОС, эксплуатируемые атаками типа CAPEC-140:

– BDU:2024-07163: Уязвимость функции vmx_enter_smm файла arch/x86/kvm/vmx/vmx.c подсистемы виртуализации KVM ядра операционной системы Linux, позволяющая нарушителю вызвать отказ в обслуживании; [12]

– BDU:2023-05522: Уязвимость реализации протокола сетевого времени NTPsec, связанная с неполным распознаванием внутреннего состояния, позволяющая нарушителю вызвать отказ в обслуживании. [12]

Оба примера указывают на реализацию CAPEC-140 через предсказуемость путей и отсутствие контроля за порядком выполнения этапов. Это позволяет злоумышленнику обходить обязательные проверки, нарушая безопасность и работоспособность системы.

Структура связей шаблона атаки с типами программных ошибок, и, как следствие, с уязвимостями имеет представление в виде древовидного графа (рисунок 6) и таблицы 9.

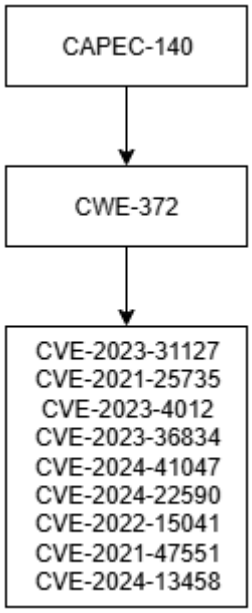


Рисунок 6 – Древо связей CAPEC-140, CWE и CVE

Таблица 9 – Соответствие CAPEC-140 с эксплуатируемыми уязвимостями

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок CWE	Связанные уязвимости CVE
CAPEC-140	Обход промежуточных форм в наборах с несколькими формами	CWE-372	CVE-2023-31127
			CVE-2021-25735
			CVE-2023-4012
			CVE-2023-36834
			CVE-2024-41047
			CVE-2024-22590
			CVE-2022-15041
			CVE-2021-47551
			CVE-2024-13458

Цикл жизни шаблона атак CAPEC-140 можно представить в виде следующей последовательности:

1) разведка: Злоумышленник анализирует процессы работы уязвимого ПО, которое использует многоэтапную валидацию данных или состояния. Объектом его поиска являются этапы, в которых отсутствует строгая проверка

последовательности или согласованность состояний между шагами. Это особенно актуально для систем, в которых промежуточные данные передаются между различными процессами или компонентами ОС.

2) подготовка: Злоумышленник разрабатывает стратегию обхода промежуточных проверок данных или состояния. С этой целью применяются инструменты перехвата данных в процессе обмена ими между процессами ОС или те, что изменяют промежуточные состояния системы.

3) воздействие: Имея к этому моменту инструменты обхода промежуточной проверки и обладая информацией об уязвимом ПО, на этом этапе злоумышленник выполняет заключительные действия нацеленные на эксплуатацию уязвимостей, позволяющие манипулировать состоянием системы.

Реализации шаблона атаки CAPEC-140 приводит к тому, что целевая операционная система или приложение не выполняет запланированные проверки или действия, основанные на корректных данных, что влечет за собой отказ в обслуживании. [10, 13]

Адаптированное описание подробного шаблона атаки CAPEC-696: «Злоумышленник эксплуатирует уязвимости микроархитектурного уровня современных процессоров, используя особенности выполнения временных инструкций. В ходе атаки уязвимая или вспомогательная инструкция загрузки обеспечивает временную передачу контролируемых злоумышленником данных из микроархитектурных буферов процессора. Путем целенаправленного вызова ошибки страницы или выполнения специфических инструкций микрокода во время работы легитимного процесса жертвы, атакующий индуцирует обработку вредоносных данных, сохраняющихся в микроархитектурных буферах. Данная методика позволяет комбинировать эксплуатацию аппаратных уязвимостей с анализом побочных каналов для извлечения конфиденциальной информации, остаточной в микроархитектурном состоянии процессора, либо для перехвата управления системой.» [10]

Шаблон атаки CAPEC-696 "Инъекция значения загрузки" требует выполнения ряда строгих предварительных условий, определяющих возможность успешной эксплуатации уязвимостей микроархитектурного уровня: [10]

– атакующий должен обладать как минимум правами доступа уровня пользователя, что позволит запустить вредоносный код. Этот код может быть представлен в виде вредоносного программного обеспечения, скрипта или процесса, который, несмотря на отсутствие прав доступа уровня администратора, способен взаимодействовать с низкоуровневыми механизмами процессора;

– после возникновения ошибок процессор должен предоставить доступ к целевым данным, что становятся временно доступными, даже после возникновения исключений или ассистированных загрузок;

– атакующий должен иметь возможность целенаправленно вызывать сбои или низкоуровневых вспомогательных инструкций, способные повлечь за собой утечку данных, что является триггером для инъекции вредоносных значений и последующего извлечения данных через анализ побочных каналов;

– наличие в системе специфических последовательностей инструкций, позволяющих перехватить управление и закодировать конфиденциальные данные в микроархитектурное состояние процессора, что даст возможность управления временными характеристиками выполнения и последующего извлечения данных через анализ времени доступа к кэш-памяти или другим разделяемым ресурсам процессора.

Структуру связей шаблона атаки с типами программных ошибок и с уязвимостями возможно представить в виде таблицы 10 и графа (рисунок 7).

Таблица 10 – Соответствие CAPEC-696 с эксплуатируемыми уязвимостями

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок CWE	Связанные уязвимости CVE
CAPEC-696	Инъекция значения загрузки	CWE-226	CVE-2022-23824
			CVE-2023-1637

Продолжение таблицы 10

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок CWE	Связанные уязвимости CVE
CAPEC-696	Инъекция значения загрузки	CWE-226	CVE-2023-3006
			CVE-2019-12675
			CVE-2019-12674
			CVE-2019-1911
			CVE- 2017-5715
			CVE-2017-5753
			CVE-2021-3156
			CVE-2024-21850

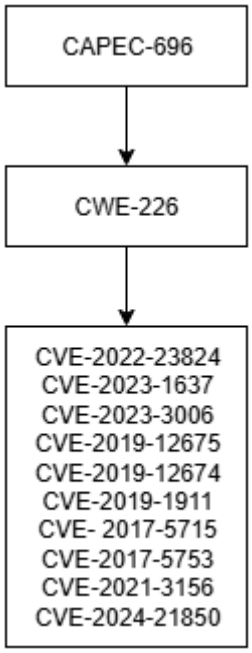


Рисунок 7 – Древо связей CAPEC-696, CWE и CVE

Цикл жизни шаблона атак CAPEC-696 можно представить в виде следующей последовательности: [3]

– разведка: На этапе разведки злоумышленник собирает информацию о структуре и характеристиках системы загрузки, исследует конфигурационные

файлы и другие параметры системы, которые определяют, как и какие модули загружаются.

– подготовка: На этом этапе злоумышленник готовит вредоносные данные или скрипты, которые будут интегрированы в конфигурационные параметры системы загрузки. Эти инъекции могут быть направлены на подмену путей к легитимным файлам загрузки, изменение аргументов, передаваемых ОС при загрузке, или подмену начальных значений загрузочных параметров.

– воздействие: Финальная стадия реализуется при возникновении запланированных ошибок вспомогательных инструкций или исключений инструкций закрузки, когда процессор инициирует временные наборы инструкций с использованием скомпрометированных значений из микроархитектурных буферов. Это позволяет либо извлечь конфиденциальные данные через анализ побочных каналов, либо перенаправить поток выполнения на заранее подготовленные цепочки инструкций

Таким образом, резюмируя выше сказанное и акцентируя внимание на предметной области исследования, можно сказать, что негативные последствия от реализации шаблона атаки CAPEC-696 связаны с возможностью злоумышленника устанавливать персистентные механизмы доступа, устойчивые к переустановке операционной системы или смене учетных данных. Данный шаблон атаки требует не только доступа к системе и эксплуатации аппаратных уязвимостей, но и глубокого понимания микроархитектурных особенностей целевого процессора. Это делает CAPEC-696 сложной для массовой эксплуатации, но крайне опасной для целевых атак на системы с критически важными данными.

2.2 Разложение шаблонов CAPEC атаки на техники MITRE ATT&CK

Согласно «Методике оценки угроз безопасности информации», утвержденной ФСТЭК России 5 февраля 2021 г. [67], каждый инцидент безопасности информации следует рассматривать как набор последовательных действий злоумышленника.

Сценарный подход позволяет структуризировать действия злоумышленника, что дает понимание о причинно-следственной связи между его действиями и о необходимых условиях для их реализации.

С этой целью предлагается подход формализации последовательностей этапов атаки через призму тактик и техник MITRE ATT&CK. Методологическая связь между ними и шаблонами атак CAPEC строится на принципе взаимодополняемости: [10, 13, 28-43, 51-55]

– CAPEC содержит сведения обобщенного характера о шаблонах атаки;

– MITRE ATT&CK выступает в качестве концептуального каркаса, обеспечивающего переход от абстрактных описаний к конкретным сценариям их реализации.

В рамках методологии MITRE ATT&CK тактики представляют собой категории, описывающие цели злоумышленника на различных этапах жизненного цикла атаки. Каждая тактика соответствует определенной стратегической задаче, такой как первоначальный доступ, расширение привилегий или сбор информации. Техники являются методами достижения этих целей, представляя собой действия, которые может предпринять нарушитель. Различие между тактиками и техниками заключается в уровне абстракции: тактики определяют что пытается достичь злоумышленник, а техники – как он это делает. [13]

Декомпозиция атаки на последовательность тактик и техник позволяет установить четкие причинно-следственные связи между этапами компрометации системы. Каждая тактика реализуется через набор техник, при этом переход между тактиками возможен только при успешном выполнении соответствующих технических приемов. Такая модель отражает логику продвижения злоумышленника в атакуемой системе, где каждая достигнутая тактическая цель создает условия для реализации последующих этапов атаки. [53-55]

Формализация сценариев через взаимосвязанные последовательности «тактика – техника – CVE» обеспечивает системный подход к анализу угроз. Этот метод позволяет учитывать различные варианты развития атаки в зависимости от

успешности эксплуатации конкретных уязвимостей и создает основу для оценки вероятности реализации каждого сценария. Получаемые модели являются фундаментом для последующего риск-анализа и разработки мер противодействия.

Полученные в предыдущем подразделе результаты о соответствии между множеством уязвимостей CVE и множеством шаблонов предметного класса атак CAPEC создают необходимую теоретическую основу для моделирования сценариев атаки. В этой связи, анализ MITRE ATT&CK позволил выявить взаимосвязи между циклами жизни шаблонов атак CAPEC и паттернами их реализации, выраженными через тактики и техники в виде графов (рисунок 8-11). [10-14, 35-40]

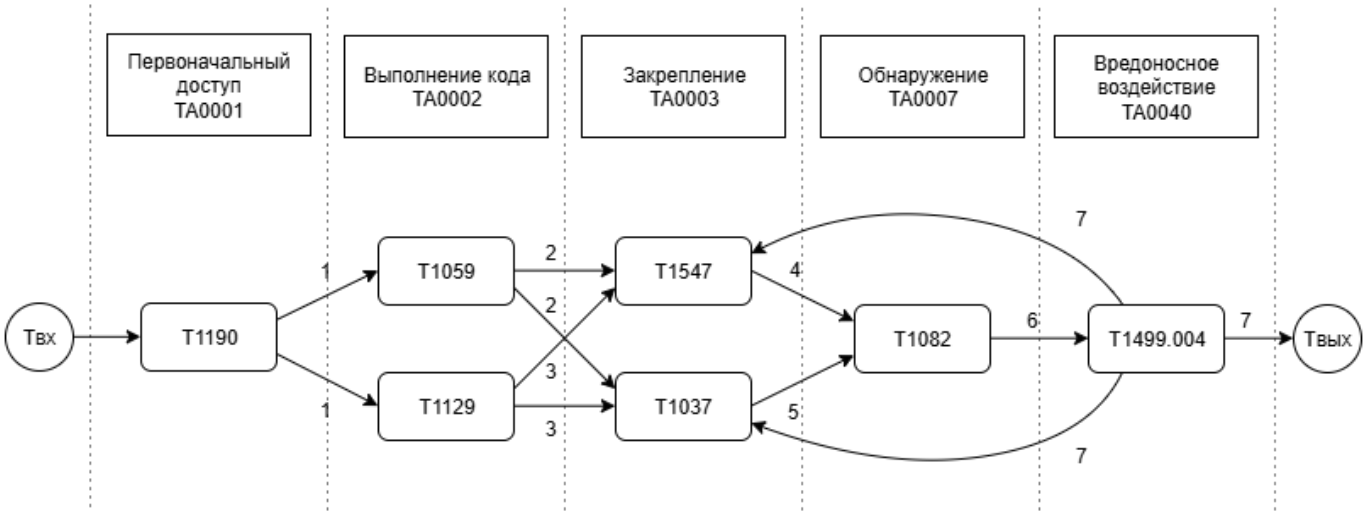


Рисунок 8 – общий сценарий шаблона атаки CAPEC-25

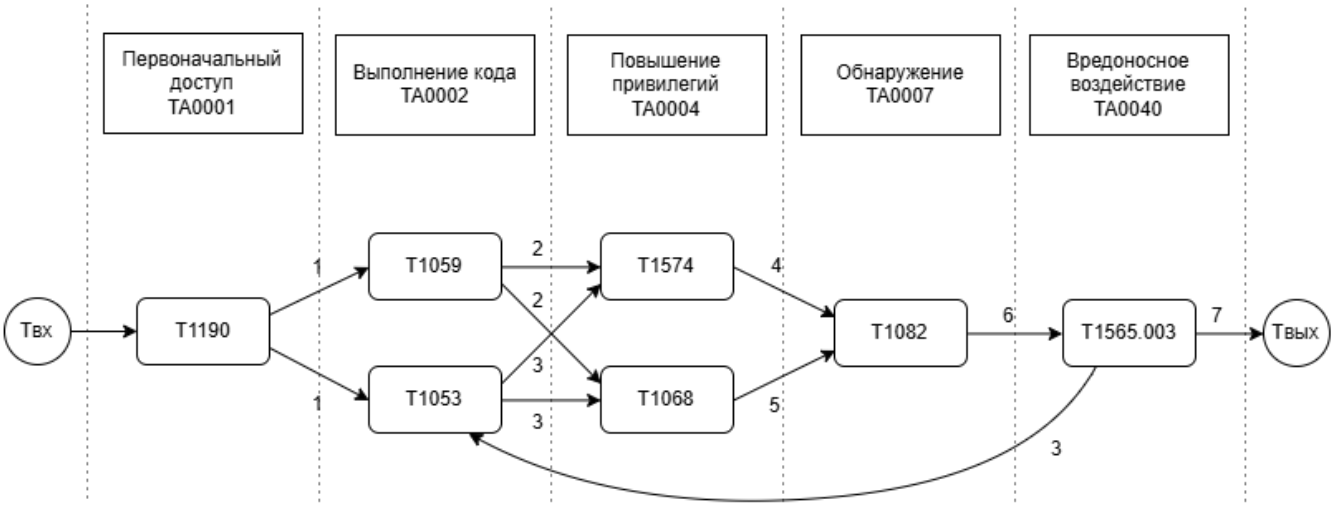


Рисунок 9 – общий сценарий шаблона атаки CAPEC-27

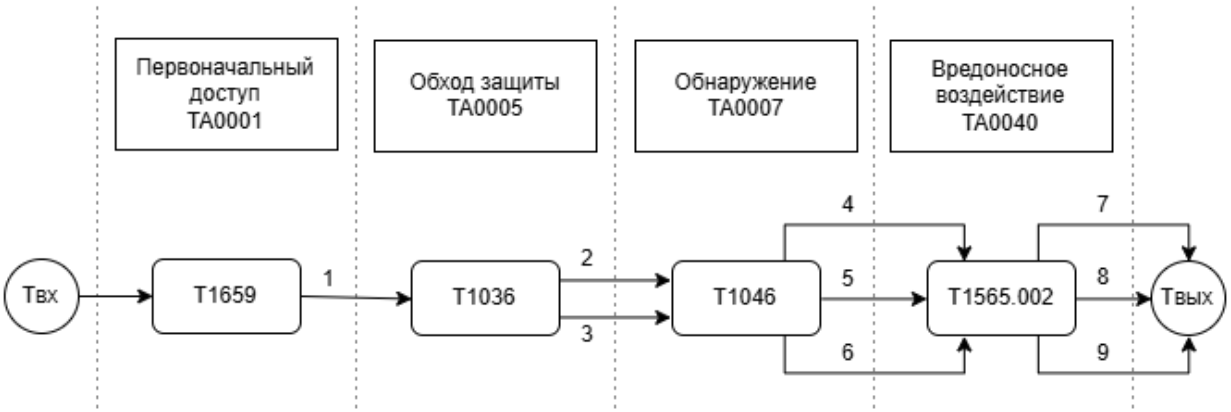


Рисунок 10 – общий сценарий шаблона атаки CAPEC-140

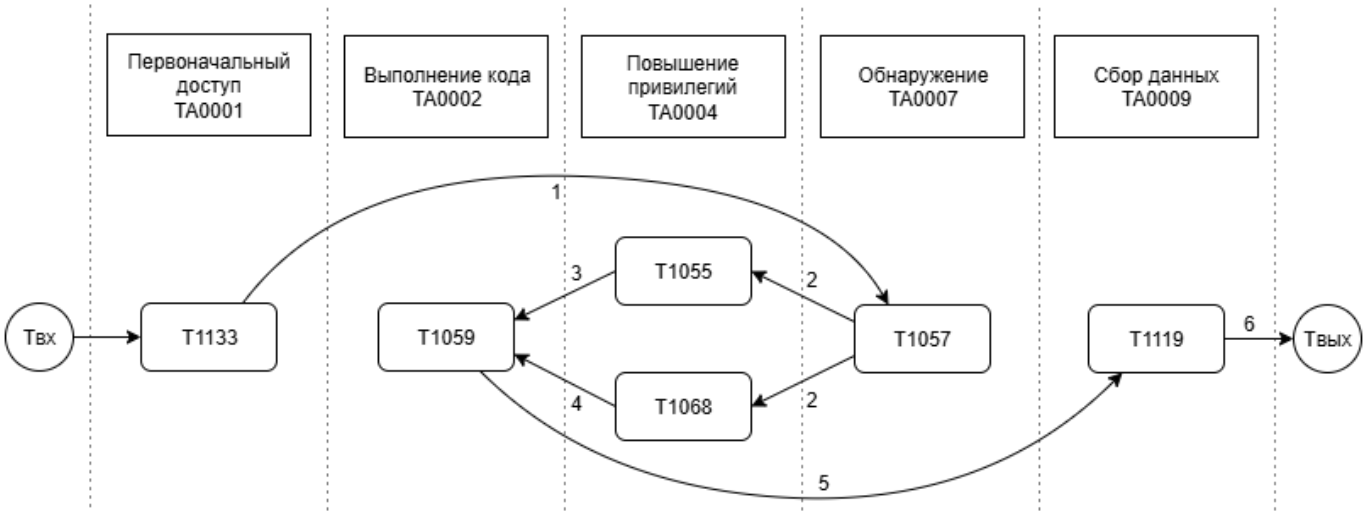


Рисунок 11 – общий сценарий шаблона атаки CAPEC-696

Данная таксономия способов реализации этапов жизненных циклов шаблонов атак покрывает всю инвариантность категории CAPEC-172 и дифференцирует множество возможных действий злоумышленника на тактический и технические уровни, тем самым позволяя смоделировать все множество вероятных сценариев атаки «Манипулирование временем и состоянием».

Из схемы сценария шаблона атаки CAPEC-25 (рисунок 8) следует четыре модели сценария единичной атаки (рисунок 12-15). Где под вершинами понимается применение злоумышленником техники, а под ребрами множества эксплуатируемых уязвимостей CVE, что используются техниками. Нумерация ребер соответствует множествам уязвимостей, которые эксплуатируются техниками, что у основании ребер:

1) техника T1190: CVE-2023-3389, CVE-2021-1622, CVE-2024-4854, CVE-2023-31082, CVE-2023-44374;

2) техника T1059: CVE-2024-1931, CVE-2022-48862, CVE-2020-14059, CVE-2023-5088;

3) техника T1129: CVE-2024-35982, CVE-2024-24786, CVE-2020-12769.

4) техника T1547: CVE-2023-34324, CVE-2021-47038, CVE-2023-52456, CVE-2023-0437, CVE-2023-0160, CVE-2024-7409;

5) техника T1037: CVE-2024-0641, CVE-2024-0639, CVE-2024-27577;

6) техника T1082: CVE-2024-26603, CVE-2019-15031, CVE-2020-25668, CVE-2022-39189;

7) подтехника T1499.004: CVE-2019-11485, CVE-2022-4269, CVE-2020-36775, CVE-2024-26650, CVE-2024-26624, CVE-2024-26605, CVE-2023-45232, CVE-2024-45003, CVE-2024-26958, CVE-2024-8088, CVE-2024-36288, CVE-2023-50120, CVE-2024-31949, CVE-2021-29650, CVE-2022-48840, CVE-2024-45506, CVE-2024-36976.

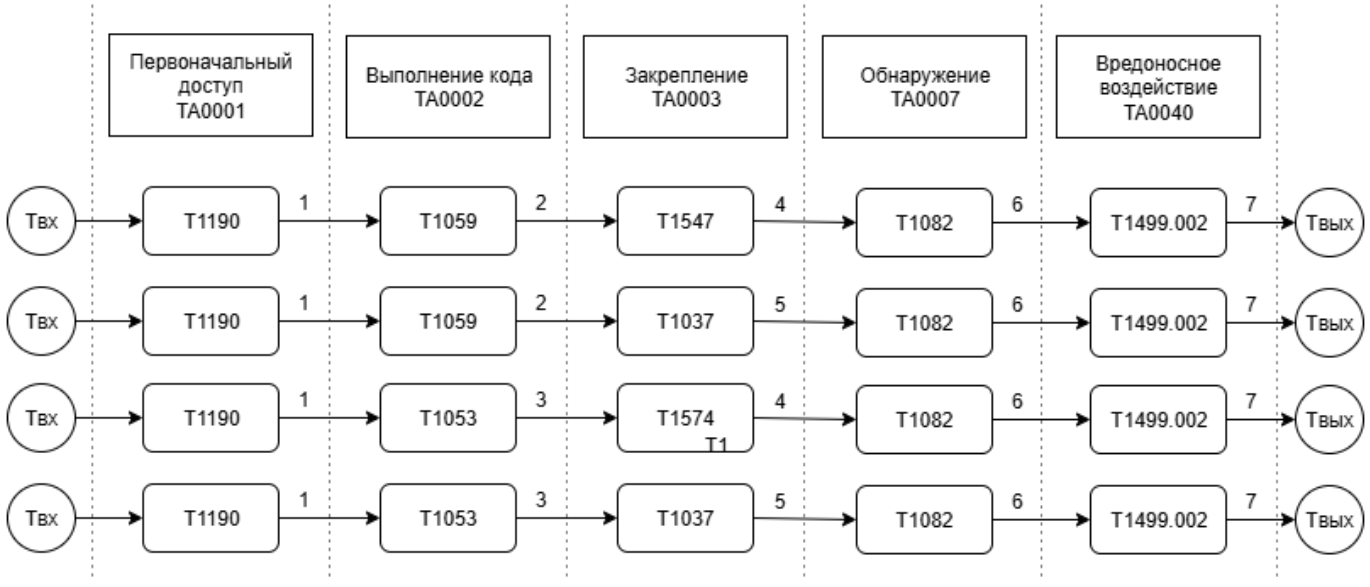


Рисунок 12 – Модели сценария единичной атаки по CAPEC-25

Из схемы сценария шаблона атаки CAPEC-27 (рисунок 9) следует четыре модели сценария единичной атаки (рисунок 16). Где под вершинами понимается техники используемые злоумышленником, а под ребрами – эксплуатируемые

техниками множества уязвимостей CVE. Нумерация ребер соответствует множествам уязвимостей, которые применяемые посредством техник, указанных на вершинах у основания реберб:

1) техника T1190: CVE-2021-3054, CVE-2023-22397, CVE-2024-7348, CVE-2024-27983, CVE-2024-7409, CVE-2023-3389, CVE-2023-31082;

2) техника T1059: CVE-2021-35937, CVE-2021-35090, CVE-2022-23084, CVE-2023-5088, CVE-2020-14059;

3) техника T1053: CVE-2023-20135, CVE-2024-26958;

4) техника T1574: CVE-2020-15702, CVE-2024-35265, CVE-2021-31997, CVE-2021-23177, CVE-2021-31566, CVE-2023-6597, CVE-2024-25952, CVE-2024-25953;

5) техника T1068: CVE-2020-35508, CVE-2024-38153, CVE-2024-30088, CVE-2020-12769;

6) техника T1082: CVE-2020-25668, CVE-2022-39189, CVE-2019-15031;

7) подтехника T1565.003: CVE-2019-15031, CVE-2023-21215, CVE-2019-16775, CVE-2020-28007, CVE-2021-29650,

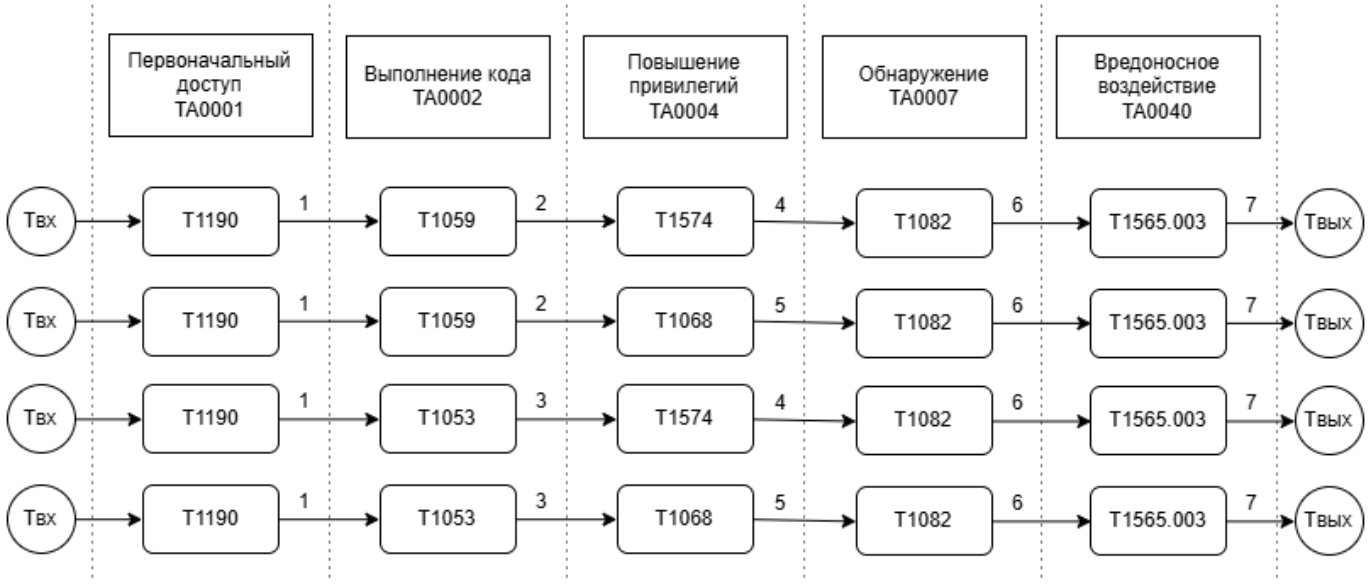


Рисунок 13 – четвертая модель сценария единичной атаки по CAPEC-27

Из схемы сценария шаблона атаки CAPEC-140 (рисунок 10) следует 18 моделей сценария единичной атаки (рисунок 14-15). Где под вершинами понимается

техники используемые злоумышленником, а под ребрами – эксплуатируемые техниками уязвимости: CVE-2023-31127, CVE-2021-25735, CVE-2023-4012, CVE-2023-36834, CVE-2024-41047, CVE-2024-22590, CVE-2022-15041, CVE-2021-47551, CVE-2024-13458 идентифицируемые порядковым номером от 1 до 9 соответственно.

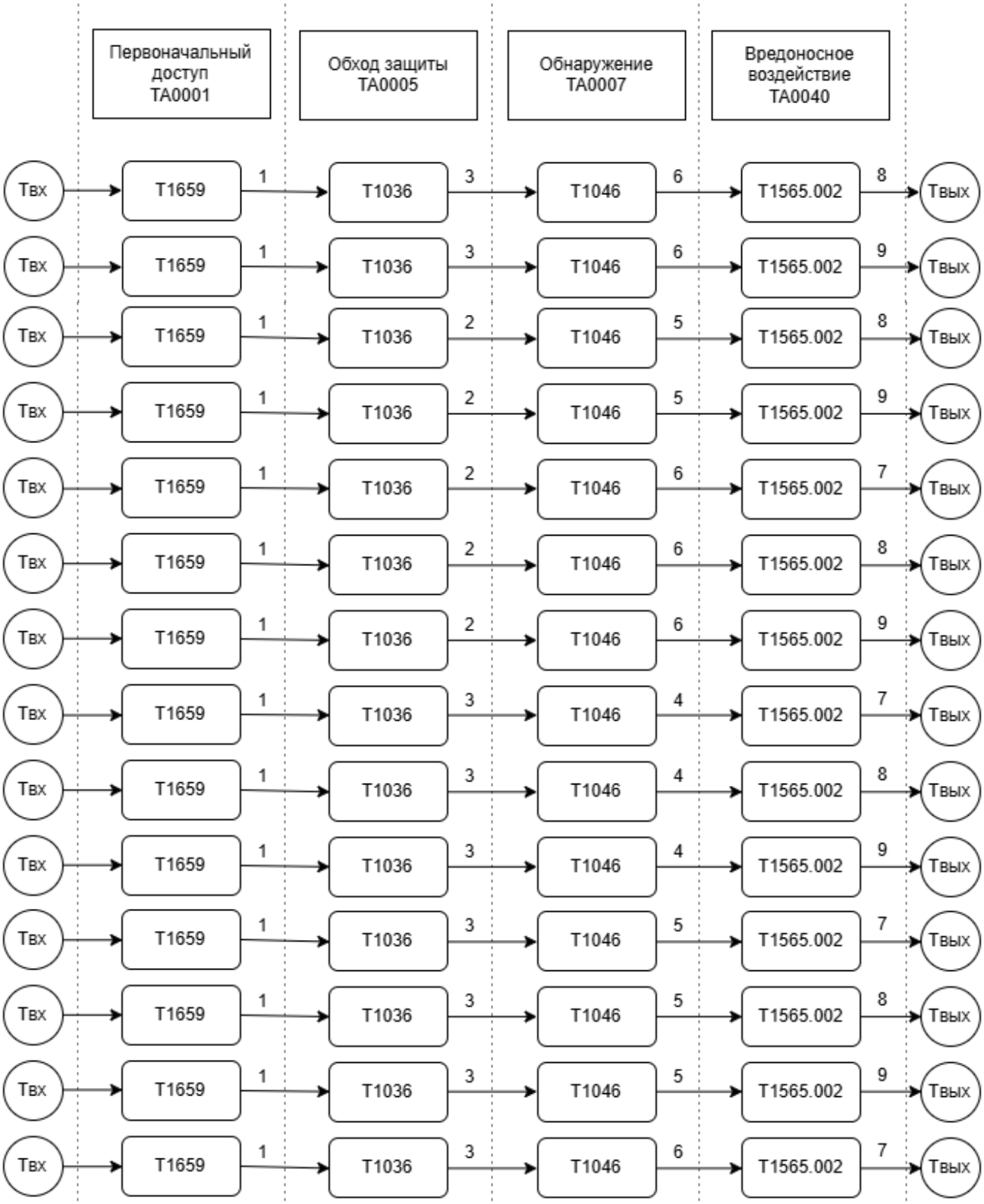


Рисунок 14 – модели 5-18 сценария единичной атаки по CAPEC-140

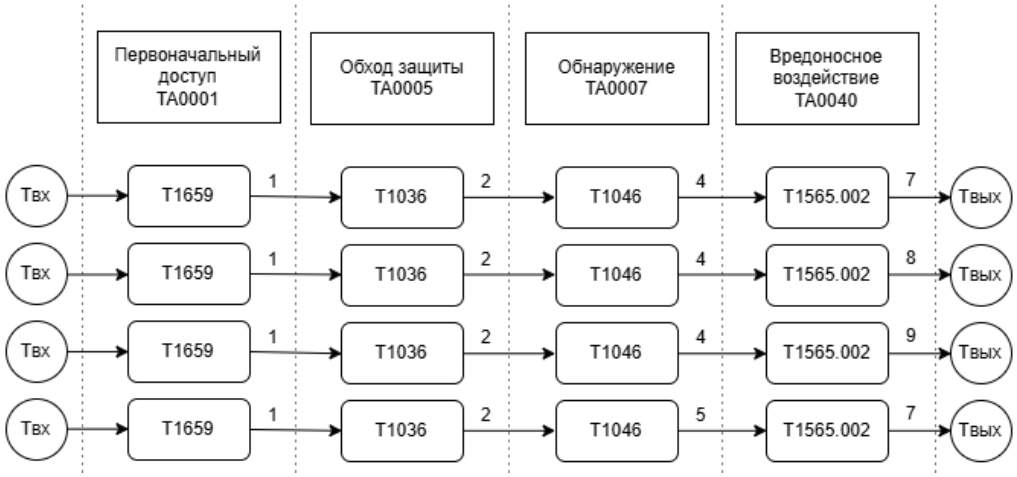


Рисунок 15 – модели 1-4 сценария единичной атаки по CAPEC-140

Из схемы сценария шаблона атаки CAPEC-696 (рисунок 11) следует 24 модели сценария единичной атаки (рисунок 16-17). Где под вершинами понимается техники используемые злоумышленником, а под ребрами – эксплуатируемые техниками уязвимости: CVE-2019-12675, CVE-2019-12674, CVE-2019-1911, CVE-2023-1637, CVE-2023-3006, CVE-2024-21850, CVE-2023-21608, CVE-2017-5715, CVE-2017-5753, CVE-2022-23824, идентифицируемые порядковым номером от 1 до 10 соответственно.

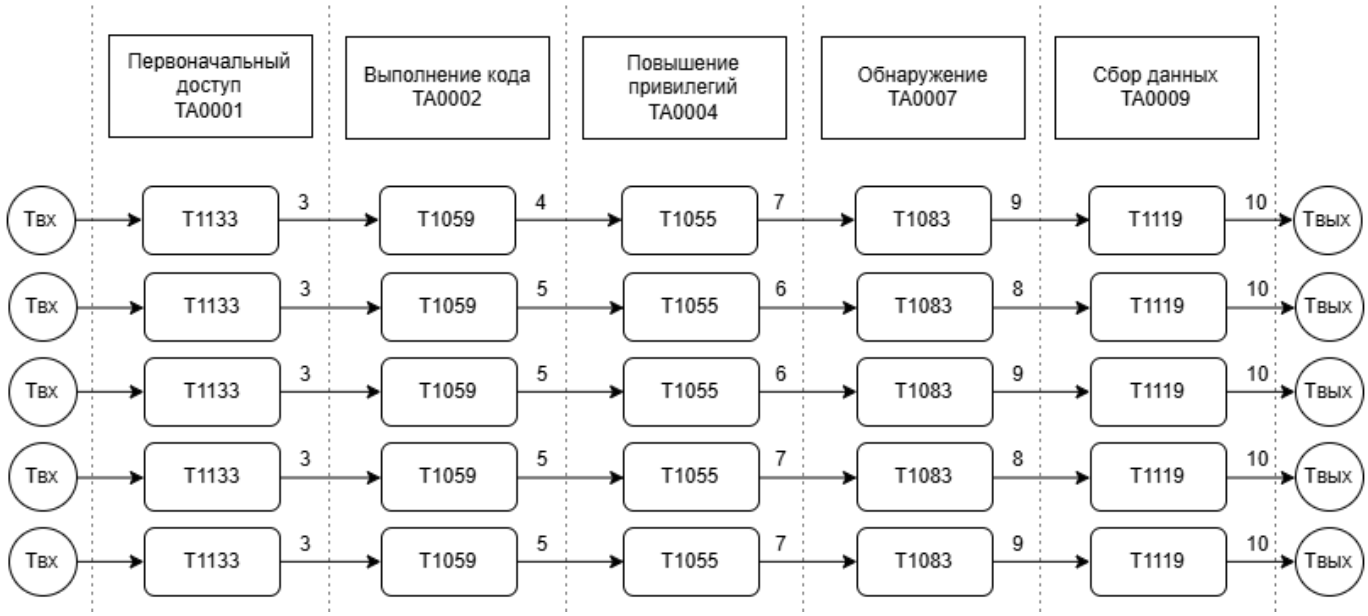


Рисунок 16 – модели 1-15 сценария единичной атаки по CAPEC-696

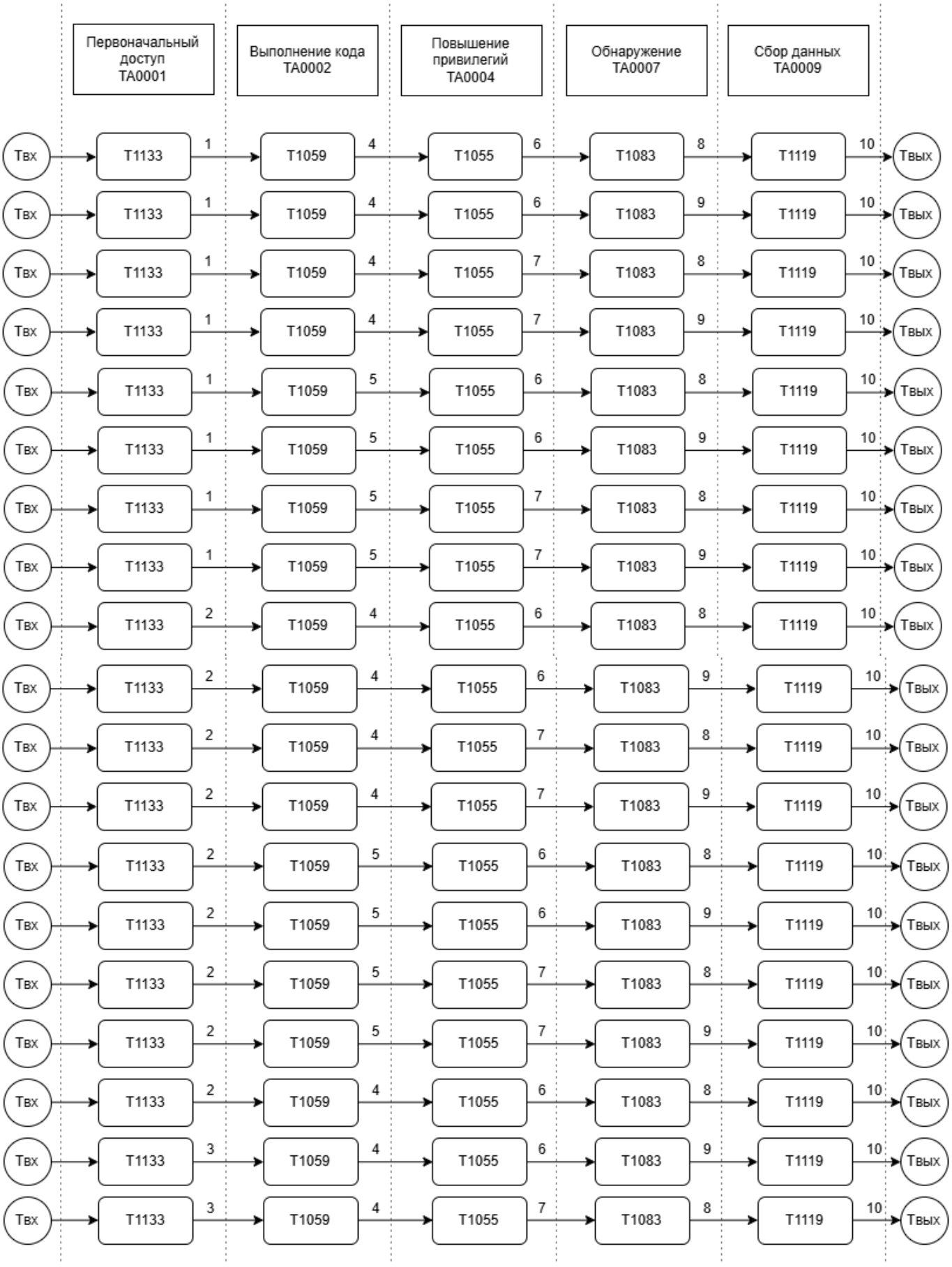


Рисунок 17 – 16-24 модели сценария единичной атаки по CAPEC-696

Таким образом, представленные сценарии играют роль каркаса, обеспечивающего логическую связность всех разделов настоящей выпускной квалификационной работы и их ориентацию на решение задач риск-анализа сценариев атаки, ранжированию всей плоскости сценариев от наименее до наиболее критичных и выработке регламентов противодействия наиболее критичным сценариям кибератаки.

2.2.1 Обоснование выбора тактик и техник MITRE ATT&CK для сценария по шаблону атаки CAPEC-25

2.2.1.1 Применимость тактики «Первичный доступ (TA0001)» в рамках CAPEC-25

Тактика TA0001 представляет собой совокупность методов, обеспечивающих первичное проникновение в целевую систему. В рамках CAPEC-25 данная тактика реализуется строго через эксплуатацию уязвимостей публичных интерфейсов, и в случае успеха можно инициировать конфликтующие операции. Без данной тактики атакующий физически не сможет передать системе команды, необходимые для создания условий взаимоблокировки. [10, 13]

Данная тактика может быть осуществлена посредством техники «Эксплуатация публично доступных API (T1190)», поскольку та основана на эксплуатации недостатков в интерфейсах и API, отвечающих за управление системными ресурсами. Кроме того, релевантность данной техники также обусловлена предварительными условиями, описанными в карточке CAPEC-25 каталога CAPEC – «Целевой хост предоставляет пользователю API». [13]

В каталоге MITRE ATT&CK, в карточке техники T1190, указаны примеры аналогичных воздействий, среди которых описан инцидент с идентификатором C0018 и следующим описанием: «Во время C0018 злоумышленники использовали шлюзы «VMWare Horizon Unified Access», которые были уязвимы для нескольких уязвимостей: CVE-2021-44228, CVE-2021-45046, CVE-2021-45105 и CVE-2021-

44832». В этом инциденте, установлено, что реализация этой техники возможна посредством эксплуатации уязвимости CVE-2021-45105 (BDU:2021-06325). [10-13, 69]

В базе данных БДУ ФСТЭК выделенная уязвимость имеет следующее описание: «Уязвимость библиотеки журналирования Java-программ «Log4j», существующая из-за недостаточной проверки входных данных, позволяющая нарушителю вызвать отказ в обслуживании». В связи с этим, возможно выделить уязвимости, связанные с CAPEC-25, с аналогичным принципом воздействия. В этом контексте характерным примером выступает уязвимость CVE-2021-1622, имеющая описание в БДУ ФСТЭК: «Уязвимость службы «Common Open Police Service (COPS)» операционных систем «Cisco IOS XE» связана с ошибками при обработке пакетов COPS. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании». На основании этих сведений можно заключить, что применение техники T1190 приводит к осуществлению тактики TA0001, в контексте шаблона атаки CAPEC-25. [12-13]

На основании анализа CVE-2021-45105 и аналогичных уязвимостей можно выделить паттерны релевантности уязвимостей для техники T1190:

– уязвимость должна эксплуатироваться через сетевые интерфейсы (AV:N) без необходимости предварительной аутентификации (PR:N);

– уязвимость должна позволять инициировать конфликтующие операции через уязвимый интерфейс.

С учетом всех критериев была получена следующая выборка уязвимостей: CVE-2023-3389, CVE-2021-1622, CVE-2024-4854, CVE-2023-31082, CVE-2023-44374.

2.2.1.2 Применимость тактики «Выполнение кода (TA0002)» в рамках CAPEC-25

Тактика TA0002) является обязательным этапом в реализации CAPEC-25, поскольку она обеспечивает переход от получения доступа к системе (TA0001) к реализации условий взаимоблокировки. Так данная тактика включает в себя методы, которые приводят к запуску вредоносного кода в локальной или удалённой системе, что часто используется в сочетании с методами из других тактик (в частности TA0003 и TA0007).

Следует отметить, что цели на осуществление TA0001 и TA0002 отличаются друг от друга. Техники выполнения кода позволяют обойти ограничения базового доступа (TA0001), посредством эксплуатации DoS-ориентированных уязвимостей, используя легитимные системные механизмы для создания условий конфликта. TA0002, в свою очередь, охватывает методы выполнения команд и кода в целевой системе и предоставляет возможность отсрочить выполнение атаки, до момента, когда будут обнаружены условия для создания состояния тупика. Техники, относящиеся к этой тактике, требуют предварительного доступа к атакуемой системе и предназначены для эксплуатации уязвимостей удаленного выполнения кода – RCE-уязвимостей. Резюмируя – цели на данные тактики (TA0001 и TA0002) отличаются: первая обеспечивает точку входа, вторая – механизмы контроля над системой. [13]

Техника T1059 применима в CAPEC-25 как инструмент для эксплуатации уязвимостей, что позволяют злоумышленнику удалённо запускать произвольные команды или код на атакуемой системе. Данное утверждение следует из описания этой техники, где явно указано следующее: «Злоумышленники могут использовать данный метод для выполнения произвольных команд. Команды и скрипты могут быть встроены в полезные нагрузки для начального доступа, которые доставляются жертвам в качестве документов-приманок или в качестве дополнительных полезных нагрузок, загружаемых с существующего командного центра. Злоумышленники

также могут выполнять команды через интерактивные терминалы/оболочки, а также использовать удаленные сервисы для удаленного выполнения команд.». [10, 13]

Характерным примером применения выделенной техники является процедура S0032, где эксплуатировалась уязвимость CVE-2015-5119 в «Adobe Flash Player». Согласно примеру процедуры, злоумышленники использовали специально сформированный документ для удаленного выполнения произвольного кода. В БДУ ФСТЭК описывает данную уязвимость следующим образом: «Уязвимость программной платформы «Flash Player», позволяющая нарушителю выполнить произвольный код или вызвать отказ в обслуживании». Метрики CVSS v3.1, а именно: AV:N, AC:L и PR:N – подтверждают, что эксплуатация возможна удаленно без необходимости аутентификации. [10, 12-13, 18, 70]

Из полученных сведений представляется возможным выделить признаки для корректного соотнесения уязвимостей с техникой T1059 в контексте тактики TA0002 шаблона CAPEC-25. Таким образом, были выделены следующие паттерны релевантности предметной технике:

– эксплуатация уязвимости должна осуществляться через стандартные интерфейсы выполнения кода (командные оболочки, API скриптовых языков);

– уязвимость должна иметь сетевой вектор атаки (AV:N) и минимальные требования к привилегиям (PR:N), обеспечивая возможность начального выполнения кода.

На основании этих критериев была сформирована выборка релевантных уязвимостей: CVE-2024-1931, CVE-2022-48862, CVE-2020-14059, CVE-2023-5088.

В ситуациях, когда отсутствует прямой доступ к API для управления ресурсами, аналогом техники T1059 может выступать «Общие модули (T1129)», что компенсирует набор функций аналогичный тактике «Повышение привилегий (TA0004)». Действия TA0004 ориентированы на повышение прав доступа злоумышленника в целевой системе. Однако в карточке CAPEC-25 явно указано предварительное условие на осуществление атаки – доступ к API. Из этого факта следует, что исполняемые злоумышленником команды будут идентифицироваться

средствами защиты как штатные, т.к. они эксплуатируют уязвимости легитимных механизмов. Этому свидетельствуют метрики уязвимостей из множества, что указано ранее как релевантное CAPEC-25, где для большинства входящих в нее, значение уровня привилегий составляет «не требуется (PR:N)». [10, 13]

Для тех уязвимостей, где значение метрики выше, возможно использование техники T1129. Такой вывод основан на описаниях MITRE ATT&CK и примерах процедуры S0661 и S1154. Анализ процедур демонстрирует, что упомянутая техника может служить эффективной альтернативой при отсутствии прямого доступа к API управления ресурсами. В случае процедуры S0661 злоумышленники использовали уязвимость CVE-2016-5195 для модификации системной библиотеки «keyutils.so», что позволило им получить устойчивый контроль над механизмами аутентификации. Этот пример показывает, как подмена системных компонентов может компенсировать отсутствие штатного API, создавая необходимые условия для реализации CAPEC-25. [10, 12-13, 71]

В примере процедуры S1154 с уязвимостью CVE-2024-39717 сообщается о возможности злоупотребления функционалом смены «favicon» для загрузки вредоносных модулей, что подтверждает возможность реализации T1129 через прикладные интерфейсы. Особенно показательно, что в обоих случаях техника T1129 обеспечивала: [12-13, 72]

– обход ограничений стандартных API управления ресурсами;
– создание скрытых механизмов контроля над системой;
– возможность модификации поведения приложения без прямого доступа к API;

Для корректного соотнесения уязвимостей с техникой T1129 в контексте тактики TA0002 и шаблона CAPEC-25 были применены следующие специфические критерии:

– уязвимость должна позволять модификацию или подмену системных компонентов (библиотек, модулей, конфигурационных файлов);

– эксплуатация должна обеспечивать функциональность, аналогичную API управления ресурсами, что критично для создания условий Коффмана в CAPEC-25;

– уязвимость должна поддерживать скрытный характер эксплуатации, используя легитимные механизмы загрузки кода (PR:N/L), что делает команды менее заметными для систем защиты.

На основании этих критериев была сформирована следующая выборка релевантных уязвимостей: CVE-2024-35982, CVE-2024-24786, CVE-2020-12769.

Тактика TA0002 выступает связующим звеном между получением доступа и достижением конечного эффекта. Успешность этого этапа напрямую зависит от двух факторов: корректности выявленных уязвимостей управления ресурсами и точности временных параметров атаки. Именно на этой стадии формируются предпосылки для последующего отказа обслуживания.

2.2.1.3 Применимость тактики «закрепление (TA0003)» в рамках CAPEC-25

Атаки взаимоблокировки относительно легко устраняемы, и в определенных сценариях их применение может привести к перезагрузке системы, что само по себе приводит к устранению вредоноса. Как следствие, одноразовый конфликт ресурсов не приведет к гарантированному DoS, потому интеграция тактики «закрепление (TA0003)» в сценарий шаблона атаки CAPEC-25, обеспечивает более устойчивую атаку.

Тактика TA0003 дает возможность сохранять устойчивое присутствие в системе даже после попыток ликвидации негативных последствий от атаки. В контексте CAPEC-25 это означает, что злоумышленник получает возможность инициировать условия взаимоблокировки и постоянно поддерживать их в активном состоянии. После перезагрузки системы или разрешения ситуации взаимоблокировки механизмы закрепления автоматически восстанавливают атакующие процессы, что существенно повышает эффективность воздействия.

Кроме того, функциональность этой тактики предоставляет следующие возможности: [10, 13]

– позволяет непрерывно мониторить состояние ресурсов и процессов, своевременно выявляя попытки разрешения конфликта.

– обеспечивает возможность динамической корректировки параметров блокировок в ответ на действия администратора или системных механизмов восстановления.

– поддерживает постоянную конкуренцию за ресурсы, не позволяя системе выйти из состояния тупика даже при частичном устранении последствий атаки.

Таким образом, интеграция тактики TA0003 в сценарий по CAPEC-25 решает проблему шаблона – его потенциальную одноразовость. Превращая единичный инцидент взаимоблокировки в постоянную угрозу, злоумышленник существенно повышает вероятность успешного отказа в обслуживании.

Техника «Выполнение автозапуска при загрузке или входе в систему (T1547)» предоставляет злоумышленнику несколько ключевых механизмов для поддержания устойчивого присутствия в системе. В контексте CAPEC-25 наиболее значимыми являются возможности внедрения вредоносных компонентов в различные точки автозапуска, включая ветки реестра «Windows», папки автозагрузки, системные службы и планировщики заданий. Эти механизмы позволяют автоматически восстанавливать условия взаимоблокировки ресурсов после перезагрузки системы или попыток администратора устранить последствия атаки. Особенность T1547 заключается в том, что она обеспечивает не просто сохранение доступа, а именно поддержание активного состояния атакующих процессов, критически важное для CAPEC-25. [10, 13]

Анализ примера процедуры S0083 демонстрирует соответствие T1547 требованиям CAPEC-25, в рамках которой CVE-2011-0611 эксплуатировалась не только для первоначального проникновения, но и для внедрения механизмов автозапуска, что подтверждается исследованием «Cylance» [73]. Уязвимость CVE-

2011-0611, позволяющая как выполнение произвольного кода, так и отказ в обслуживании, способствует реализации CAPEC-25, так как сочетает возможности создания условий взаимоблокировки и их последующего поддержания. Метрики CVSS (AV:N/AC:L/PR:N) показывают, что эксплуатация возможна удаленно без специальных привилегий, что соответствует требованиям шаблона атаки. [12-13]

На примере CVE-2011-0611 можно выделить ключевые характеристики уязвимостей, пригодных для реализации T1547 в CAPEC-25:

– возможность выполнения произвольного кода (C:H/I:H) для внедрения компонентов автозапуска;

– воздействие на доступность системы (A:H) для создания условий блокировки;

– сетевой вектор атаки (AV:N) с минимальными требованиями к привилегиям (PR:N);

– способность модифицировать критические системные компонент, связанные с механизмами автозагрузки и/или планировщиками задач.

На основании этих паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующие уязвимости, эксплуатируемые T1547: CVE-2023-34324, CVE-2021-47038, CVE-2023-52456, CVE-2023-0437, CVE-2023-0160, CVE-2024-7409.

Альтернативой T1547 выступает техника «Сценарии инициализации загрузки или входа в систему (T1037)», что используется для модификации системных скриптов, выполняющихся до загрузки операционной системы. В контексте CAPEC-25 условия взаимоблокировки могут быть восстановлены еще до того, как система полностью перейдет в рабочее состояние, что существенно затрудняет противодействие атаке. [13]

Пример процедуры C0046, в ходе которой эксплуатируется CVE-2024-20353, демонстрирует принцип действия T1037, как части сценария шаблона атаки CAPEC-25. Это следует из описания указанной процедуры, что ссылается на отчет канадского центра кибербезопасности [26], где сообщается, что данная уязвимость

позволила злоумышленникам модифицировать критические скрипты инициализации управляемых межсетевых экранов модельного ряда «Cisco ASA». Так применение T1037 обеспечивает более устойчивую форму персистентности – даже полный сброс устройства не устраняет внедренные изменения, поскольку скрипты инициализации восстанавливаются из неизмененных образов. Это соответствует ключевому требованию CAPEC-25 – способности постоянно поддерживать условия взаимоблокировки, даже при попытках администратора восстановить нормальную работу системы. [10, 12-13, 74]

Анализ CVE-2024-20353 позволяет выделить паттерны уязвимостей, способствующих осуществлению T1037 в контексте CAPEC-25:

– обеспечение модификации системных скриптов или конфигураций запуска (C:H/I:H);

– оказывать воздействие на доступность системы (A:H) для создания устойчивых условий блокировки.

На основании этих паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующие уязвимости, эксплуатируемые T1037: CVE-2024-0641, CVE-2024-0639, CVE-2024-27577.

2.1.1.4 Применимость тактики «Обнаружение (TA0007)» в рамках CAPEC-25

Как следует из описания CAPEC-25, реализация этого шаблона атаки требует выполнения предварительного условия о чем явно указано карточке шаблона атаки каталога CAPEC в разделе о цикле жизни атаки, на исследовательской фазе: «Целевой хост находится в состоянии взаимоблокировки». [9] Перед тем как злоумышленник сможет инициировать этап воздействия, ему необходимо найти уязвимую операцию, находящуюся в состоянии взаимоблокировки, и объем памяти, к которому эта операция обращается. Без этой информации атака будет либо неэффективной, либо вовсе невозможной. [10]

В рамках данного шаблона атаки, посредством осуществления тактики TA0007 злоумышленник может реализовать следующие цели: [13]

– идентификация ресурсов с максимальным потенциалом для создания конфликта – это включает анализ загрузки процессора, распределения памяти и паттернов доступа к системным объектам;

– определение временных окон для максимально эффективного воздействия, что требует мониторинга циклов работы системы и периодов пиковой нагрузки.

Среди всего многообразия техник TA0007 выделяется «Обнаружение системной информации (T1082)», т.к. ее применение ориентировано на получение сведений о текущем состоянии системных ресурсов (CPU, память, устройства), динамике их использования различными процессами, доступности и загруженности объектов синхронизации и параметрах механизмов предотвращения тупиков. В контексте CAPEC-25, злоумышленник может применить T1082 для выявления процессов и интервалов времени, когда они наиболее подвержены взаимоблокировкам. [13]

Этому утверждению свидетельствует пример процедуры S1185, в котором злоумышленники воспользовались уязвимостью CVE-2020-9910. Данная процедура демонстрирует, возможность сбора данных о загрузке центрального процессора и распределении памяти, что позволяет оптимизировать атаку для создания максимально устойчивой взаимоблокировки. [12-13, 75]

Кроме способности T1082, решать указанные задачи, ее актуальность обуславливается эксплуатируемой уязвимостью, что соответствует, по характеру воздействия некоторым уязвимостям, релевантные CAPEC-25, т.е. позволяет нарушителю оказать воздействие на конфиденциальность, целостность и доступность защищаемой информации и типу уязвимого ПО (операционная система).

Анализ CVE-2020-9910 позволяет выделить паттерны уязвимостей, способствующих осуществлению T1082 в контексте CAPEC-25:

– способность раскрывать критическую системную информацию (CVSS-метрики: Низкий или нулевой уровень воздействия на доступность (A:N/L));

– отсутствие необходимости в модификации данных (CVSS-метрики: Низкий или нулевой уровень целостности (I:N/L))

На основании этих паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующие уязвимости, эксплуатируемые T1082: CVE-2024-26603, CVE-2019-15031, CVE-2020-25668, CVE-2023-5088, CVE-2022-39189.

2.2.1.5 Применимость тактики «Воздействие (TA0040)» в рамках CAPEC-25

Тактика TA0040 в рамках MITRE ATT&CK представляет собой заключительную фазу – манипулирование, прерывание или уничтожение системы и данных. Обоснование применимости TA0040 для CAPEC-25 основано на том, что успешная реализация атаки невозможна без финального воздействия на систему, которое и относится к тактике «Воздействие». В рамках этого шаблона атаки, задача на тактику уточняется до техники «Отказ конечной точки в обслуживании (T1499)» – эксплуатация уязвимостей управления ресурсами, для создания ситуации полной или частичной неработоспособности целевой системы. [10, 13]

Среди прочих подтехник техники T1499 выделяется соответствие между принципом реализации CAPEC-25 и «Отказ в обслуживании конечной точки: эксплуатация приложения или системы (T1499.004)». Такая связь заключается в возможности создания устойчивого отказа в обслуживании путем искусственного провоцирования состояния взаимоблокировки, о чем, в карточке CAEPC-25, свидетельствует явное указание на соответствие между предметным шаблоном атаки и подтехникой T1499.004. [10, 13]

После этапов разведки (TA0007) и выполнения вредоносных действий (TA0002) злоумышленник переходит к активному нарушению работы системы, что является сутью TA0040, При этом связь с тактикой TA0002 проявляется в

необходимости предварительного запуска процессов, которые создадут условия для взаимоблокировки. Например, атакующий может использовать TA0002 для одновременного запуска нескольких процессов, удерживающих ресурсы, а затем применить TA0040 для перевода системы в неработоспособное состояние. Кроме того, если атака включает элементы персистентности (TA0003), злоумышленник может повторно инициировать взаимоблокировку после перезагрузки системы, что усиливает долгосрочный эффект воздействия.

В этой связи, релевантными для данной подтехники являются следующие уязвимости: CVE-2019-11485, CVE-2022-4269, CVE-2020-36775, CVE-2024-26650, CVE-2024-26624, CVE-2024-26605, CVE-2023-45232, CVE-2024-45003, CVE-2024-26958, CVE-2024-8088, CVE-2024-36288, CVE-2023-50120, CVE-2024-31949, CVE-2021-29650, CVE-2022-48840, CVE-2024-45506, CVE-2024-36976.

Таким образом, TA0040 выступает логическим завершением жизненного цикла CAPEC-25, трансформируя результаты подготовительных этапов (разведка, выполнение кода) в конкретный разрушительный эффект. При этом ее реализация через T1499.004 обеспечивает методологическую основу для создания устойчивого DoS, будь то однократный сбой или персистентная атака с повторным воздействием.

2.2.2 Обоснование выбора тактик и техник MITRE ATT&CK для сценария по шаблону атаки CAPEC-27

2.2.2.1 Применимость тактики «Первичный доступ (TA0001)» в рамках CAPEC-27

Тактика первоначального доступа (TA0001) необходима в реализации типа CAPEC-27, поскольку создает необходимые предпосылки для выполнения последующих этапов жизненного цикла предметного шаблона атаки. Согласно описанию CAPEC-27, злоумышленник должен обладать возможностью создавать символьные ссылки в целевой файловой системе (TA0040), что требует наличия определенного уровня доступа к системе.

Особое значение имеет анализ предварительных условий CAPEC-27 через призму тактики TA0001. В описании шаблона явно указано, что целевая система должна предоставлять пользователю API или интерфейс для взаимодействия, что соответствует типичным векторам атаки техники T1190, Например, эксплуатация уязвимости в веб-интерфейсе «PAN-OS» (CVE-2021-3054) или в «PostgreSQL» (CVE-2024-7348) позволяет злоумышленнику получить уровень доступа, который необходим для последующего создания символьных ссылок. Таким образом, тактика TA0001 обеспечивает первоначальное проникновение и создает условия для реализации специфических механизмов атаки, описанных в CAPEC-27. [10, 12-13]

Действие T1190 основано на эксплуатации уязвимостей публично доступных интерфейсов, что соответствует требованию CAPEC-27 – наличие доступа к файловой системе для создания символических ссылок. Особенность данной техники заключается в том, что она позволяет преодолеть защиту на периметре сети, создавая основу для последующей реализации этапов атаки, связанных с эксплуатацией условий гонки. [13]

Пример процедуры G1045 демонстрирует универсальный характер техники T1190, способствующая реализации и CAPEC-25, и CAPEC-27, чему свидетельствует два факта:

– уязвимость CVE-2018-0171, что использовалась в данном примере процедуры. Ее эксплуатация в сетевом сервисе операционной системы «Cisco IOS» приводит к возможности выполнения произвольного кода – последствие характерное для уязвимостей релевантных CAPEC-27. [10-12, 76]

– для множеств CWE, на эксплуатации которых основана реализация CAPEC-25 и CAEPC-27, общими являются CWE-667 и CWE-662. Из этой корреляции следует, что CVE-2023-3389 и CVE-2023-31082 могут актуальны к использованию техникой T1190 в единичных сценариях предметных шаблонов атак. [10-12, 83]

На основе CVE-2018-0171 можно выделить следующие паттерны пригодности уязвимостей к их эксплуатации техникой T1190:

– уязвимость должна предоставлять возможность выполнения кода или получения доступа к файловой системе через публичный интерфейс (веб-сервис, API, сетевой протокол), что отражается в метриках CVSS как сетевой вектор атаки (AV:N).

– эксплуатация уязвимости не должна требовать предварительной аутентификации (PR:N), что характерно для большинства серьезных уязвимостей в публичных интерфейсах.

– уязвимость должна позволять хотя бы частичное управление файловой системой, необходимое для создания символьных ссылок или манипуляции с временными файлами.

На основании этих паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующие уязвимости, эксплуатируемые T1190: CVE-2021-3054, CVE-2023-22397, CVE-2024-7348, CVE-2024-27983, CVE-2024-7409.

2.2.2.2 Применимость тактики «Выполнение (TA0002)» в рамках CAPEC-27

В основе CAPEC-27 лежит использование условий гонки, что накладывает жесткие рамки на время, когда возможно осуществить несанкционированный доступ к целевому объекту и повлиять на его целостность, т.е. задачи на тактику TA0040, Потому, в отличие от первоначального доступа (TA0001), который обеспечивает точку входа, TA0002 непосредственно реализует основной механизм атаки – синхронизацию действий при осуществлении тактики TA0040 для эффективной эксплуатации условий гонки, что достигается через «циклическое выполнение скриптов (T1059)» или «запланированных задач (T1053)». [10, 13]

Цели на TA0002 в контексте данной атаки сводятся к реализации трех ключевых функций:

– автоматизацию своевременного создания символьных ссылок в файловой системе.;

– мониторинг процессов целевой системы для определения оптимального момента вмешательства в работу привилегированных программ.

– обеспечение персистентности атаки, что важно в случаях, если не удается вовремя воспользоваться уязвимостью.

Таким образом тактика TA0002 становится связующим звеном между полученным доступом (TA0001), сбора сведений о целевом объекте (TA0007) и конечным воздействием (TA0040), преобразуя теоретическую возможность в конкретные вредоносные действия.

Использование «Запланированная задача (T1053)» в CAPEC-27 позволяет автоматизировать действия для создания символьных ссылок и дает возможность эксплуатации соответствующих уязвимостей, используемых в контексте тактики TA0040, с учетом временных рамок установленных «периодом проверки и периодом воздействия». Данная техника использует функции планирования задач, чтобы облегчить первоначальное или периодическое выполнение вредоносного кода. Утилиты для планирования программ и сценариев присутствуют во всех основных операционных системах, в некоторых случаях возможно удаленно запланировать задачу. [13]

Хронометрический потенциал T1053 уступает T1059, что и представляет собой существенный недостаток этой техники, т.к. является причиной возникновения сбоев в ситуациях гонки. Из этого недостатка следует создание артефакты несанкционированного воздействия на систему, создания временных файлов и символьных ссылок, количество которых будет расти прямо пропорционально количеству попыток реализации действий на тактику TA0040, Тем не менее, преимущество данной техники в том, что она предоставляет шаблону атаки CAPEC-27 устойчивость к сбоям в случаях неудачных попыток заключительного воздействия. [10, 13]

Пример процедуры S1052 «DEADEYE» демонстрирует, как злоумышленники использовали системный планировщик «Windows» для регулярного выполнения скриптов, отслеживающих появление временных файлов в целевых каталогах, что

соответствует именно логике CAPEC-27. Роль уязвимости CVE-2021-44228 в примере процедуры S1052 заключалась в обеспечении первоначального выполнения кода, необходимого для последующего развертывания механизмов персистентности через запланированные задачи. В данном контексте эксплуатация этой уязвимости позволила злоумышленникам получить возможность выполнить произвольный код на целевой системе, что является предварительным условием для реализации техники T1053. Как подробно описано в отчете «Google Cloud Threat Intelligence» [69], группа «APT41» использовала уязвимость в CVE-2021-44228 для загрузки и выполнения вредоносного загрузчика «DEADEYE», который затем настраивал автоматическое выполнение через системный планировщик «Windows». [10-13]

На основе анализа CVE-2021-44228 и специфики CAPEC-27 можно выделить следующие паттерны для отбора уязвимостей, релевантных технике T1053:

– эксплуатация уязвимости должна предоставлять возможность добавлять или изменять запланированные задачи в системе. В контексте CAPEC-27 это применяется для организации регулярных попыток эксплуатации условий гонки.

– эксплуатация уязвимости должна приводить к сохранению вредоносной деятельности даже после перезагрузки системы.

На основании этих паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующие уязвимости, эксплуатируемые T1053: CVE-2023-20135, CVE-2024-26958.

Таким образом, можно заключить, что техника T1053 обладает меньшим приоритетом, в сравнении с T1059, но предоставляет дополнительные возможности, особенно в сложных окружениях, где злоумышленник вынужден предпринимать множественное повторение попыток эксплуатации условий гонки. Комбинация T1053 с другими техниками выполнения кода создает более устойчивый и надежный механизм эксплуатации условий гонки, увеличивая общие шансы на успешную реализацию атаки.

Техника «выполнение кода через командную строку (T1059)» в контексте реализации шаблона атаки CAPEC-27, в отличие от запланированных задач (T1053),

которые работают с фиксированными интервалами, позволяет злоумышленнику динамически реагировать на изменения в системе. Эта техника особенно эффективна при необходимости точной синхронизации между моментом идентификации целевого объекта и моментом его фактического использования, где временное окно может составлять всего несколько миллисекунд. [10, 13]

Пример процедуры G0073 демонстрирует валидность техники T1059, что эксплуатирует уязвимость CVE-2017-0199, в шаблоне атаки CAPEC-27. В данном случае группой «APT19» использовалась возможность выполнения произвольного кода через уязвимость в «Microsoft Office» для загрузки и запуска PowerShell-скрипта, который создавал символьные ссылки в системных каталогах «Windows». Как отмечается в отчете о примере процедуры G0073, этот подход позволял не только инициировать атаку, но и поддерживать постоянное присутствие в системе, что соответствует требованиям CAPEC-27 по обеспечению персистентности. Особенность данного примера заключается в том, что техника T1059 использовалась здесь как для первоначального выполнения вредоносного кода, так и для последующего управления символьными ссылками, что подчеркивает ее универсальность. [10-13, 77]

Техника T1059, по аналогии с техникой T1190 является универсальной, т.к. может быть использована и в контексте CAPEC-27, и при реализации шаблона атаки CAPEC-25, что подтверждает ее стратегическую ценность для атак класса «Манипулирование временем и состоянием». В CAPEC-25 данная техника применяется для создания условий взаимоблокировки ресурсов, где точность временных параметров выполнения команд играет решающую роль. В качестве примера выступает эксплуатация уязвимости CVE-2015-5119 в процедуре S0032, где злоумышленники использовали командную строку для одновременного запуска множества процессов, удерживающих критические ресурсы.

Сравнительный анализ применения T1059 в CAPEC-25 и CAPEC-27 показывает общие закономерности – в обоих случаях техника обеспечивает:

– детерминированное выполнение команд с точностью до миллисекунд, что критически важно для эксплуатации временных окон в условиях гонки (CAPEC-27) или создания точных условий взаимоблокировки (CAPEC-25);

– возможность динамической адаптации к изменениям в системе через условные конструкции скриптов.

Таким образом, предпочтительность T1059 в моделировании обоих шаблонов атак обусловлена ее уникальной способностью обеспечивать как высокоточное временное управление, так и гибкость при реализации сложных сценариев эксплуатации уязвимостей.

Анализ уязвимости CVE-2017-0199 позволяет выявить паттерны уязвимостей, которые могут быть использованы техникой T1059:

– уязвимость должна предоставлять возможность выполнения произвольного кода с доступом к файловой системе, что отражается в метриках CVSS как высокий уровень воздействия на конфиденциальность и целостность (C:H/I:H);

– такие уязвимости позволяют осуществить неинтерактивное выполнение команд (UI:N);

– поддержка скриптовых языков, т.е. языки программирования, посредством которых происходит взаимодействие злоумышленника с предметными интерпретаторами команд и скриптов.

На основании вышеуказанных паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующие уязвимости, эксплуатируемые T1059: CVE-2021-35937, CVE-2021-35090, CVE-2022-23084, CVE-2023-5088, CVE-2020-14059.

2.2.2.3 Применимость тактики «Повышение привилегий (TA0004)» в рамках CAPEC-27

Модель сценария CAPEC-27 начинается с осуществления тактики первоначального доступа (TA0001), ограничивающим фактором является ущербный набор прав доступа, которого недостаточно для реализации всех этапов жизненного цикла данного шаблона атаки. Этому утверждению свидетельствуют значения метрики «уровень привилегий (PR)» уязвимостей, эксплуатируемых CAPEC-27. Всего выделено 34 уязвимости: для 21 из них требуется минимальный уровень привилегий (PR: L), для 7 необходимы права доступа уровня администратора (PR: H) и 6 уязвимостей могут быть эксплуатированы без каких либо прав (PR: N). В этом контексте TA0004 необходима как средство получения прав доступа к защищенным областям файловой системы для определения целевых объектов, создания и манипуляции символьными ссылками. [10-13]

Техника «подмена выполнения (T1574)» является методом получения повышенных привилегий, необходимых для манипуляции символьными ссылками в защищенных каталогах. Сущность данной техники заключается в перехвате нормального потока выполнения программного обеспечения через подмену критически важных компонентов системы, таких как библиотеки, переменные окружения или пути загрузки. В контексте CAPEC-27, это позволяет обойти строгие ограничения доступа к системным каталогам, где обычно располагаются целевые файлы для атаки через символьные ссылки. Механизм работы T1574 соответствует логике CAPEC-27, поскольку соответствует принципу рассинхронизации между моментом проверки подлинности системного компонента и моментом его фактической загрузки в память. [10, 13]

Пример процедуры S1147, связанной с вредоносным ПО «Nightdoor», демонстрирует эффективность техники T1574 при реализации CAPEC-27. В данном случае злоумышленники использовали уязвимость CVE-2021-30869 в ядре XNU операционных систем «Apple» для подмены легитимных компонентов системы и получения прав уровня ядра. Как отмечается в отчете «Threat Hunter Team.» [78], эта

уязвимость позволяла не только повысить привилегии, но и обеспечить устойчивое присутствие в системе через механизм загрузки вредоносных DLL-файлов. [10-13]

Приведенный пример примечателен тем, что эксплуатация CVE-2021-30869 создала условия для последующей реализации CAPEC-27, предоставляя доступ к защищенным областям файловой системы, где располагались конфигурационные файлы. Этот случай подчеркивает, как T1574 может служить связующим звеном между получением повышенных привилегий и успешной реализацией атаки через символьные ссылки.

Анализ уязвимости CVE-2021-30869 позволяет выявить ключевые паттерны, характерные для уязвимостей, релевантных технике T1574:

– уязвимости должны позволять подменять системные библиотеки (например, через LD_PRELOAD в Linux) или модифицировать пути загрузки компонентов;

– успешная эксплуатация должна приводить к повышению прав доступа;

– предпочтение отдается уязвимостям, не требующим взаимодействия с пользователем (UI:N), что снижает вероятность обнаружения.

На основании этих паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующие уязвимости, эксплуатируемые T1574: CVE-2020-15702, CVE-2024-35265, CVE-2021-31997, CVE-2021-23177, CVE-2021-31566, CVE-2023-6597, CVE-2024-25952, CVE-2024-25953.

Техника эксплуатации уязвимостей для повышения привилегий (T1068) представляет собой альтернативный подход к получению необходимого уровня доступа для реализации CAPEC-27, когда прямое манипулирование системными компонентами (как в T1574) невозможно или нецелесообразно. В отличие от подмены выполнения, T1068 фокусируется на эксплуатации уязвимостей в механизмах контроля доступа, что особенно актуально в условиях, когда злоумышленник уже имеет первоначальный доступ к системе (TA0001), но ему требуются повышенные права для манипуляции символьными ссылками в защищенных каталогах. [13]

Пример процедуры S1181 демонстрирует практическое применение T1068 в CAPEC-27, где злоумышленники использовали уязвимость CVE-2021-34523 сервера «Microsoft Exchange» для эскалации привилегий до уровня, позволяющего модифицировать системные файлы. Как отмечается в отчете «Microsoft Incident Response», эта уязвимость предоставляла возможность обхода механизмов контроля доступа через неправильную обработку запросов аутентификации, что в конечном итоге позволяло получить права, необходимые для создания символьных ссылок в защищенных директориях. [79]

Анализ уязвимости CVE-2021-34523 и позволяет выделить паттерны уязвимостей релевантных технике T1068:

– уязвимости должны эксплуатировать рассинхронизацию между процессами проверки прав и выполнения операции, тем самым позволяя выполнять вредоносные действия, с правами доступа уровня «администратор»;

– возможность выполнения кода или критических операций с повышенными привилегиями – успешная эксплуатация должна приводить к устойчивому повышению уровня доступа (PR:L/H). В случае CVE-2024-30088 («Windows Kernel») это достигается через эксплуатацию условий гонки в драйвере файловой системы.

– минимизация требований к взаимодействию с пользователем – предпочтение отдается уязвимостям, не требующим действий пользователя (UI:N) или работающим в фоновом режиме. Например, CVE-2020-12769 («glibc») позволяет повысить привилегии через обработку специально сформированных символьных ссылок без каких-либо вспомогательных действий.

На основании вышеуказанных паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующие уязвимости, эксплуатируемые T1068: CVE-2020-35508, CVE-2024-38153, CVE-2024-30088, CVE-2020-12769.

2.1.2.4 Применимость тактики «Обнаружение (TA0007)» в рамках CAPEC-27

Связь между TA0007 и другими тактиками проявляется в нескольких аспектах. Техника выполнения кода (TA0002) выступает инструментом для реализации задач обнаружения, позволяя запускать системные утилиты мониторинга. Полученные данные затем используются для точной синхронизации атаки в рамках TA0040, когда злоумышленнику необходимо вмешаться в промежуток между проверкой и использованием целевого файла. Особенность CAPEC-27 заключается в том, что успешность финального воздействия напрямую зависит от качества разведывательных данных – неточность в определении временных интервалов или путей к файлам делает атаку бесполезной.

Основные цели злоумышленника при применении TA0007 в контексте CAPEC-27 можно сформулировать в три направления. Первостепенной задачей является идентификация процессов, работающих с временными файлами, и анализ их поведения – это включает определение точных временных интервалов между операциями проверки и использования файловых объектов. Второй важной целью становится картирование файловой системы с выделением защищенных каталогов, где могут находиться целевые файлы, и областей с разрешениями на запись, где можно разместить символьные ссылки. Третья цель заключается в сборе информации о механизмах защиты, которые могут препятствовать созданию символьных ссылок в критических локациях. [10, 13]

Применимость T1082 в сценариях CAPEC-25 и CAPEC-27 обусловлена ее необходимостью сбора критической информации о системе перед непосредственной эксплуатацией уязвимостей. В случае CAPEC-25 это информация о загрузке системы и состоянии объектов синхронизации, а для CAPEC-27 – сведения о файловых операциях и правах доступа. При этом использование одних и тех же уязвимостей (CVE-2020-25668, CVE-2022-39189, CVE-2019-15031) подчеркивает универсальный характер техники T1082 и ее важность для атак, эксплуатирующих временные и состоятельные уязвимости. [10-13]

Сущность данной техники заключается в системном сборе информации о целевой системе, что является обязательным условием для успешной эксплуатации условий гонки при работе с символьными ссылками. Анализ примера процедуры G0022, где группа «APT3» использовала уязвимость CVE-2014-1776, демонстрирует типичный паттерн поведения злоумышленников при подготовке к атаке. [12-13, 80]

На основании анализа CVE-2014-1776 можно выделить ключевые паттерны для идентификации уязвимостей валидных T1082:

– уязвимости должны позволять раскрывать информацию о системе без необходимости модификации данных, что отражается в низких показателях воздействия на целостность (I:N/L);

– они должны предоставлять доступ к критически важным системным данным – структуре каталогов, списку процессов или параметрам файловых операций.

На основании вышеуказанных паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующие уязвимости, эксплуатируемые T1082: CVE-2020-25668, CVE-2022-39189, CVE-2019-15031.

2.2.2.5 Применимость тактики «Вредоносное воздействие (TA0040)» в рамках CAPEC-27

Тактика TA0040 представляет собой заключительную и наиболее значимую фазу жизненного цикла атаки CAPEC-27, где злоумышленник реализует конечную цель — манипуляцию данными или отказ в обслуживании через эксплуатацию условий гонки. Принцип воздействия основан на подмене временных файлов с использованием символьных ссылок, что позволяет либо модифицировать критически важные данные (техника T1565.003), либо нарушить работоспособность системы. Персистентность этого этапа обеспечивается техникой T1053 из тактики TA0002, которая позволяет автоматически восстанавливать условия атаки после

сбоев или перезагрузки системы, создавая устойчивый цикл эксплуатации уязвимости. [13]

Обоснование применимости TA0040 для CAPEC-27 строится на ее тесной связи с предыдущими тактиками. TA0001 обеспечивает точку входа в систему, без которой невозможно создание символьных ссылок. TA0002 реализует механизм атаки через запланированные задачи (T1053) или командные интерфейсы (T1059), синхронизируя действия злоумышленника с уязвимыми операциями целевой системы. TA0004 решает проблему ограниченных прав доступа, что особенно важно для манипуляции файлами в защищенных каталогах. Наконец, TA0007 предоставляет данные о файловой системе и процессах, без которых точная эксплуатация условий гонки невозможна. Эта взаимосвязь демонстрирует, что TA0040 не существует изолированно, а является кульминацией многоэтапной атаки.

При реализации шаблона атаки CAPEC-27 тактика TA0040 преследует несколько конкретных целей, которые непосредственно вытекают из механизма эксплуатации условий гонки при работе с символьными ссылками. Основная цель заключается в несанкционированном изменении данных целевой системы путем подмены временных файлов через созданные злоумышленником символьные ссылки. Это позволяет нарушителю модифицировать конфиденциальную информацию или критически важные конфигурации, что соответствует технике «Манипуляции с данными во время выполнения (T1565.003)». [10, 13]

Пример процедуры G0082, связанной с деятельностью группы «APT38», демонстрирует практическое применение T1565.003 в сложных кибероперациях. В данном случае злоумышленники использовали вредоносный инструмент «DYEPACK.FOX» для манипуляции PDF-документами, связанными с транзакциями «SWIFT», что позволяло скрывать факты мошеннических операций от сотрудников банка. В этой связи, релевантными для данной подтехники являются следующие уязвимости: CVE-2019-15031, CVE-2023-21215, CVE-2019-16775, CVE-2020-28007, CVE-2021-29650. [10-13, 81]

2.2.3 Обоснование выбора тактик и техник MITRE ATT&CK для сценария по шаблону атаки CAPEC-140

2.2.3.1 Применимость тактики «Первичный доступ (TA0001)» в рамках CAPEC-140

Тактика первоначального доступа является основой для реализации шаблона CAPEC-140, поскольку обход промежуточных форм требует обязательного наличия точки входа в систему. Предметный шаблон атаки предполагает целенаправленное эксплуатацию уязвимостей логику многоэтапных процессов валидации, что невозможно без получения контролируемого доступа к соответствующим интерфейсам системы. Это подтверждается анализом уязвимости CVE-2023-31127, релевантной CAPEC-140, успешная эксплуатация которой требует не просто сетевого доступа к SPDM-интерфейсу, но и возможности инъекции специфических сообщений в установленный протоколом сеанса порядок взаимодействия. [10-12]

В рамках CAPEC-140 применение тактики TA0001 предполагает достижение трех целей, каждая из которых непосредственно связана с осуществлением последующих этапов CAPEC-140:

– получение контролируемого доступа к интерфейсам, участвующим в многоэтапной обработке данных. В случае CVE-2023-31127 это означает доступ к SPDM-респондеру с возможностью отправки специально сформированных сообщений. Данная цель является фундаментальной, так как без её достижения невозможна реализация последующих этапов атаки. [12-13]

– создание условий для последующего обхода проверок (TA0005). Это достигается за счет выбора таких векторов доступа, которые позволяют манипулировать состоянием системы между этапами валидации. Например, доступ к API промежуточной обработки данных дает возможность влиять на логику выполнения последующих проверок. [13]

– обеспечение минимальной заметности при получении доступа, что напрямую связано с тактикой TA0005, т.к. атака предполагает многоэтапное

вмешательство в работу системы, и преждевременное обнаружение на этапе первоначального доступа сделает невозможным выполнение последующих действий. [10, 13]

Техника «Внедрение данных (T1659)» обеспечивает критически важный механизм реализации первоначального доступа для CAPEC-140, что подтверждается анализом уязвимости CVE-2023-31127. В данном случае техника проявляется в возможности комбинирования сообщений «запрос/ответ» из разных методов аутентификации, что нарушает предусмотренную протоколом SPDM последовательность проверок. Согласно описанию уязвимости, такая манипуляция содержимым сообщений позволяет обойти аутентификацию, сохраняя при этом формальную корректность протокольного взаимодействия. [12-13]

Анализ примеров процедур S1088 и G1019 демонстрирует аналогичный принцип эксплуатации уязвимости CVE-2022-27926 через инъекцию контента в DNS, HTTP и SMB-ответы. Хотя конкретный вектор атаки отличается от CVE-2023-31127, оба случая объединяет ключевая особенность – вмешательство в установленную последовательность обработки данных на транспортном уровне. [12-13, 82]

На основании сравнительного анализа можно выделить следующие потерны релевантности уязвимостей технике T1659 в CAPEC-140:

– наличие возможности модификации структуры или содержания передаваемых между компонентами системы сообщений, что в случае CVE-2023-31127 выражается в комбинировании несовместимых методов аутентификации;

– отсутствие полной валидации последовательности получаемых данных, что для libspdm проявляется в недостаточной проверке соответствия;

– способность внедренного контента повлиять на логику обработки на последующих этапах, приводя к обходу критических проверок.

Применительно к CAPEC-140 техника T1659 необходима, поскольку позволяет не просто получить доступ, а сразу создать условия для обхода промежуточных проверок. В случае эксплуатации CVE-2023-31127 это достигается

за счет того, что само внедрение некорректной последовательности сообщений одновременно является и способом получения доступа, и первым этапом обхода механизмов защиты. Такой дуализм делает T1659 оптимальным выбором для реализации первоначального доступа в CAPEC-140,

2.2.3.2 Применимость тактики «Обход средств защиты информации (TA0005)» в рамках CAPEC-140

Тактика TA0005 необходима при реализации шаблона атаки CAPEC-140, поскольку успешный обход промежуточных форм требует нарушения последовательности маскировки вредоносной активности. Согласно описанию CAPEC-140, злоумышленник должен иметь возможность явно указать имя конечной формы, минуя предыдущие этапы проверки, что предполагает необходимость скрытия артефактов, свидетельствующих о действиях злоумышленника, от систем мониторинга. В этом контексте, посредством осуществления TA0005 злоумышленник способен реализовать три задачи: [10, 13]

– сокрытие факта нарушения последовательности валидации принимаемых данных, что достигается через маскировку вредоносных запросов под легитимные операции;

– обеспечение обхода механизмов контроля доступа, что для осуществления тактики «Обнаружение (TA0007)»;

– минимизирование количества артефактов воздействия на систему, что снижает вероятность обнаружения на этапе «Воздействие (TA0040)», когда происходит заключительное манипулирование данными или состояниями.

Техника «Маскировка (T1036)» необходима при реализации шаблона CAPEC-140, поскольку обход промежуточных форм требует нарушения последовательности валидации кода и имитации легитимной активности. Сущность данной техники заключается в манипуляции атрибутами объектов системы (именами файлов, метаданными, путями выполнения) с целью сокрытия их происхождении и

назначения. В контексте CAPEC-140 это проявляется в необходимости сокрытия факт несанкционированного доступа к конечным формам обработки данных. В данном случае злоумышленник может модифицировать атрибуты процессов или файлов, участвующих в многоэтапной валидации, чтобы замаскировать их под легитимные компоненты системы, тем самым обходя механизмы контроля целостности. [10, 13]

Пример процедуры C0018, связанный с эксплуатацией уязвимости CVE-2021-45105, демонстрирует универсальность техники T1036 для различных классов атак, включая CAPEC-140, В данном случае злоумышленники использовали маскировку для переименования вредоносного «payload» в «vmware_kb.exe», что позволило им имитировать легитимный процесс обновления «VMware». Это поведение аналогично эксплуатации CVE-2021-25735 в «Windows Kernel», где подмена параметров драйверов использовалась для скрытия несанкционированного доступа к промежуточным этапам обработки данных. [12-13, 83]

На основании CVE-2021-45105 удалось выделить три ключевых паттерна, характерных для уязвимостей эксплуатируемых техникой T1036:

– уязвимости должны предоставлять возможность модификации критических атрибутов объектов (например, имен файлов или метаданных процессов), что отражается в метриках CVSS как высокое воздействие на целостность (I:H);

– эксплуатация такой уязвимости дает возможность сохранять функциональность маскируемого объекта, что отличает T1036 от чистого разрушения данных;

– предпочтение отдается уязвимостям, не требующим интерактивного взаимодействия с пользователем (UI:N), что снижает вероятность обнаружения.

На основании вышеуказанных паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующие уязвимости, эксплуатируемые T1036: CVE-2023-4012 и CVE-2021-25735.

2.2.3.3 Применимость тактики «Обнаружение (TA0007)» в рамках CAPEC-140

Тактика TA0007 необходима для реализации шаблона CAPEC-140, поскольку успешный обход промежуточных форм требует детального понимания архитектуры целевой системы и логики обработки данных. В отличие от классических веб-атак, где структура форм часто предсказуема, в контексте эксплуатации уязвимостей ОС злоумышленник сталкивается с необходимостью анализа сложных цепочек вызовов между системными компонентами. Это включает исследование таких аспектов, как временные интервалы между операциями проверки состояния, механизмы синхронизации процессов и точки передачи контроля между модулями. [13]

При реализации CAPEC-140 тактика TA0007 преследует три взаимосвязанные цели, каждая из которых напрямую влияет на успешность последующего заключительного этапа атаки:

– анализ процессов обработки данных, на предмет компонентов, участвующих в многоэтапной валидации (например, драйверов файловой системы или менеджеров виртуальных машин);

– анализ временных характеристик целевого процесса, для синхронизации вредоносных действий с периодами между проверками состояния, когда возможно воздействие;

– выявление механизмов мониторинга, которые могут обнаружить аномальную активность, что напрямую связано с тактикой TA0005, для обеспечения перехода от разведки к целенаправленному воздействию (TA0040), минимизируя риск преждевременного обнаружения.

Техника «Сканирование сетевых служб (T1046)» применяется в реализации шаблона CAPEC-140, поскольку успешный обход промежуточных форм требует предварительного выявления компонентов системы, участвующих в многоэтапной обработке данных. В контексте CAPEC-140, применение данной техники ориентировано на обнаружение цепочек взаимодействия между процессами, где нарушение последовательности проверок может привести к компрометации.

Например, при эксплуатации уязвимости CVE-2024-22590 в ядре «Linux» злоумышленнику необходимо точно определить компоненты, отвечающие за валидацию состояний между системными вызовами, что невозможно без тщательного анализа сетевых и межпроцессных взаимодействий. [10-13]

Пример процедуры S0604, связанный с вредоносным ПО «Industroyer» и уязвимостью CVE-2015-5374, демонстрирует адаптацию техники T1046 для сложных промышленных систем, что концептуально близко к задачам CAPEC-140, В данном случае злоумышленники использовали сканер портов для обнаружения сервисов и выявления уязвимостей в цепочке обработки данных энергосистемы, с целью нарушения последовательности проверок состояний. Этот подход аналогичен критериям CAPEC-140 на анализ многоэтапных процессов, где успех атаки зависит от точного определения компонентов, участвующих в промежуточной валидации. В обоих случаях сканирование направлено не на классические уязвимости, а на логические ошибки в последовательности обработки состояний. [10-13, 84]

На основании CVE-2015-5374 удалось выделить паттерны, характерные для уязвимостей, эксплуатируемых техникой T1046 в CAPEC-140:

– уязвимости должны затрагивать сервисы, участвующие в многоэтапной обработке данных с промежуточной валидацией состояний, что отражается в наличии специальных протокольных последовательностей или конечных автоматов в описании CVE;

– эксплуатация уязвимости должна приводить к ожидаемой последовательности операций без полного отказа сервиса (CVSS: A:H, но C:N/I:N);

– предпочтение отдается уязвимостям в компонентах, являющихся мостами между различными подсистемами, поскольку содержащиеся в них логические ошибки в реализации проверок последовательности состояний видятся более критичными.

На основании вышеуказанных паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующие уязвимости, эксплуатируемые T1046: CVE-2023-36834, CVE-2024-41047 и CVE-2024-22590,

2.2.3.4 Применимость тактики «Вредоносное воздействие (TA0040)» в рамках CAPEC-140

Тактика TA0040 является кульминационным этапом реализации шаблона CAPEC-140, где теоретическая возможность обхода промежуточных проверок трансформируется во вредоносное воздействие. В контексте эксплуатации уязвимостей операционных систем, это проявляется в целенаправленном нарушении последовательности состояний системы, что приводит к выполнению невалидных операций. Особенность CAPEC-140 заключается в том, что воздействие осуществляется не через прямое разрушение данных, а через тонкую манипуляцию логикой обработки информации, когда система, сохраняя видимость нормальной работы, фактически выполняет несанкционированные действия. Это отличает данный шаблон от классических атак на доступность и требует особого подхода к анализу последствий.

Посредством тактики TA0040 злоумышленник может достичь две цели, каждая из которых напрямую влияет на успешность последующего заключительного этапа атаки:

– нарушение целостности логики системы путем пропуска критических этапов валидации входящих данных, что может выражаться в принятии неполных или противоречивых данных;

– эскалация последствий до уровня отказа обслуживания, когда накопленные ошибки состояний приводят к сбою работы службы или процесса.

Подтехника «Манипуляции данными во время выполнения (T1565.002)» представляет собой инструмент для реализации финальной стадии шаблона CAPEC-140, поскольку позволяет напрямую вмешиваться в процесс обработки данных, минуя предусмотренные проверки. В отличие от статического изменения данных, эта техника фокусируется на динамической модификации информации непосредственно в момент ее обработки системой, что приводит к обходу многоэтапных валидационных процедур. При эксплуатации уязвимостей CVE-2022-

15041, CVE-2021-47551 или CVE-2024-13458 злоумышленник получает возможность изменять критические параметры системы между этапами проверки, создавая ситуацию, когда формально корректные операции выполняются над некорректными данными. Это соответствует ключевому принципу CAPEC-140 – нарушению целостности процесса обработки информации без явного разрушения системных компонентов. [10-13]

2.2.4 Обоснование выбора тактик и техник MITRE ATT&CK для сценария по шаблону атаки CAPEC-696

2.2.4.1 Применимость тактики «Первичный доступ (TA0001)» в рамках CAPEC-696

Тактика TA0001 выступает критически важным элементом реализации CAPEC-696, поскольку эксплуатация микроархитектурных уязвимостей процессора требует предварительного выполнения кода на целевом узле. Как следует из предварительных условий CAPEC-696, злоумышленнику необходимо получить хотя бы пользовательский уровень доступа для запуска вредоносного процесса, взаимодействующего с низкоуровневыми механизмами процессора. Данное требование напрямую коррелирует с определением TA0001 в MITRE ATT&CK, где подчеркивается необходимость получения первоначальных прав доступа в системе. Без реализации данной тактики последующие этапы атаки, включая инъекцию значений загрузки (CAPEC-696) и анализ побочных каналов, становятся технически невозможными. [10, 13]

В контексте CAPEC-696 тактика первоначального доступа решает две задачи. Первая заключается в обеспечении точки входа для последующей эксплуатации микроархитектурных уязвимостей, что достигается через компрометацию внешних сервисов или использование легитимных учетных данных. Вторая задача связана с созданием условий для персистентности, поскольку многие аппаратные уязвимости требуют многократного доступа к процессору для успешного извлечения данных.

Техника T1133 необходима в реализации CAPEC-696, поскольку обеспечивает первоначальный доступ к целевой системе через внешние сервисы. В контексте микроархитектурных атак большинство уязвимостей требуют локального выполнения кода для воздействия на работу процессора. Техника T1133 позволяет обойти это ограничение, предоставляя злоумышленнику возможность удаленного взаимодействия с системой через VPN-шлюзы, системы удаленного управления или веб-интерфейсы. [13]

Пример процедуры C0046, где использовалась уязвимость CVE-2024-20359 в «Cisco ASA», демонстрирует типичный сценарий применения T1133 для CAPEC-696. Уязвимость позволяла выполнить произвольный код после перезагрузки устройства, что соответствует требованию персистентности в микроархитектурных атаках. Особенно показательно, что вектор атаки (удаленный доступ через VPN) и конечный результат (исполнение кода с правами «root») создают идеальные условия для последующей эксплуатации аппаратных уязвимостей. Данный случай подтверждает, что техника T1133 не только обеспечивает первоначальный доступ, но и поддерживает длительное присутствие в системе, необходимое для сложных атак на процессорном уровне. [10-13, 75]

На основании анализа CVE-2024-20359 и аналогичных уязвимостей можно выделить паттерны релевантности уязвимостей технике T1133:

– эксплуатация уязвимости должна воздействовать на сервисы удаленного доступа (VPN, RDP, веб-интерфейсы), что отражается в сетевом векторе атаки (AV:N) в метриках CVSS;

– успешная эксплуатация должна предоставлять возможность выполнения кода и установки персистентных механизмов ввода и вывода информации;

– эксплуатация уязвимости не должна требовать прав доступа выше пользовательских (PR:L/N), что соответствует предварительным условиям реализации CAPEC-696.

На основании вышеуказанных паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующие уязвимости, эксплуатируемые T1133: CVE-2019-12675, CVE-2019-12674 и CVE-2019-1911.

2.2.4.2 Применимость тактики «Выполнение (TA0002)» в рамках CAPEC-696

Согласно предварительным условиям CAPEC-696, атакующий должен иметь возможность запускать специально сформированный код, который вызывает исключения или использует особенности спекулятивного выполнения для доступа к защищенным данным. Техники «выполнения кода» обеспечивают необходимый механизм для инъекции таких инструкций, что делает TA0002 неотъемлемой частью атаки. Без реализации данной тактики остаются недостижимыми как этап инъекции значений в микроархитектурные буферы, так и последующий анализ побочных каналов для извлечения информации (TA0009). [10, 13]

В рамках CAPEC-696 тактика TA0002 решает две взаимосвязанные задачи:

– воздействие на интерпретацию низкоуровневых корректных инструкций целевым устройством, чтобы при выполнении корректной инструкции возникал сбой страницы или помощь микрокода, для нарушения обработки данных в низкоуровневых сегментах памяти

– внедрение кода для загрузки значения в микроархитектурный буфер.

В этом контексте, техника T1059 способна решить задачи на тактику TA0004, как часть шаблона атаки CAPEC-696, поскольку обеспечивает необходимый механизм выполнения низкоуровневых инструкций, критически важных для эксплуатации уязвимостей спекулятивного выполнения. В контексте CAPEC-696 командные интерпретаторы используются для выполнения стандартных вредоносных и служат инструментом точного управления временными характеристиками выполнения кода на процессоре. Это позволяет злоумышленнику: инициировать сбои в работе процессора; контролировать заполнение

микроархитектурных буферов; синхронизировать выполнение вредоносных инструкций с работой легитимных процессов

Пример процедуры G1031 демонстрирует аспект применения T1059 – использование уязвимостей в интерпретаторах для выполнения произвольного кода. Уязвимость CVE-2017-11882 в «Microsoft Office», хотя и не связана напрямую с микроархитектурными атаками, иллюстрирует ключевой принцип: возможность выполнения произвольных инструкций через компрометацию стандартных интерпретаторов. [12-13, 85]

На основании анализа CVE-2017-11882 и аналогичных уязвимостей можно выделить паттерны релевантности уязвимостей для техники T1059 в CAPEC-696:

– Возможность выполнения произвольного машинного кода (не только скриптов), что отражается в метриках CVSS как высокий уровень воздействия на конфиденциальность и целостность (C:H/I:H);

– Доступ к низкоуровневым инструкциям процессора, что характерно для уязвимостей, позволяющих обходить ограничения песочниц или работать напрямую с аппаратными ресурсами;

– Поддержка точного временного контроля выполнения, что необходимо для синхронизации с работой легитимных процессов и эксплуатации условий гонки.

На основании вышеуказанных паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующие уязвимости, эксплуатируемые T1059: CVE-2023-1637 и CVE-2023-3006.

2.2.4.3 Применимость тактики «Повышение привилегий (TA0004)» в рамках CAPEC-696

Тактику TA0004 необходимо рассматривать в рамках сценария реализации CAPEC-696, поскольку эксплуатация микроархитектурных уязвимостей требует доступа к защищенным областям памяти и системным ресурсам. Предварительные условия CAPEC-696 указывают на необходимость пользовательского уровня

доступа к защищенным областям памяти, содержащим критически важные данные; установки персистентных механизмов для многократного выполнения атаки; обхода систем мониторинга, которые могут препятствовать эксплуатации микроархитектурных уязвимостей. [10, 13]

В рамках CAPEC-696 тактика повышения привилегий решает две задачи:

– получение доступа к защищенным областям памяти ядра;

– обход механизмов контроля доступа, которые могут препятствовать выполнению низкоуровневых инструкций, необходимых для эксплуатации микроархитектурных уязвимостей.

Техника T1055 решает задачи тактики TA0004 в рамках шаблона CAPEC-696, обеспечивая механизм повышения привилегий, необходимый для эксплуатации микроархитектурных уязвимостей. В контексте данной атаки внедрение в процессы позволяет преодолеть ограничение – необходимость доступа к защищенным областям памяти и системным ресурсам процессора. Это достигается за счет выполнения кода в контексте привилегированных процессов, что соответствует предварительным условиям CAPEC-696, требующим взаимодействия с низкоуровневыми механизмами процессора. [10,13]

Пример процедуры G1043 с использованием уязвимости CVE-2021-34523 демонстрирует практическую реализацию данной техники. Хотя в данном случае атака была направлена на почтовый сервер «Microsoft Exchange», принцип эксплуатации уязвимости иллюстрирует ключевые возможности T1055: выполнение произвольного кода с повышенными привилегиями и доступ к защищенным областям памяти. Эти характеристики критически важны для CAPEC-696, где требуется: манипуляция микроархитектурными буферами; обход механизмов изоляции процессов; сохранение персистентности между сеансами работы системы. [10-13, 86]

Анализ CVE-2021-34523 и аналогичных уязвимостей позволяет выделить следующие паттерны релевантности для техники T1055 в CAPEC-696:

– возможность выполнения кода в контексте системных процессов (C:H/I:H), что необходимо для доступа к защищенным областям ядра;

– нарушение механизмов контроля целостности памяти, характерное для уязвимостей, позволяющих манипулировать указателями или нарушать границы процессов;

– поддержка персистентного выполнения, обеспечивающая возможность многократных попыток извлечения данных через побочные каналы.

На основании вышеуказанных паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующая уязвимость, эксплуатируемая T1055: CVE-2024-21850.

Техника T1055 обеспечивает решение задач тактики TA0004 в рамках CAPEC-696 через внедрение кода в привилегированные процессы системы. Этот подход позволяет злоумышленнику получить доступ к защищенным областям памяти и системным ресурсам процессора, что является необходимым условием для эксплуатации микроархитектурных уязвимостей. В отличие от других методов повышения привилегий, T1055 сохраняет возможность управления выполнением кода, необходимого для синхронизации с работой легитимных процессов при манипуляции с памятью процессора. Пример уязвимости CVE-2021-34523 демонстрирует, как внедрение в системные процессы почтового сервера «Microsoft Exchange» позволяет получить уровень привилегий, достаточный для доступа к низкоуровневым механизмам процессора. [10-13]

Альтернативным методом реализации тактики TA0004, в рамках шаблона атаки CAPEC-696, является техника T1068, основанная на эксплуатации уязвимостей в компонентах операционной системы. В контексте CAPEC-696 данный подход предлагает возможность получения прав уровня ядра. Уязвимости типа CVE-2017-0263 или CVE-2022-38028 системных служб «Windows» позволяют обойти механизмы контроля доступа и напрямую взаимодействовать с аппаратными ресурсами процессора. Это делает T1068 приоритетным выбором в ситуациях, когда

период эксплуатации уязвимости для выполнения атаки узок или когда система защищена от методов внедрения кода. [10-13]

Сравнивая эффективность этих техник для CAPEC-696, можно отметить, что T1055 обеспечивает более высокую скрытность за счет маскировки под легитимные процессы, но требует тщательного анализа системы для выбора подходящих процессов-целей. В то же время T1068, хотя и более заметна для систем мониторинга, позволяет достичь требуемого уровня привилегий за счет прямого использования уязвимостей в механизмах безопасности ОС. Выбор между этими техниками в конкретном сценарии атаки должен основываться на анализе защитных механизмов целевой системы, доступных уязвимостей и требуемого уровня контроля над выполнением кода на процессоре.

Пример процедуры G0007, связанной с деятельностью «APT28», демонстрирует практическое применение техники T1068 через эксплуатацию уязвимостей CVE-2017-0263 и CVE-2022-38028. Особенность данных уязвимостей заключается в их способности нарушать механизмы контроля доступа на уровне ядра операционной системы, что полностью соответствует требованиям CAPEC-696. [10-13, 87]

Анализ указанных уязвимостей позволяет выделить паттерны релевантности для техники T1068 в контексте CAPEC-696:

– уязвимость должна предоставлять возможность выполнения произвольного кода в контексте ядра или системных процессов (C:H/I:H/A:H);

– эксплуатация уязвимости должна приводить к нарушению механизмов контроля доступа к защищенным областям памяти процессора;

На основании вышеуказанных паттернов были сформулированы критерии для выборки, по результатам которой была выявлена следующая уязвимость, эксплуатируемая T1059: CVE-2023-21608.

2.2.4.4 Применимость тактики «Обнаружение (Discovery: TA0007)» в рамках CAPEC-696

Анализ жизненного цикла CAPEC-696 указывает на необходимость предварительного выполнения тактики разведки (TA0007) перед осуществлением тактики «Выполнение кода». Так как на этапе подготовки злоумышленнику требуется точная информация об объеме конфиденциальной информации и точном ее расположении в памяти процессора, что невозможно получить без предварительного сбора системных данных. Тактика «Обнаружение» обеспечивает критически важные сведения о занимаемых процессами ресурсах памяти, используемых библиотеках и особенностях работы процессора, которые необходимы для корректного заполнения буферов контролируемыми значениями. [10, 13]

Техника T1057 обеспечивает злоумышленника информацией о выполняемых процессах. Пример процедуры S0606 иллюстрирует практическое применение техники T1057 через эксплуатацию уязвимости CVE-2017-0147, основанной на недостаточной проверке входных данных в протоколе SMBv1, что приводит к утечке информации из памяти процессов. [10-13, 88]

Анализ CVE-2017-0147 позволяет выделить следующие паттерны релевантности уязвимостей технике T1057 в CAPEC-696:

– эксплуатация уязвимости должна приводить к получению информации о выполняемых процессах (C:H);

– уязвимость должна давать возможность определить сегмент памяти, с которым взаимодействуют искомые процессы (I:N).

На основании вышеуказанных паттернов были сформулированы критерии для выборки, по результатам которой были выявлены следующие уязвимости, эксплуатируемые T1057: CVE-2017-5715 и CVE-2017-5753.

2.2.4.5 Применимость тактики «Сбор данных (Collection: TA0009)» в рамках CAPEC-696

Тактика TA0009 является завершающим этапом жизненного цикла CAPEC-696, где осуществляется извлечение конфиденциальной информации памяти процессора. Согласно описанию шаблона атаки, после успешной инъекции значений и манипуляции состоянием процессора (TA0002), злоумышленнику требуется механизм для считывания компрометируемых данных, что и составляет цель на данную тактику. [13]

Применение техники T1119 обеспечивает автоматизированный сбор данных, что соответствует завершающей фазе CAPEC-696 по извлечению информации из памяти процессора. Этому утверждению свидетельствует пример процедуры C0046, где посредством эксплуатации CVE-2024-20359 позволило осуществить сбор информации с учетом аппаратных особенностей обработки информации процессором, что соответствует цели на реализацию шаблона атаки CAPEC-696. [10-13, 89]

Анализ CVE-2024-20359 позволяет выделить паттерн релевантности уязвимости технике T1119 в CAPEC-696: эксплуатация уязвимости должна предоставлять возможность непрерывного мониторинга и сбора данных – чему сответствует уязвимость CVE-2022-23824. [12]

3 Моделирование микромоделей сценариев шаблонов атак, оценка критичности уязвимостей и рисков успешности реализации сформированных сценариев атаки

3.1 Оценка критичности уязвимостей релевантных заданным шаблонам атак

В этом разделе проводится оценка критичности уязвимостей в контексте заданных шаблонов атак, с применением калькуляторов критичности уязвимостей. Особое внимание уделяется анализу оценок критичности уязвимостей, посредством унификации результатов применения соответствующих калькуляторов.

Нормализованная среднеквадратичная оценка позволит устранить расхождения между различными системами оценки и получить сопоставимые показатели вероятности успешной эксплуатации. Результатом станет матрица весовых коэффициентов, отражающая относительную опасность каждой уязвимости, в рамках сценариев предметных шаблонов атак. Это создаст основу для риск-анализа успешности реализации сценариев атаки. [27-29, 51-55]

С этой целью используются калькуляторы, реализованные на следующих системах оценки критичности – CVSS 3.1, CVSS 4.0, EPSS, OWASP. Однако для достоверности результатов прежде всего, необходимо провести нормализацию значений калькуляторов. Причиной тому стали диапазоны результатов применяемого инструментария, т.к. для одних характерна шакала от 0 до 1, а для других от 0 до 10 и др. Исходя из этого противоречия необходимо провести нормализацию оценок, что возможно при применении формулы 1: [51-55]

$$S_{norm} = \frac{S - S_{min}}{S_{max} - S_{min}}, \quad (1)$$

где S_{norm} – нормализованная оценка калькулятора критичности уязвимости;

S – оценка калькулятора критичности уязвимости;

S_{max} и S_{min} – максимально и минимально возможные оценки калькулятора критичности уязвимости.

Для единой оценки критичностей используется метод нахождения среднеквадратичного значения по формуле 2: [53-55]

$$K = \sqrt{\frac{1}{N}\sum_{i=1}^{N} S_{norm,i}^2}, \quad (2)$$

где K – результирующая критичность оцениваемой уязвимости;

N – количество используемых калькуляторов.

Примененный метод использует среднеквадратичное значение для вычисления итоговой оценки, посредством которого нивелируется вероятный "разброс" нормализованных значений. Данный подход подтверждает важность крайних значений и позволяет учитывать вариативность данных.

Метод среднеквадратичного значения используется в статистике и анализе данных для получения представления о средней величине с учетом изменчивости и разброса оценок. Метод имеет обоснование, заключающееся в его способности учитывать как централизованные тенденции, так и различность данных. Высокая нестабильность оценок может свидетельствовать о наличии значительных рисков.

Данный метод чувствителен к выбросам, что делает его полезным индикатором для выявления потенциальных проблем в нестабильных данных. Использование среднеквадратичного значения для расчёта количественного показателя риска является обоснованным решением, поскольку оно учитывает как центральную тенденцию, так и вариативность данных. Такой подход позволяет более точно оценивать риски и принимать обоснованные решения. Чувствительность метода к выбросам и способность учитывать неопределённость делают его предпочтительным для анализа сложных систем. [51-55]

Посредством применения калькуляторов по системам CVSS 3.1, CVSS 4.0, EPSS, OWASP получены значения критичности уязвимостей, релевантных для CAPEC-25 (таблица 11), а с применением формулы 1 данные значения удалось привести к единой шкале, дифференцирующей значения в диапазоне от 0 до 1 (таблица 12). [16-20]

Таблица 11 – Результаты применения калькуляторов для уязвимостей CAPEC-25

Связанные типы ошибок CWE	Связанные уязвимости CVE	CVSS 3.1	CVSS 4.0	EPSS	OWASP
CWE-412	CVE-2019-11485	3.3	4.8	0,095	3.375
CWE-567	CVE-2023-44374	6.5	7.1	0,55	7.125
CWE-667	CVE-2023-31082	5.5	6.8	0,2	8.375
CWE-833	CVE-2021-1622	8.6	9.2	0,47	6.375
	CVE-2022-4269	5.5	6.8	0,01	4.125
CWE-833	CVE-2023-0160	5.5	6.8	0,005	3.500
	CVE-2023-34324	4.9	6.9	0,65	4.125
	CVE-2024-0641	4.4	6.7	0,04	4.250
	CVE-2024-0639	4.4	6.7	0,04	8.875
	CVE-2020-36775	4.4	6.7	0,04	4.620
	CVE-2021-47038	5.5	6.8	0,007	4.375
	CVE-2023-52456	5.5	6.8	0,19	6.375
CWE-833	CVE-2024-26650	4.4	6.7	-	6.375
	CVE-2024-26624	5.5	6.8	-	6.875
	CVE-2024-26605	5.5	6.8	0,19	8.250
	CVE-2024-36976	5.5	6.8	0,12	7.500
	CVE-2024-45003	5.5	6.8	0,14	7.750
CWE-835	CVE-2023-45232	7.5	8.7	0,78	7.125
	CVE-2024-26603	5.5	5.7	0,007	7.750
	CVE-2024-1931	7.5	8.7	0,96	4.620
	CVE-2023-0437	7.5	8.7	0,14	5.0
	CVE-2024-27577	7.5	8.7	0,79	3.250
	CVE-2024-24786	5.9	8.2	0,37	4.125
	CVE-2024-4854	5.3	5.9	0,72	7.620
	CVE-2024-36288	5.5	6.8	0,18	8.875
	CVE-2023-50120	5.5	6.7	0,11	3.750

Продолжение таблицы 11

Связанные типы ошибок CWE	Связанные уязвимости CVE	CVSS 3.1	CVSS 4.0	EPSS	OWASP
CWE-835	CVE-2024-35982	5.5	6.8	0,22	5.125
	CVE-2022-48840	5.5	5.7	0,01	5.875
	CVE-2022-48862	5.5	6.8	0,02	5.125
	CVE-2024-45506	6.2	6.9	0,72	5.125
CWE-662	CVE-2024-31949	6.2	6.9	0,5	4.500
	CVE-2024-8088	4.7	5.7	0,08	9.375
	CVE-2019-15031	4.4	4.8	0,15	3.0
	CVE-2020-12769	5.5	6.8	0,17	8.500
	CVE-2020-14059	6.3	7.0	0,86	5.750
	CVE-2021-29650	5.5	6.8	0,03	5.0
	CVE-2020-25668	7.0	7.3	0,16	3.750
	CVE-2022-39189	5.5	6.8	0,01	6.620
	CVE-2023-3389	7.8	8.5	0,12	3.750
	CVE-2023-5088	6.4	7.1	0,02	7.750
	CVE-2024-26958	5.5	5.7	0,2	3.500
	CVE-2024-7409	7.5	8.7	0,79	6.620

Таблица 12 – Нормализованные оценки критичности уязвимостей CAPEC-25

Связанные типы ошибок CWE	Связанные уязвимости CVE	CVSS 3.1	CVSS 4.0	EPSS	OWASP
CWE-412	CVE-2019-11485	0,33	0,48	0,095	0,34
CWE-567	CVE-2023-44374	0,65	0,71	0,55	0,71
CWE-667	CVE-2023-31082	0,55	0,68	0,2	0,84
CWE-833	CVE-2021-1622	0,86	0,92	0,47	0,64
	CVE-2022-4269	0,55	0,68	0,01	0,41
	CVE-2023-0160	0,55	0,68	0,005	0,35

Продолжение таблицы 12

Связанные типы ошибок CWE	Связанные уязвимости CVE	CVSS 3.1	CVSS 4.0	EPSS	OWASP
CWE-833	CVE-2023-34324	0,49	0,69	0,65	0,41
	CVE-2024-0641	0,44	0,67	0,04	0,42
	CVE-2024-0639	0,44	0,67	0,04	0,89
	CVE-2020-36775	0,44	0,67	0,04	0,46
	CVE-2021-47038	0,55	0,68	0,007	0,44
	CVE-2021-1622	0,86	0,92	0,47	0,64
	CVE-2022-4269	0,55	0,68	0,01	0,41
	CVE-2023-0160	0,55	0,68	0,005	0,35
	CVE-2023-34324	0,49	0,69	0,65	0,41
	CVE-2024-0641	0,44	0,67	0,04	0,42
	CVE-2024-0639	0,44	0,67	0,04	0,89
	CVE-2020-36775	0,44	0,67	0,04	0,46
	CVE-2021-47038	0,55	0,68	0,007	0,44
	CVE-2023-52456	0,55	0,68	0,19	0,64
	CVE-2024-26650	0,44	0,67	-	0,64
	CVE-2024-26624	0,55	0,68	-	0,69
	CVE-2024-26605	0,55	0,68	0,19	0,82
	CVE-2024-36976	0,55	0,68	0,12	0,75
	CVE-2024-45003	0,55	0,68	0,14	0,77
CWE-835	CVE-2023-45232	0,75	0,87	0,78	0,71
	CVE-2024-26603	0,55	0,57	0,007	0,77
	CVE-2024-1931	0,75	0,87	0,96	0,46
	CVE-2023-0437	0,75	0,87	0,14	0,5
	CVE-2024-27577	0,75	0,87	0,79	0,32
	CVE-2024-24786	0,59	0,82	0,37	0,41
	CVE-2024-4854	0,53	0,59	0,72	0,76

Продолжение таблицы 12

Связанные типы ошибок CWE	Связанные уязвимости CVE	CVSS 3.1	CVSS 4.0	EPSS	OWASP
CWE-835	CVE-2024-36288	0,55	0,68	0,18	0,89
	CVE-2023-50120	0,55	0,67	0,11	0,37
	CVE-2024-35982	0,55	0,68	0,22	0,51
	CVE-2022-48840	0,55	0,57	0,01	0,59
	CVE-2022-48862	0,55	0,68	0,02	0,51
	CVE-2024-45506	0,62	0,69	0,72	0,51
	CVE-2024-35982	0,55	0,68	0,22	0,51
	CVE-2024-31949	0,62	0,69	0,5	0,45
	CVE-2024-8088	0,75	0,57	0,08	0,93
CWE-662	CVE-2019-15031	0,44	0,48	0,15	0,3
	CVE-2020-12769	0,55	0,68	0,17	0,85
	CVE-2020-14059	0,63	0,7	0,86	0,57
	CVE-2021-29650	0,55	0,68	0,03	0,5
	CVE-2020-25668	0,7	0,73	0,16	0,37
	CVE-2022-39189	0,55	0,68	0,01	0,66
	CVE-2023-3389	0,78	0,85	0,12	0,37
	CVE-2023-5088	0,64	0,71	0,02	0,77
	CVE-2024-26958	0,55	0,57	0,2	0,35
	CVE-2024-7409	0,75	0,87	0,79	0,66

Применение формулы 2 позволило консолидировать нормированные результаты калькуляторов критичности уязвимостей, релевантных шаблону атаки CAPEC-25 (таблица 13).

Таблица 13 – Среднеквадратичные значения критичности уязвимостей CAPEC-25

Связанные типы ошибок CWE	Связанные уязвимости CVE	Значение критичности
CWE-412	CVE-2019-11485	0,34
CWE-567	CVE-2023-44374	0,66
CWE-667	CVE-2023-31082	0,61
CWE-833	CVE-2021-1622	0,74
	CVE-2022-4269	0,48
	CVE-2023-0160	0,47
	CVE-2023-34324	0,57
	CVE-2024-0641	0,45
	CVE-2024-0639	0,6
	CVE-2020-36775	0,46
	CVE-2021-47038	0,49
	CVE-2023-52456	0,55
	CVE-2024-26650	0,59
	CVE-2024-26624	0,64
	CVE-2024-26605	0,6
	CVE-2024-36976	0,58
	CVE-2024-45003	0,59
CWE-835	CVE-2023-45232	0,78
	CVE-2024-26603	0,55
	CVE-2024-1931	0,78
	CVE-2023-0437	0,63
	CVE-2024-27577	0,71
	CVE-2024-24786	0,57
	CVE-2024-4854	0,66
	CVE-2024-36288	0,52
	CVE-2023-50120	0,47

Продолжение таблицы 13

Связанные типы ошибок CWE	Связанные уязвимости CVE	Значение критичности
CWE-835	CVE-2024-35982	0,52
	CVE-2022-48840	0,49
CWE-835	CVE-2022-48862	0,5
	CVE-2024-45506	0,64
	CVE-2024-31949	0,57
	CVE-2024-8088	0,66
CWE-662	CVE-2019-15031	0,37
	CVE-2020-12769	0,61
	CVE-2020-14059	0,7
	CVE-2021-29650	0,5
	CVE-2020-25668	0,54
	CVE-2022-39189	0,55
	CVE-2023-3389	0,61
	CVE-2023-5088	0,51
	CVE-2024-26958	0,44
	CVE-2024-7409	0,77

Посредством применения калькуляторов по системам CVSS 3.1, CVSS 4.0, EPSS, OWASP получены значения критичности уязвимостей, релевантных для CAPEC-27 (таблица 14), а с применением формулы 1 данные значения удалось привести к единой шкале, дифференцирующей значения в диапазоне от 0 до 1 (таблица 15).

Таблица 14 – Результаты применения калькуляторов для уязвимостей CAPEC-27

Связанные типы ошибок CWE	Связанные уязвимости CVE	EPSS	CVSS 3.1	CVSS 4.0	OWASP
CWE-367	CVE-2024-27983	0,686	5.3	6,9	5.125
	CVE-2021-35937	0,003	6.3	5,4	7.25
	CVE-2022-23084	0,059	8.2	9,3	6.875
CWE-367	CVE-2020-15702	0,2665	7.0	7,3	7.25
	CVE-2021-3054	0,6956	7.2	8,6	5.125
	CVE-2023-22397	0,2036	6.1	7	9.875
	CVE-2024-7348	0,5058	8.8	8,7	6.125
	CVE-2023-21215	0,297	7.8	8,5	6.875
	CVE-2020-35508	0,176	4.5	2	3.25
	CVE-2024-30088	0,992	7.0	7,3	9.250
	CVE-2024-38153	0,5	7.8	8,5	6.620
	CVE-2021-35090	0,294	9.3	9,4	7.125
	CVE-2023-20135	0,025	7.0	7,3	8.875
	CVE-2024-35265	0,314	7.0	7,3	5.75
CWE-662	CVE-2020-12769	0,199	5.5	6,8	3.375
	CVE-2020-25668	0,337	7.0	7,3	4.250
	CVE-2022-39189	0,0155	5.5	6,8	6.875
	CVE-2019-15031	0,177	4.4	4,8	5.375
	CVE-2024-7409	0,8139	7.5	8,7	7.62
	CVE-2023-3389	0,0312	7.8	8,5	8.75
	CVE-2023-5088	0,012	6.4	7,1	5.375
	CVE-2020-14059	0,869	6.3	7	4.62
	CVE-2024-26958	0,009	5.5	6,8	6.125
	CVE-2021-29650	0,013	5.5	6,8	7.620
CWE-667	CVE-2023-31082	0,0373	5.5	6,8	3.0
CWE-61	CVE-2021-31997	0,331	6.8	7	5.0

Продолжение таблицы 14

Связанные типы ошибок CWE	Связанные уязвимости CVE	EPSS	CVSS 3.1	CVSS 4.0	OWASP
CWE-61	CVE-2021-23177	0,118	7.3	7	6.25
	CVE-2021-31566	0,078	7.3	7	6.15
	CVE-2023-6597	0,231	8.4	8,6	3.125
	CVE-2024-25952	0,278	6.0	6,8	4.5
	CVE-2024-25953	0,278	6.0	6,8	6.875
	CVE-2019-16775	0,529	7.7	8,6	3.5
	CVE-2020-28007	0,314	7.8	8,5	7.875

Таблица 15 – Нормализованные оценки критичности уязвимостей CAPEC-27

Связанные типы ошибок CWE	Связанные уязвимости CVE	CVSS 3.1	CVSS 4.0	EPSS	OWASP
CWE-367	CVE-2024-27983	0,686	0,53	0,69	0,5125
	CVE-2021-35937	0,003	0,63	0,54	0,725
	CVE-2022-23084	0,059	0,82	0,93	0,6875
	CVE-2020-15702	0,2665	0,70	0,73	0,725
	CVE-2021-3054	0,6956	0,72	0,86	0,5125
	CVE-2023-22397	0,2036	0,61	0,7	0,9875
	CVE-2024-7348	0,5058	0,88	0,87	0,6125
	CVE-2023-21215	0,297	0,78	0,85	0,6875
	CVE-2020-35508	0,176	0,45	0,2	0,325
	CVE-2024-30088	0,992	0,70	0,73	0,925
	CVE-2024-38153	0,5	0,78	0,85	0,662
	CVE-2021-35090	0,294	0,93	0,94	0,7125
	CVE-2023-20135	0,025	0,7	0,73	0,8875
	CVE-2024-35265	0,314	0,7	0,73	0,575
CWE-662	CVE-2020-12769	0,199	0,55	0,68	0,3375

Продолжение таблицы 15

Связанные типы ошибок CWE	Связанные уязвимости CVE	CVSS 3.1	CVSS 4.0	EPSS	OWASP
CWE-662	CVE-2020-25668	0,337	0,7	0,73	0,425
	CVE-2022-39189	0,0155	0,55	0,68	0,6875
	CVE-2019-15031	0,177	0,44	0,48	0,5375
	CVE-2024-7409	0,8139	0,75	0,87	0,762
	CVE-2023-3389	0,0312	0,78	0,85	0,875
	CVE-2023-5088	0,012	0,64	0,71	0,5375
	CVE-2020-14059	0,869	0,63	0,7	0,462
	CVE-2024-26958	0,009	0,55	0,68	0,6125
	CVE-2021-29650	0,013	0,55	0,68	0,762
CWE-667	CVE-2023-31082	0,0373	0,55	0,68	0,3
CWE-61	CVE-2021-31997	0,331	0,68	0,7	0,5
	CVE-2021-23177	0,118	0,73	0,7	0,625
	CVE-2021-31566	0,078	0,73	0,7	0,615
	CVE-2023-6597	0,231	0,84	0,86	0,3125
	CVE-2024-25952	0,278	0,6	0,68	0,45
	CVE-2024-25953	0,278	0,6	0,68	0,6875
	CVE-2019-16775	0,529	0,77	0,86	0,35
	CVE-2020-28007	0,314	0,78	0,85	0,7875

Применение формулы 2 позволило привести нормированные результаты калькуляторов критичности уязвимостей, релевантных шаблону атаки CAPEC-27, к единому виду (таблица 16).

Таблица 16 – Среднеквадратичные значения критичности уязвимостей CAPEC-27

Связанные типы ошибок CWE	Связанные уязвимости CVE	Значение критичности
CWE-367	CVE-2021-35937	0,55
	CVE-2022-23084	0,71
	CVE-2020-15702	0,636
	CVE-2021-3054	0,708
	CVE-2023-22397	0,685
	CVE-2024-7348	0,735
	CVE-2023-21215	0,688
	CVE-2020-35508	0,308
	CVE-2024-30088	0,846
	CVE-2024-38153	0,71
	CVE-2021-35090	0,765
	CVE-2023-20135	0,685
	CVE-2024-35265	0,698
CWE-662	CVE-2020-12769	0,479
	CVE-2020-25668	0,71
	CVE-2022-39189	0,512
	CVE-2019-15031	0,556
	CVE-2024-7409	0,431
	CVE-2023-3389	0,779
	CVE-2023-5088	0,636
	CVE-2020-14059	0,681
	CVE-2024-26958	0,534
	CVE-2021-29650	0,567
CWE-667	CVE-2023-31082	0,463
CWE-61	CVE-2021-31997	0,645
	CVE-2021-23177	0,567

Продолжение таблицы 16

Связанные типы ошибок CWE	Связанные уязвимости CVE	Значение критичности
CWE-61	CVE-2021-31566	0,82
	CVE-2023-6597	0,63
	CVE-2024-25952	0,583
	CVE-2024-25953	0,61
	CVE-2019-16775	0,659
	CVE-2020-28007	0,723

Посредством применения калькуляторов по системам CVSS 3.1, CVSS 4.0, EPSS, OWASP получены значения критичности уязвимостей, релевантных для CAPEC-140 (таблица 17), а с применением формулы 1 данные значения удалось привести к единой шкале, дифференцирующей значения в диапазоне от 0 до 1 (таблица 18).

Таблица 17 – Результаты применения калькуляторов для уязвимостей CAPEC-140

Связанные типы ошибок CWE	Связанные уязвимости CVE	EPSS	CVSS 3.1	CVSS 4.0	OWASP
CWE-372	CVE-2023-31127	0,011	8.8	8,7	8.750
	CVE-2021-25735	0,185	6.5	7	7.500
	CVE-2023-4012	0,002	7.5	8,7	3.750
	CVE-2023-36834"	0,002	7.5	8,7	6.0
	CVE-2024-41047'	0,034	6.3	7	4.62
	CVE-2024-22590'	0,00006	6.3	5,4	7.25
	CVE-2022-15041	0,003	8.8	8,7	6.125
	CVE-2021-47551	0,0001	6.4	7,1	5.375
	CVE-2024-13458	0,0004	7.3	7	6.25

Таблица 18 – Нормализованные оценки критичности уязвимостей CAPEC-140

Связанные типы ошибок CWE	Связанные уязвимости CVE	EPSS	CVSS 3.1	CVSS 4.0	OWASP
CWE-372	CVE-2023-31127	0,011	0,88	0,87	0,8750
	CVE-2021-25735	0,185	0,65	0,7	0,7500
	CVE-2023-4012	0,002	0,75	0,87	0,3750
	CVE-2023-36834"	0,002	0,75	0,87	0,6
	CVE-2024-41047'	0,034	0,63	0,7	0,462
	CVE-2024-22590'	0,00006	0,63	0,54	0,725
	CVE-2022-15041	0,003	0,88	0,87	0,6125
	CVE-2021-47551	0,0001	0,64	0,71	0,5375
	CVE-2024-13458	0,0004	0,73	0,7	0,625

Применение формулы 2 позволило привести нормированные результаты калькуляторов критичности уязвимостей, релевантных шаблону атаки CAPEC-140, к единому виду (таблица 19).

Таблица 19 – Среднеквадратичные значения критичности уязвимостей CAPEC-140

Связанные типы ошибок CWE	Связанные уязвимости CVE	Значение критичности
CWE-372	CVE-2023-31127	0,756
	CVE-2021-25735	0,687
	CVE-2023-4012	0,673
	CVE-2023-36834"	0,647
	CVE-2024-41047	0,525
	CVE-2024-22590'	0,55
	CVE-2022-15041	0,734
	CVE-2021-47551	0,548
	CVE-2024-13458	0,594

Посредством применения калькуляторов по системам CVSS 3.1, CVSS 4.0, EPSS, OWASP получены значения критичности уязвимостей, релевантных для CAPEC-696 (таблица 20), а с применением формулы 1 данные значения удалось привести к единой шкале, дифференцирующей значения в диапазоне от 0 до 1 (таблица 21).

Таблица 20 – Результаты применения калькуляторов для уязвимостей CAPEC-696

Связанные типы ошибок CWE	Связанные уязвимости CVE	EPSS	CVSS 3.1	CVSS 4.0	OWASP
CWE-226	CVE-2022-23824	0,0002	5.6	6,8	5.0
	CVE-2023-1637	0,0001	5.5	6,8	9.62
	CVE-2023-3006	0,00009	5.5	6,8	5.25
	CVE-2019-12675	0,00032	8.2	9,3	5.0
	CVE-2019-12674	0,00028	8.2	9,3	6.875
	CVE-2019-1911	0,00055	5.3	4,8	9.5
	CVE- 2017-5715	0,0001	5.6	6,8	4.875
	CVE-2017-5753	0,0004	6.8	6,3	6.175
	CVE-2021-3156	0,0009	7.8	8,5	6.375
	CVE-2024-21850	0,00024	4.4	4,8	8.375

Таблица 21 – Нормализованные оценки критичности уязвимостей CAPEC-696

Связанные типы ошибок CWE	Связанные уязвимости CVE	EPSS	CVSS 3.1	CVSS 4.0	OWASP
CWE-226	CVE-2022-23824	0,0002	0,56	0,68	0,5
	CVE-2023-1637	0,0001	0,55	0,68	0,962
	CVE-2023-3006	0,00009	0,55	0,68	0,525
	CVE-2019-12675	0,00032	0,82	0,93	0,5
	CVE-2019-12674	0,00028	0,82	0,93	0,6875
	CVE-2019-1911	0,00055	0,53	0,48	0,95

Продолжение таблицы 21

Связанные типы ошибок CWE	Связанные уязвимости CVE	EPSS	CVSS 3.1	CVSS 4.0	OWASP
CWE-226	CVE- 2017-5715	0,0001	0,56	0,68	0,4875
	CVE-2017-5753	0,0004	0,68	0,63	0,6175
	CVE-2021-3156	0,0009	0,78	0,85	0,6375
	CVE-2024-21850	0,00024	0,44	0,48	0,8375

Применение формулы 2 позволило привести нормированные результаты калькуляторов критичности уязвимостей, релевантных шаблону атаки CAPEC-696, к единому виду (таблица 22).

Таблица 22 – Среднеквадратичные значения критичности уязвимостей CAPEC-696

Связанные типы ошибок CWE	Связанные уязвимости CVE	Значение критичности
CWE-226	CVE-2022-23824	0,506
	CVE-2023-1637	0,65
	CVE-2023-3006	0,51
	CVE-2019-12675	0,668
	CVE-2019-12674	0,709
	CVE-2019-1911	0,595
	CVE- 2017-5715	0,5
	CVE-2017-5753	0,557
	CVE-2023-21608	0,659
	CVE-2024-21850	0,53

3.2 Оценка вероятностей успешного использования уязвимостей и рисков успешности реализации различных вариантов сформированных сценариев атак

Для выборки наиболее вероятного подмножества сценариев реализации атаки необходимо провести оценку вероятности эксплуатации выделенных ранее уязвимостей и соответствующих значений ущерба, в случае их эксплуатации, в рамках рассмотренных ранее техник.

Пусть в системе классификации CAPEC идентифицирована кибератака шаблона, тогда в рамках сценария, посредством техники, может быть эксплуатирована одна из рассматриваемых уязвимостей, следовательно вероятность успешного применения техники можно определить по формуле 3: [53-55, 61]

$$p_i = \frac{K_i}{\sum_{j=1}^{N} K_j}, \quad (3)$$

где p_i – значение вероятности эксплуатации уязвимости;

K_i – значение критичности рассматриваемой уязвимости;

K_j – значение критичности уязвимости, релевантных сценарию атаки;

N – количество уязвимостей, что могут быть эксплуатированы рассматриваемой техникой.

В этом контексте важно уточнить, что для каждой группы событий справедливо утверждение – сумма вероятностей эксплуатации уязвимости равна 1 (формула 4):

$$\sum_{i=1}^{N} p_i = 1, \quad (4)$$

где p_i – значение вероятности эксплуатации i-ой уязвимости посредством предметной техники;

N – количество уязвимостей, что могут быть эксплуатированы рассматриваемой техникой.

Ущерб, наносимый атакуемой системе в случае успешной эксплуатации уязвимости, оценивается по формуле 5: [53-55, 61]

$$U = 1 - (1 - U_{\text{К}}) \cdot (1 - U_{\text{Ц}}) \cdot (1 - U_{\text{Д}}), \quad (5)$$

где U – значение ущерба от эксплуатации уязвимости;

$U_К$, $U_Ц$ и $U_Д$ – показатели воздействия на конфиденциальность, целостность и доступность данных от эксплуатации уязвимости, соответственно.

Группа базовых показателей CVSS v3.1 представляет собой внутренние характеристики уязвимости, которые остаются неизменными с течением времени и в разных пользовательских средах. Среди этих показателей присутствуют метрики, отражающие влияние эксплуатации уязвимостей на конфиденциальность (C), целостность (I) и доступность (A).Оценка каждой из трех метрик может быть выражена в трех качественных значениях: Не оказывает (N), Низкое (L) или Высокое (H). [17-19, 51-55, 61]

Оценка ущерба требует применения скалярных значений. Исходя из этого метрики воздействия на триаду защищенности информации дифференцированы CIA по шкале от 0 до 1 на три значения: 0 соответствует значению «не оказывает»; 0,2 соответствует значению «низкое»; 0,5 соответствует значению «высокое».

Предложенная модель (формула 6) определяет общий риск как произведение вероятностей эксплуатации отдельных уязвимостей и суммы ущербов, наносимых каждой из них. [53-55, 61]

$$Risk = \prod_{i=1}^{N} p_i \cdot \sum_{j=1}^{N} U_j, \quad (6)$$

где *Risk* – значение риска успешной реализации сценария атаки;

p_i – значение вероятности эксплуатации i-ой уязвимости посредством реализации техники;

U_j – значение ущерба, наносимого атакуемой системе в результате эксплуатации j-ой уязвимости посредством реализации техники;

N – количество переходов между техниками в сценарии атаки.

Каждый шаг атаки детально описан, включая используемые техники из базы MITRE ATT&CK, что позволяет структурировать описание сценария и использовать его для оценки риска, для последующего ранжирования мероприятий по усилению безопасности, на предмет наиболее приоритетных. Результат анализа обеспечит чёткое понимание механизма атаки и позволит выделить наиболее уязвимые точки в сценарии предметного шаблона атаки. [10-14, 27-29, 39, 61-63]

С помощью результатов, которые возможно оценить посредством указанных формул, возможно провести выборку среди смоделированных сценариев, на предмет наиболее вероятного алгоритма действий злоумышленника. Однако, оценивать метрики полных сценариев видится избыточным, т.к. данные множества сценариев базируются на одних тактиках и техниках атаки. В этой связи целесообразно разбить сценарии на микромодели для последующего конструирования расчетов в целостные векторы атаки.

Далее представлены результаты оценки вероятности и негативных последствий выраженных в скалярных величинах (таблица 23-29) для выборки микромоделей с наибольшими показателями ущерба и вероятности сценария реализации шаблона атаки CAPEC-25, представленные в виде графа Марковских процессов, что позволяет учесть вероятностный характер переходов между этапами атаки и неопределенность действий злоумышленника. (рисунок 19-25).

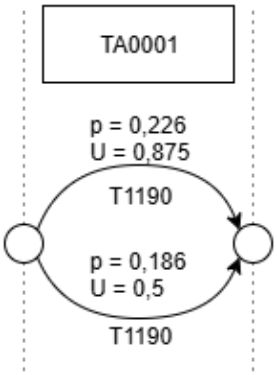


Рисунок 18 – Наиболее вероятная микромодель сценария CAPEC-25 по технике T1190

Таблица 23 – Микромодель сценария CAPEC-25 (T1190 – T1059| T1129)

Уязвимость	Вероятность атаки	Ущерб
CVE-2023-3389	**0,186**	**0,875**
CVE-2021-1622	**0,226**	**0,5**
CVE-2024-4854	0,201	0,2
CVE-2023-31082	0,186	0,5
CVE-2023-44374	0,201	0,5

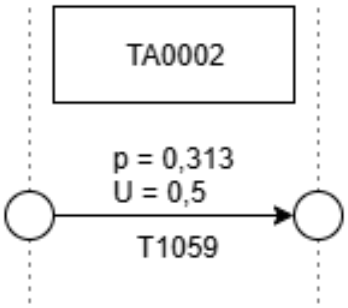


Рисунок 19 – Наиболее вероятная микромодель сценария CAPEC-25 по технике T1059

Таблица 24 – Микромодель сценария CAPEC-25 (T1059 – T1547| T1037)

Уязвимость	Вероятность атаки	Ущерб
CVE-2024-1931	**0,313**	**0,5**
CVE-2022-48862	0,2	0,5
CVE-2020-14059	0,281	0,5
CVE-2023-5088	0,206	0,875

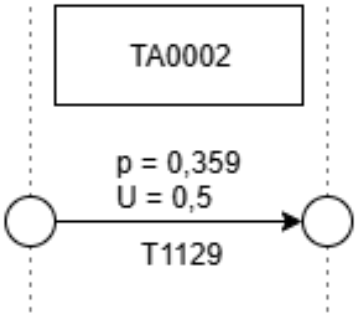


Рисунок 20 – Наиболее вероятная микромодель сценария CAPEC-25 по технике T1129

Таблица 25 – Микромодель сценария CAPEC-25 (T1129 – T1547| T1037)

Уязвимость	Вероятность атаки	Ущерб
CVE-2024-35982	0,306	0,5
CVE-2024-24786	0,335	0,5
CVE-2020-12769	**0,359**	**0,5**

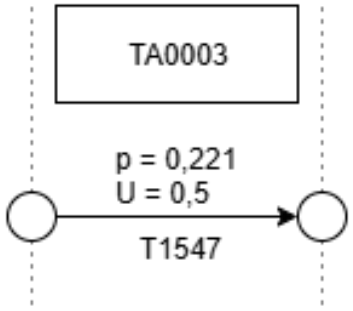


Рисунок 21 – Наиболее вероятная микромодель сценария CAPEC-25 по технике T1547

Таблица 26 – Микромодель сценария CAPEC-25 (T1547 – T1082)

Уязвимость	Вероятность атаки	Ущерб
CVE-2023-34324	0,16	0,5
CVE-2021-47038	0,14	0,5
CVE-2023-52456	0,158	0,5
CVE-2023-0437	0,18	0,5
CVE-2023-0160	0,135	0,5
CVE-2024-7409	**0,221**	**0,5**

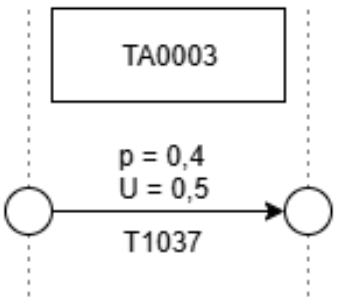


Рисунок 22 – Наиболее вероятная микромодель сценария CAPEC-25 по технике T1037

Таблица 27 – микромодель сценария CAPEC-25 (T1037 – T1082)

Уязвимость	Вероятность атаки	Ущерб
CVE-2024-0641	0,26	0,5
CVE-2024-0639	0,34	0,5
CVE-2024-27577	**0,4**	**0,5**

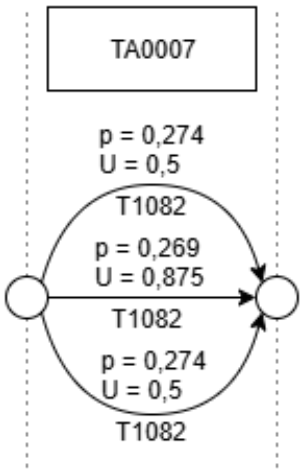


Рисунок 23 – Наиболее вероятная микромодель сценария CAPEC-25 по технике T1082

Таблица 28 – Микромодель сценария CAPEC-25 (T1082 – T1499.004)

Уязвимость	Вероятность атаки	Ущерб
CVE-2024-26603	**0,275**	**0,5**
CVE-2019-15031	0,184	0,36
CVE-2020-25668	**0,269**	**0,875**
CVE-2022-39189	**0,273**	**0,5**

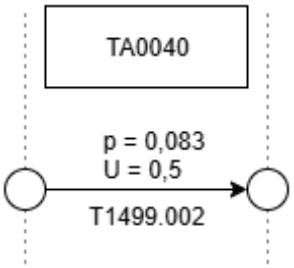


Рисунок 24 – Наиболее вероятная микромодель сценария CAPEC-25 по технике T1499.004

Таблица 29 – микромодель сценария CAPEC-25 (T1499.004 – Твых|TA003)

Уязвимость	Вероятность атаки	Ущерб
CVE-2019-11485	0,036	0,2
CVE-2022-4269	0,051	0,5
CVE-2020-36775	0,049	0,5
CVE-2024-26650	0,063	0,5
CVE-2024-26624	0,068	0,5
CVE-2024-26605	0,064	0,5
CVE-2023-45232	**0,083**	**0,5**
CVE-2024-45003	0,063	0,5
CVE-2024-26958	0,047	0,5
CVE-2024-8088	0,07	0,5
CVE-2024-36288	0,056	0,5
CVE-2023-50120	0,05	0,5
CVE-2024-31949	0,06	0,5
CVE-2021-29650	0,053	0,5
CVE-2022-48840	0,052	0,5
CVE-2024-45506	0,068	0,5
CVE-2024-36976	0,062	0,5

Анализ показал, что в случае атаки наиболее критичными и вероятными представляются следующие пары «техника – уязвимость»: T1190 – CVE-2023-3389, T1190 – CVE-2021-1622, T1059 – CVE-2024-1931, T1129 – CVE-2020-12769, T1547 – CVE-2024-7409, T1037 – CVE-2024-27577, T1082 – CVE-2024-26603, T1082 – CVE-2020-25668, T1082 – CVE-2022-39189, T1499.004 – CVE-2023-45232. Данная выборка микромоделей сценария реализации шаблона атаки CAPEC-25, позволила смоделировать обобщенный сценарий, состоящий пар с наибольшим значение риска, в виде графа Марковских процессов (рисунок 26) и провести оценку риска всей инвариантности его подмножества сценариев (таблица 30). В рамках выборки

было применено сочетание двух критериев: экстремумы вероятности эксплуатации уязвимости, посредством предметной техники, в совокупности с экстремумами потенциального ущерба от эксплуатации уязвимостей. [27-29, 39, 61-63]

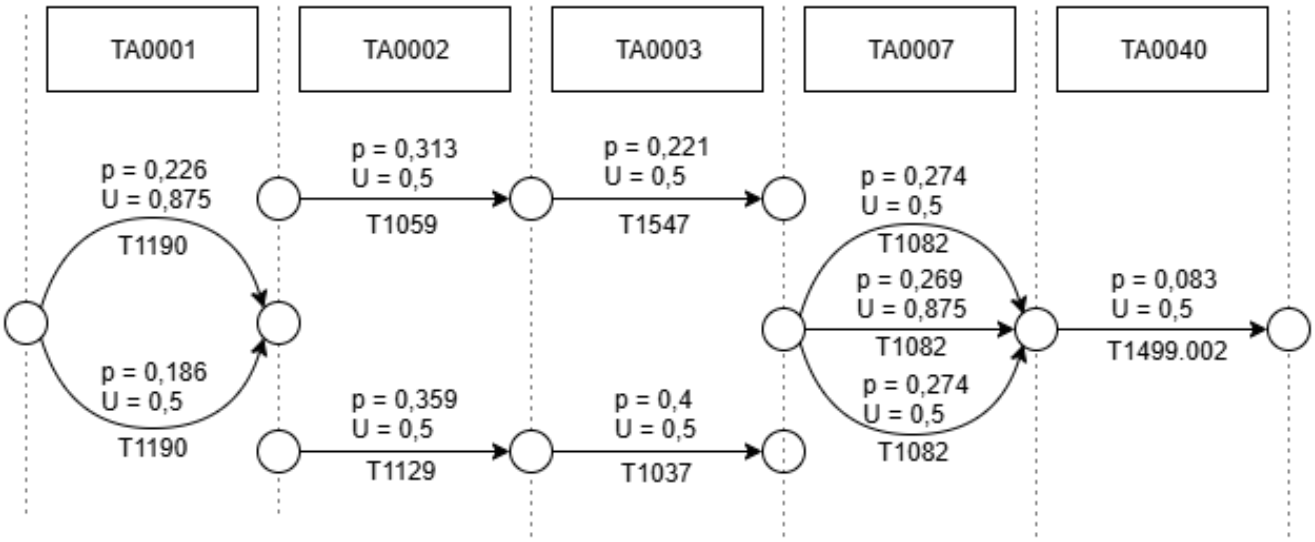


Рисунок 25 – Общая модель сценария CAPEC-25, сформированная на основе наиболее вероятных действий злоумышленника

Из данной модели сценария (рисунок 26) следует 18 подсценариев (таблица 30).

Таблица 30 – Значения риска наиболее вероятных подсценариев CAPEC-25 единичной атаки

Наиболее вероятные подсценарии CAPEC-25 единичной атаки	Риск
T1190 – CVE-2023-3389 – T1059 – CVE-2024-1931 – T1547 – CVE-2024-7409 – T1082 – CVE-2024-26603 – T1499.004 – CVE-2023-45232	0,0008
T1190 – CVE-2023-3389 – T1059 – CVE-2024-1931 – T1037 – CVE-2024-2757 – T1082 – CVE-2024-26603 – T1499.004 – CVE-2023-45232	0,0015
T1190 – CVE-2023-3389 – T1129 – CVE-2020-12769 – T1547 – CVE-2024-7409 – T1082 – CVE-2024-26603 – T1499.004 – CVE-2023-45232	0,001
T1190 – CVE-2023-3389 – T1129 – CVE-2020-12769 – T1037 – CVE-2024-2757 – T1082 – CVE-2024-26603 – T1499.004 – CVE-2023-45232	0,005

Продолжение таблицы 30

Наиболее вероятные подсценарии CAPEC-25 единичной атаки	Риск
T1190 – CVE-2023-3389 – T1059 – CVE-2024-1931 – T1547 – CVE-2024-7409 – T1082 – CVE-2020-25668 – T1499.004 – CVE-2023-45232	0,001
T1190 – CVE-2023-3389 – T1059 – CVE-2024-1931 – T1037 – CVE-2024-2757 – T1082 – CVE-2020-25668 – T1499.004 – CVE-2023-45232	**0,017**
T1190 – CVE-2023-3389 – T1129 – CVE-2020-12769 – T1547 – CVE-2024-7409 – T1082 – CVE-2020-25668 – T1499.004 – CVE-2023-45232	0,001
T1190 – CVE-2023-3389 – T1129 – CVE-2020-12769 – T1037 – CVE-2024-2757 – T1082 – CVE-2020-25668 – T1499.004 – CVE-2023-45232	0,002
T1190 – CVE-2023-3389 – T1059 – CVE-2024-1931 – T1547 – CVE-2024-7409 – T1082 – CVE-2022-39189 – T1499.004 – CVE-2023-45232	0,0008
T1190 – CVE-2023-3389 – T1059 – CVE-2024-1931 – T1547 – CVE-2024-7409 – T1082 – CVE-2022-39189 – T1499.004 – CVE-2023-45232	0,0015
T1190 – CVE-2023-3389 – T1059 – CVE-2024-1931 – T1037 – CVE-2024-2757 – T1082 – CVE-2022-39189– T1499.004 – CVE-2023-45232	0,001
T1190 – CVE-2023-3389 – T1129 – CVE-2020-12769 – T1547 – CVE-2024-7409 – T1082 – CVE-2022-39189 – T1499.004 – CVE-2023-45232	0,0004
T1190 – CVE-2023-3389 – T1059 – CVE-2024-1931 – T1547 – CVE-2024-7409 – T1082 – CVE-2024-26603 – T1499.004 – CVE-2023-45232	0,0009
T1190 – CVE-2023-3389 – T1059 – CVE-2024-1931 – T1037 – CVE-2024-2757 – T1082 – CVE-2024-26603 – T1499.004 – CVE-2023-45232	0,0016
T1190 – CVE-2023-3389 – T1129 – CVE-2020-12769 – T1547 – CVE-2024-7409 – T1082 – CVE-2024-26603 – T1499.004 – CVE-2023-45232	0,001
T1190 – CVE-2023-3389 – T1129 – CVE-2020-12769 – T1037 – CVE-2024-2757 – T1082 – CVE-2024-26603 – T1499.004 – CVE-2023-45232	0,002
T1190 – CVE-2023-3389 – T1059 – CVE-2024-1931 – T1547 – CVE-2024-7409 – T1082 – CVE-2020-25668 – T1499.004 – CVE-2023-45232	0,001

Продолжение таблицы 30

Наиболее вероятные подсценарии CAPEC-25 единичной атаки	Риск
T1190 – CVE-2023-3389 – T1059 – CVE-2024-1931 – T1037 – CVE-2024-2757 – T1082 – CVE-2020-25668 – T1499.004 – CVE-2023-45232	0,002
T1190 – CVE-2023-3389 – T1129 – CVE-2020-12769 – T1547 – CVE-2024-7409 – T1082 – CVE-2020-25668 – T1499.004 – CVE-2023-45232	0,001
T1190 – CVE-2023-3389 – T1129 – CVE-2020-12769 – T1037 – CVE-2024-2757 – T1082 – CVE-2020-25668 – T1499.004 – CVE-2023-45232	0,002
T1190 – CVE-2021-1622 – T1129 – CVE-2020-12769 – T1037 – CVE-2024-27577 – T1082 – CVE-2024-26603 – T1499.004 – CVE-2023-45232	**0,00185**
T1190 – CVE-2023-3389 – T1059 – CVE-2024-1931 – T1547 – CVE-2024-7409 – T1082 – CVE-2022-39189 – T1499.004 – CVE-2023-45232	0,0009
T1190 – CVE-2023-3389 – T1059 – CVE-2024-1931 – T1037 – CVE-2024-2757 – T1082 – CVE-2022-39189 – T1499.004 – CVE-2023-45232	0,0016
T1190 – CVE-2023-3389 – T1129 – CVE-2020-12769 – T1547 – CVE-2024-7409 – T1082 – CVE-2022-39189 – T1499.004 – CVE-2023-45232	0,001
T1190 – CVE-2023-3389 – T1129 – CVE-2020-12769 – T1037 – CVE-2024-2757 – T1082 – CVE-2022-39189 – T1499.004 – CVE-2023-45232	0,002

Таким образом, на основании риск-анализа сценария (рисунок 26) реализации шаблона атаки CAPEC-25, можно выделить сценарии, смоделированный на основе микромоделей с наибольшим показателем вероятности эксплуатации уязвимости, и сценарии с наибольшим и наименьшим показателем риска:

– наибольший риск компрометации АИС представляет следующий сценарий: T1190 – CVE-2023-3389 – T1059 – CVE-2024-1931 – T1037 – CVE-2024-2757 – T1082 – CVE-2020-25668 – T1499.004 – CVE-2023-45232;

– наиболее вероятный сценарий: T1190 – CVE-2021-1622 – T1129 – CVE-2020-12769 – T1037 – CVE-2024-27577 – T1082 – CVE-2024-26603 – T1499.004 – CVE-2023-45232;

– наименьший риск (0,0001) компрометации АИС представляет следующий сценарий: T1190 – CVE-2024-4854 – T1059 – CVE-2022-48862 – T1547 – CVE-2021-47038 – T1082 – CVE-2019-15031 – T1499.004 – CVE-2019-11485.

Далее представлены результаты оценки вероятности и негативных последствий выраженных в скалярных величинах (таблица 31-37) для выборки микромоделей с наибольшими показателями ущерба и вероятности сценария реализации шаблона атаки CAPEC-27 представленные в виде графа марковских процессов, что позволяет учесть вероятностный характер переходов между этапами атаки и неопределенность действий злоумышленника. (рисунок 29-35). [27-29, 39, 61-63]

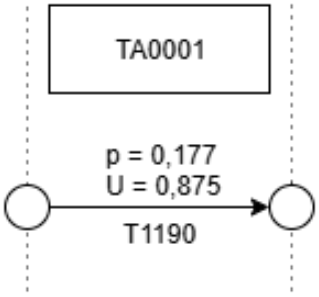


Рисунок 26 – Наиболее вероятная микромодель сценария CAPEC-27 по технике T1190

Таблица 31 – Микромодель сценария CAPEC-27 (T1190 – T1059|T1053)

Уязвимость	Вероятность атаки	Ущерб
CVE-2021-3054	0,16	0,875
CVE-2023-22397	0,155	0,5
CVE-2024-7348	0,167	0,875
CVE-2024-27983	0,138	0,6
CVE-2024-7409	0,098	0,5
CVE-2023-3389	**0,177**	**0,875**
CVE-2023-31082	0,105	0,5

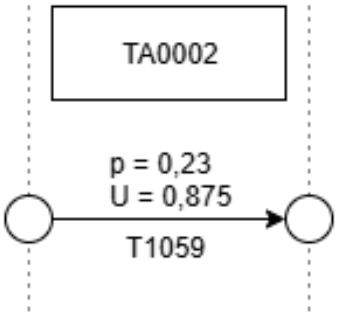


Рисунок 27 – Наиболее вероятная микромодель сценария CAPEC-27 по технике T1068

Таблица 32 – Микромодель сценария CAPEC-27 (T1059 – T1574|T1068)

Уязвимость	Вероятность атаки	Ущерб
CVE-2021-35937	0,165	0,875
CVE-2021-35090	**0,23**	**0,875**
CVE-2022-23084	0,212	0,875
CVE-2023-5088	0,19	0,875
CVE-2020-14059	0,203	0,5

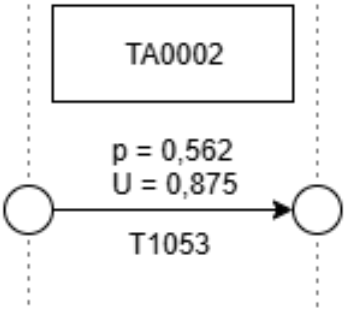


Рисунок 28 – Наиболее вероятная микромодель сценария CAPEC-27 по технике T1053

Таблица 33 – Микромодель сценария CAPEC-27 (T1053 – T1574|T1068)

Уязвимость	Вероятность атаки	Ущерб
CVE-2023-20135	**0,562**	**0,875**
CVE-2024-26958	0,438	0,5

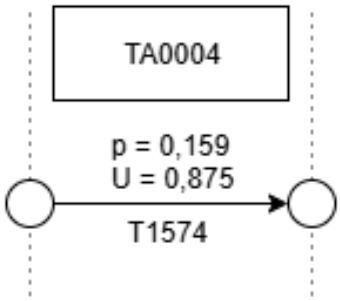


Рисунок 29 – Наиболее вероятная микромодель сценария CAPEC-27 по технике T1574

Таблица 34 – Микромодель сценария CAPEC-27 (T1574 – T1082)

Уязвимость	Вероятность атаки	Ущерб
CVE-2020-15702	0,123	0,875
CVE-2024-35265	0,134	0,875
CVE-2021-31997	0,124	0,6
CVE-2021-23177	0,11	0,875
CVE-2021-31566	**0,159**	**0,875**
CVE-2023-6597	0,121	0,75
CVE-2024-25952	0,112	0,75
CVE-2024-25953	0,117	0,75

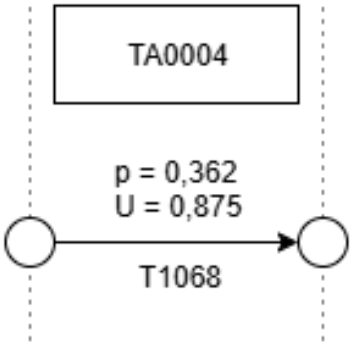


Рисунок 30 – Наиболее вероятная микромодель сценария CAPEC-27 по технике T1068

Таблица 35 – Микромодель сценария CAPEC-27 (T1068 – T1082)

Уязвимость	Вероятность атаки	Ущерб
CVE-2020-35508	0,131	0,488

Продолжение таблицы 35

Уязвимость	Вероятность атаки	Ущерб
CVE-2024-38153	0,303	0,875
CVE-2024-30088	**0,362**	**0,875**
CVE-2020-12769	0,204	0,5

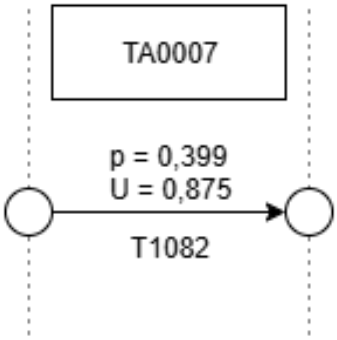


Рисунок 31 – Наиболее вероятная микромодель сценария CAPEC-27 по технике T1082

Таблица 36 – Микромодель сценария CAPEC-27 (T1082 – T1565.003)

Уязвимость	Вероятность атаки	Ущерб
CVE-2020-25668	**0,399**	**0,875**
CVE-2022-39189	0,288	0,5
CVE-2019-15031	0,313	0,36

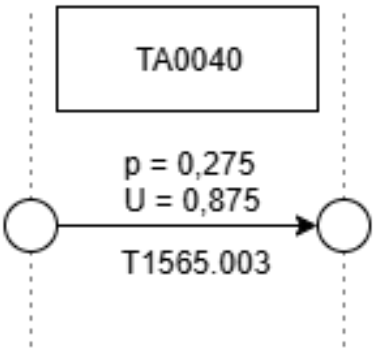


Рисунок 32 – Наиболее вероятная микромодель сценария CAPEC-27 по подтехнике T1565.003

Таблица 37 – Микромодель сценария CAPEC-27 (T1565.003 – Твых|T1053)

Уязвимость	Вероятность атаки	Ущерб
CVE-2023-21215	0,26	0,875
CVE-2019-16775	0,249	0,75
CVE-2020-28007	**0,275**	**0,875**
CVE-2021-29650	0,216	0,5

Анализ показал, что в случае атаки наиболее критичными и вероятными представляются следующие пары «техника – уязвимость»: T1190 – CVE-2023-3389, T1059 – CVE-2021-35090, T1053 – CVE-2023-20135, T1574 – CVE-2021-31566, T1068 – CVE-2024-30088, T1082 – CVE-2020-25668, T1565.003 – CVE-2020-28007. Данная выборка микромоделей сценария реализации шаблона атаки CAPEC-27, позволила смоделировать обобщенный сценарий, состоящий пар с наибольшим значение риска, в виде графа Марковских процессов (рисунок 34) и провести оценку риска всей инвариантности его подсценариев (таблица 38). В рамках выборки было применено сочетание двух критериев: экстремумы вероятности эксплуатации уязвимости, посредством предметной техники, в совокупности с экстремумами потенциального ущерба от эксплуатации уязвимостей. [27-29, 39, 61-63]

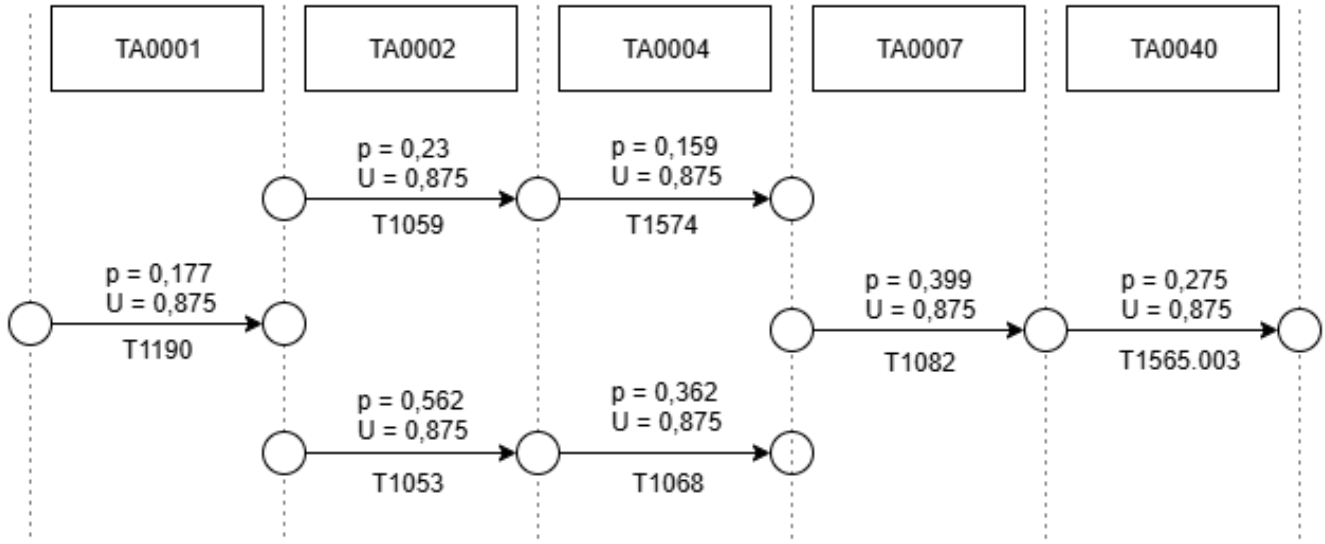


Рисунок 33 – Подсценарий CAPEC-27, сформированный на основе наиболее вероятных действий злоумышленника

Из данной модели сценария (рисунок 34) следует 4 подсценария (таблица 38).

Таблица 38 – Значения риска наиболее вероятных подсценариев CAPEC-27 единичной атаки

Наиболее вероятные подсценарии CAPEC-27 единичной атаки	Риск
T1190 – CVE-2023-3389 – T1059 – CVE-2021-35090 – T1574 – CVE-2021-31566 – T1082 – CVE-2020-25668 – T1565.003 – CVE-2020-28007	0,0031
T1190 – CVE-2023-3389 – T1059 – T1068 – CVE-2024-30088 – CVE-2021-35090 – T1082 – CVE-2020-25668 – T1565.003 – CVE-2020-28007	0,007
T1190 – CVE-2023-3389 – T1053 – CVE-2023-20135 – T1574 – CVE-2021-31566 – T1082 – CVE-2020-25668 – T1565.003 – CVE-2020-28007	0,0076
T1190 – CVE-2023-3389 – T1053 – CVE-2023-20135 – T1068 – CVE-2024-30088 – T1082 – CVE-2020-25668 – T1565.003 – CVE-2020-28007	**0,0173**

Таким образом, на основании риск-анализа сценария реализации шаблона атаки CAPEC-27, можно заключить, что наиболее вероятный и представляющий наибольший риск компрометации АИС представляет следующий сценарий: T1190 – CVE-2023-3389 – T1053 – CVE-2023-20135 – T1068 – CVE-2024-30088 – T1059 – T1082 – CVE-2020-25668 – T1565.003 – CVE-2020-28007.

Сценарий с наименьшим показателем риска (0,00023): T1190 – CVE-2024-7409 – T1059 – CVE-2021-35937 – T1068 – CVE-2020-35508 – T1082 – CVE-2019-15031 – T656.003 – CVE-2021-29650.

Далее представлены результаты оценки вероятности и негативных последствий выраженных в скалярных величинах (таблица 39-42) для выборки микромоделей с наибольшими показателями ущерба и вероятности сценария реализации шаблона атаки CAPEC-140 (рисунок 35-38).

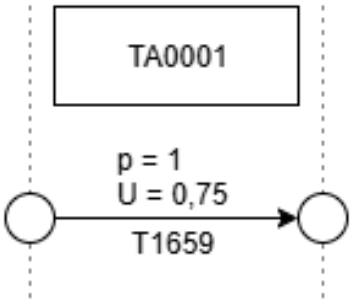


Рисунок 34 – Микромодель сценария CAPEC-140 по технике T1659

Таблица 39 – Микромодель сценария CAPEC-140 (T1659 – T1036)

Уязвимость	Вероятность атаки	Ущерб
CVE-2023-31127	**1**	**0,75**

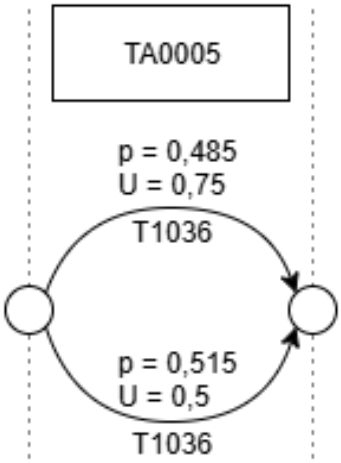


Рисунок 35 – Микромодель сценария CAPEC-140 по технике T1036

Таблица 40 – Микромодель сценария CAPEC-140 (T1036 – T1046)

Уязвимость	Вероятность атаки	Ущерб
CVE-2021-25735	**0,485**	**0,75**
CVE-2023-4012	0,515	0,5

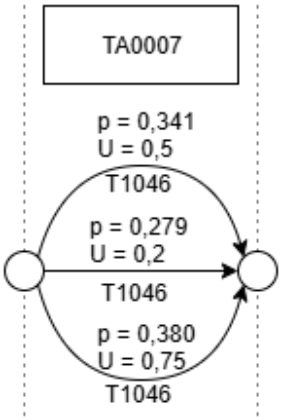


Рисунок 36 – Микромодель сценария CAPEC-140 по технике T1046

Таблица 41 – Микромодель сценария CAPEC-140 (T1046-T1565.002)

Уязвимость	Вероятность атаки	Ущерб
CVE-2023-36834'	0,341	0,5
CVE-2024-41047	0,279	0,2
CVE-2024-22590	**0,380**	**0,75**

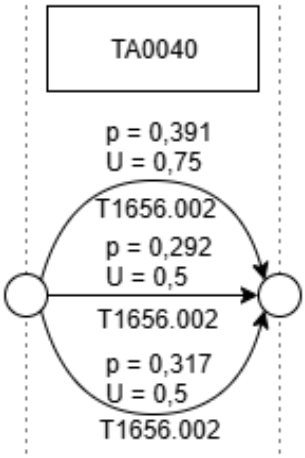


Рисунок 37 – Микромодель сценария CAPEC-140 по подтехнике T1656.002

Таблица 42 – Микромодель сценария CAPEC-140 (T1565.002 – Твых)

Уязвимость	Вероятность атаки	Ущерб
CVE-2022-15041	**0,391**	**0,75**
CVE-2021-47551	0,292	0,5
CVE-2024-13458	0,317	0,5

Анализ показал, что наибольший риск представляют следующие пары «техника – уязвимость»: T1659 – CVE-2023-31127, T1036 – CVE-2021-25735, T1046 – CVE-2024-22590, T1565.002 – CVE-2022-15041. Данная выборка наиболее вероятных микромоделей составляет сценарий с наибольшим показателем риска успешности реализации шаблона атаки CAPEC-140 (рисунок 39) (таблица 43). В рамках выборки было применено сочетание двух критериев: экстремумы вероятности эксплуатации уязвимости, посредством предметной техники, в совокупности с экстремумами потенциального ущерба от эксплуатации уязвимостей. [27-29, 39, 61-63]

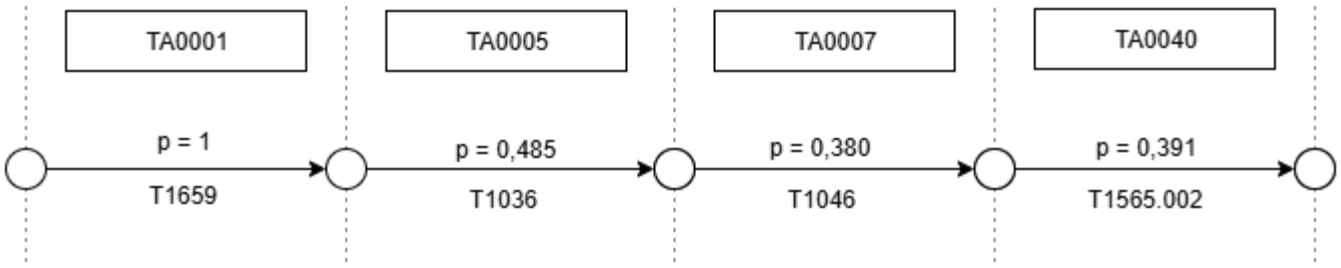


Рисунок 38 – Подсценарий CAPEC-140, сформированный на основе наиболее вероятных действий злоумышленника

Таблица 43 – Значение риска наиболее вероятного подсценария CAPEC-140 единичной атаки

Наиболее вероятные подсценарии CAPEC-140 единичной атаки	Риск
T1659 – CVE-2023-31127 – T1036 – CVE-2021-25735 – T1046 – CVE-2024-22590 – T1565.002 – CVE-2022-15041	0,216
T1659 – CVE-2023-31127 – T1036 – CVE-2023-4012 – T1046 – CVE-2024-22590 – T1565.002 – CVE-2022-15041	0,2104
T1659 – CVE-2023-31127 – T1036 – CVE-2023-4012 – T1046 – CVE-2024-41047 – T1565.002 – CVE-2021-47551	0,04196

Таким образом, на основании риск-анализа сценария реализации шаблона атаки CAPEC-140, можно заключить:

– наибольший риск компрометации АИС представляет следующий сценарий: T1659 – CVE-2023-31127 – T1036 – CVE-2021-25735 – T1046 – CVE-2024-22590 – T1565.002 – CVE-2022-15041;

– наиболее вероятный сценарий: T1659 – CVE-2023-31127 – T1036 – CVE-2023-4012 – T1046 – CVE-2024-22590 – T1565.002 – CVE-2022-15041;

– наименьший риск компрометации АИС представляет следующий сценарий: T1659 – CVE-2023-31127 – T1036 – CVE-2023-4012 – T1046 – CVE-2024-41047 – T1565.002 – CVE-2021-47551.

Далее представлены результаты оценки вероятности и негативных последствий выраженных в скалярных величинах (таблица 44-49) для выборки микромоделей сценария реализации шаблона атаки CAPEC-696 представленные в виде графа марковских процессов, что позволяет учесть вероятностный характер переходов между этапами атаки и неопределенность действий злоумышленника. (рисунок 40-45).

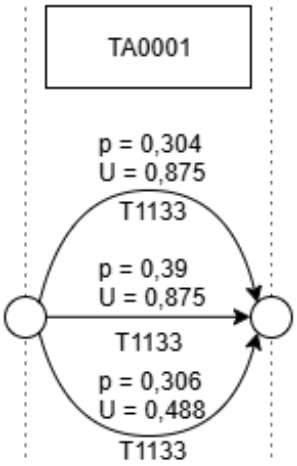


Рисунок 39 – Микромодель сценария CAPEC-696 по технике T1133

Таблица 44 – Микромодель сценария CAPEC-696 (T1133 – T1057)

Уязвимость	Вероятность атаки	Ущерб
CVE-2019-12675	0,304	0,875
CVE-2019-12674	**0,39**	**0,875**
CVE-2019-1911	0,306	0,488

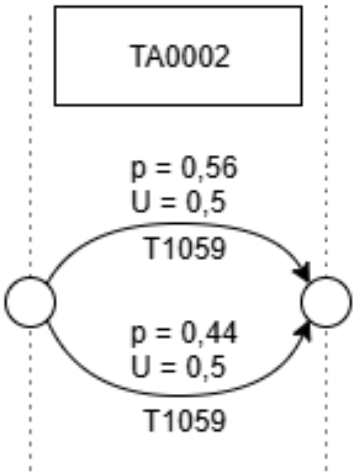


Рисунок 40 – Микромодель сценария CAPEC-696 по технике T1059

Таблица 45 – Микромодель сценария CAPEC-696 (T1059 – T1119)

Уязвимость	Вероятность атаки	Ущерб
CVE-2023-1637	**0,56**	**0,5**
CVE-2023-3006	0,44	0,5

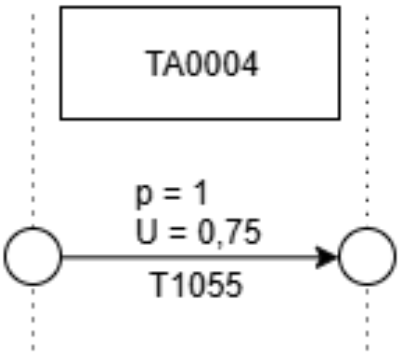


Рисунок 41 – Микромодель сценария CAPEC-696 по технике T1055

Таблица 46 – Микромодель сценария CAPEC-696 (T1055 – T1059)

Уязвимость	Вероятность атаки	Ущерб
CVE-2024-21850	1	0,75

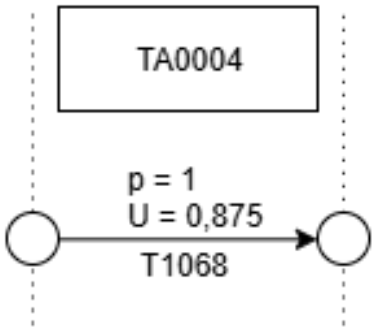


Рисунок 42 – Микромодель сценария CAPEC-696 по технике T1068

Таблица 47 – Микромодель сценария CAPEC-696 (T1068 – T1059)

Уязвимость	Вероятность атаки	Ущерб
CVE-2023-21608	**1**	**0,875**

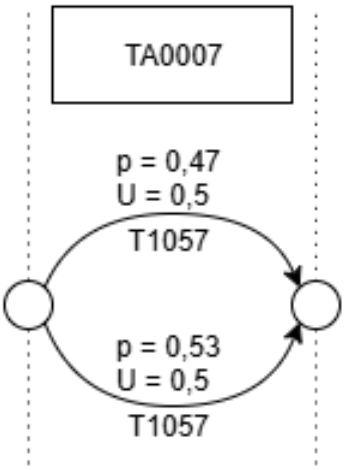


Рисунок 43 – Микромодель сценария CAPEC-696 по технике T1057

Таблица 48 – Микромодель сценария CAPEC-696 (T1057 – T1055|T1068)

Уязвимость	Вероятность атаки	Ущерб
CVE-2017-5715	0,47	0,5
CVE-2017-5753	**0,53**	**0,5**

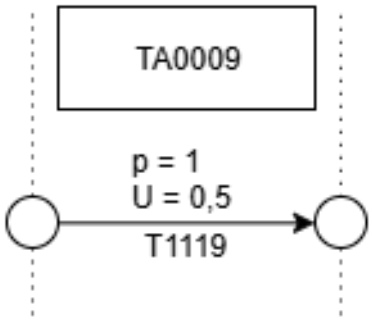


Рисунок 44 – Микромодель сценария CAPEC-696 по технике T1119

Таблица 49 – Микромодель сценария CAPEC-696 (T1119 – Твых)

Уязвимость	Вероятность атаки	Ущерб
CVE-2022-23824	**1**	**0,5**

Анализ показал, что наибольший риск представляют следующие пары «техника – уязвимость»: T1133 – CVE-2019-12674, T1057 – CVE-2017-5753, T1055 – CVE-2024-21850, T1068 – CVE-2023-21608, T1059 – CVE-2023-1637, T1119 – CVE-2022-23824. Данная выборка микромоделей сценария реализации шаблона атаки CAPEC-140, позволила смоделировать обобщенный сценарий, состоящий пар с наибольшим значение риска, в виде графа Марковских процессов (рисунок 46) и провести оценку риска всей инвариантности его подмножества сценариев (таблица 50). В рамках выборки было применено сочетание двух критериев: экстремумы вероятности эксплуатации уязвимости посредством предметной техники в совокупности с экстремумами потенциального ущерба от эксплуатации уязвимостей. [27-29, 39, 61-63]

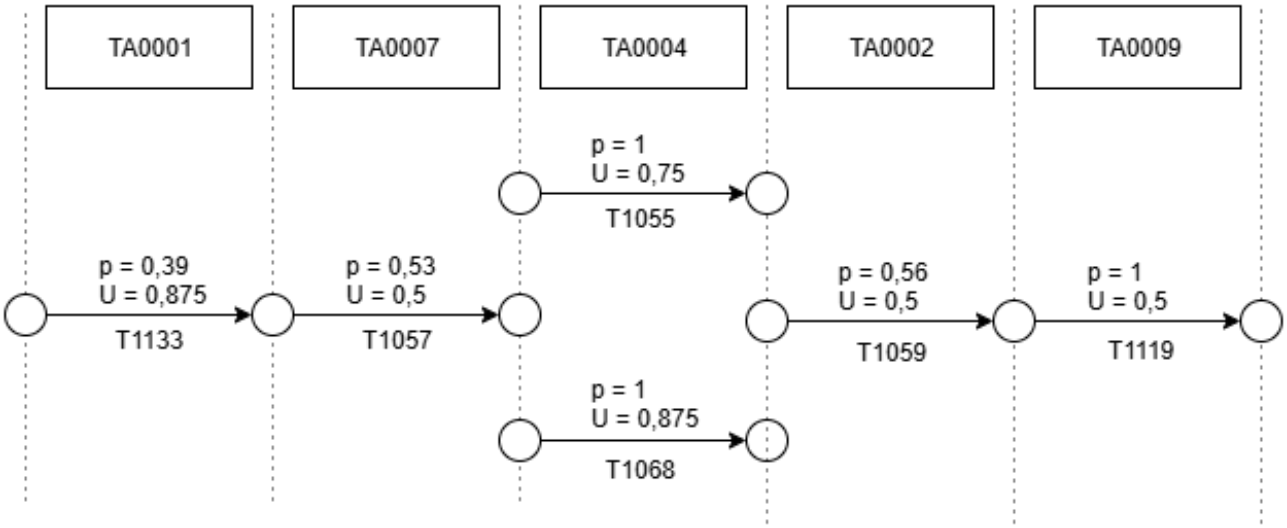


Рисунок 45 – Подсценарий CAPEC-696, сформированный на основе наиболее вероятных действий злоумышленника

Таблица 50 – Значение риска наиболее вероятного подсценария CAPEC-696 единичной атаки

Наиболее вероятные подсценарии CAPEC-696 единичной атаки	Риск
T1133 – CVE-2019-12674 – T1057 – CVE-2017-5753 – T1055 – CVE-2024-21850 – T1059 – CVE-2023-1637 – T1119 – CVE-2022-23824	0,362
T1133 – CVE-2019-12674 – T1057 – CVE-2017-5753 – T1068 – CVE-2023-21608 – T1059 – CVE-2023-1637 – T1119 – CVE-2022-23824	**0,376**

Таким образом, на основании риск-анализа сценария реализации шаблона атаки CAPEC-696, можно заключить, что наибольший вероятность и риск компрометации АИС представляет следующий сценарий атаки: T1133 – CVE-2019-12674 – T1057 – CVE-2017-5753 – T1068 – CVE-2023-21608 – T1059 – CVE-2023-1637 – T1119 – CVE-2022-23824. В то время как наименьший риск компрометации АИС представляет следующий сценарий атаки: T1133 – CVE-2019-1911 – T1057 – CVE-2017-5715 – T1055 – CVE-2024-21850 – T1059 – CVE-2023-3006 – T1119 – CVE-2022-23824.

4 Разработка регламентов реагирования и ликвидации последствий инцидентов безопасности для наиболее опасных сценариев атак класса «Манипулирование временем и состоянием»

В рамках данного раздела разработаны регламенты на основе анализа наиболее опасных и вероятных сценариев атак, выявленных в предыдущей главе. Такой подход позволяет создать детализированные процедуры реагирования, включающие как оперативные меры реагирования, так и мероприятия по ликвидации последствий для каждого рассматриваемого сценария. Форма представления разрабатываемых регламентов соответствует актуальным методическим рекомендациям и современным стандартам в области информационной безопасности. [31-34, 42-44, 56-60, 64-67]

Для обеспечения эффективной защиты информационных систем и минимизации потенциальных рисков необходимо разработать комплексный план противодействия киберугрозам. В рамках данного исследования предлагается систематизированный подход (таблица 51-54), основанный на анализе наиболее вероятных сценариев атак, выявленных в предыдущей главе, с учетом этапности реализации атак класса «Манипулирование временем и состоянием» соответствующей методологии MITRE ATT&CK.

Таблица 51 – Организационно-правовой регламент вектора атаки CAPEC-25

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Первоначальный Доступ	Атака на сетевой интерфейс путем отправки специально сформированных пакетов, вызывая конфликт ресурсов в подсистеме обработки сессий, что свидетельствует о	1. Проверить журналы системных событий на наличие сообщений об ошибках в работе подсистемы ввода-вывода 2. Заблокировать учетные записи пользователей, что были подвержены атаке.	1. Требуется выполнить полный аудит рабочей станции на предмет внедрения вредоносного кода и подозрительных процессов с повышенными привилегиями 2. Переустановить или

Продолжение таблицы 51

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
	применении техники T1190, эксплуатирующей уязвимость ядра операционной системы Linux CVE-2023-3389, связанной с использованием ранее освобожденной памяти.		восстановить операционную систему, а также проверить все критичные конфигурационные файлы на предмет несанкционированных изменений.
Выполнение	Злоупотребления функционалом смены для загрузки вредоносных модулей через прикладные интерфейсы, что свидетельствует о применении техники T1059, эксплуатирующей уязвимость CVE-2024-1931, связанной с выполнением цикла с недоступным условием выхода.	1. При обнаружении признаков атаки (например, аномальная загрузка CPU) необходимо немедленно изолировать проблемный узел. 2. Все подозрительные процессы должны быть принудительно завершены с последующим сбором дампов памяти для дальнейшего анализа.	1. Выполнить полную проверку целостности системных файлов и переустановить командные интерпретаторы из доверенных источников 2. Настроить систему автоматического мониторинга состояния с возможностью отправки уведомлений при обнаружении аномалий в работе узла сети.
Закрепление	Внедрения вредоносного кода в процессы загрузки системы для закрепления в системе и инициализации эксплойта до загрузки операционной системы, что свидетельствует о применении техники T1037, эксплуатирующей уязвимость CVE-2024-2757 в механизме загрузки ОС.	1. Перевести систему в аварийный режим с минимальным набором сервисов 2. Все подозрительные службы должны быть отключены, а соответствующие сервисы – остановлены.	1. Провести аудит планировщика заданий и автозагрузки на предмет наличия других следов компрометации 2. Выполнить полную переустановку загрузочного сектора и основных системных файлов. 3. Установить программный или программно-аппаратный модуль доверенной загрузки.

Продолжение таблицы 51

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
			4. Создание образа системы с для быстрого восстановления.
Обнаружение	Сбор данных о запущенных процессах и их взаимосвязях (для данного действия характерно аномальное потребление ресурсов атакуемого узла сети) – поведение свойственное технике T1082, эксплуатирующая уязвимость CVE-2020-25668, свидетельствующее о закреплении злоумышленника в системе.	1. Немедленно изолировать атакуемый узел от сети. 2. Все обнаруженные процессы, связанные со сбором системной информации, должны быть принудительно завершены с сохранением дампов памяти для последующего анализа 3. Произвести анализ логов, на предмет предыдущих действий по компрометации узла сети.	1. Зафиксировать обнаруженные следы несанкционированного доступа к системной информации для последующего расследования. 2. Проверить политики доступа к системной информации, внедрить механизмы контроля целостности ядра. 3. Провести аудит целостности системы, и в случае нарушении – восстановить из доверенных источников.
Воздействие	Отказ в обслуживании критических компонентов системы или средств защиты информации, свидетельствующий о реализации подтехники T1499.004, эксплуатирующей уязвимость CVE-2023-45232, что связана с переполнением буфера.	1. Изолировать атакованный узел от сети. 2. Перевести систему в аварийный режим с минимальным набором сервисов.	1. Зафиксировать обнаруженные следы несанкционированного доступа к системной информации для последующего расследования. 2. Все обнаруженные уязвимые компоненты должны быть обновлены или защищены компенсирующими мерами или выполнить полную проверку целостности системы и восстановить из доверенного источника.

Продолжение таблицы 51

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
			3. Провести аудит сетевой инфраструктуры на предмет атакованных узлов.

Таблица 52 – Организационно-правовой регламент вектора атаки CAPEC-27

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Первоначальный Доступ	Атака на сетевой интерфейс путем отправки специально сформированных пакетов, вызывая конфликт ресурсов в подсистеме обработки сессий, что свидетельствует о применении техники T1190, эксплуатирующей уязвимость ядра операционной системы Linux CVE-2023-3389, связанной с использованием ранее освобожденной памяти.	1. Проверить журналы системных событий на наличие сообщений об ошибках в работе подсистемы ввода-вывода. 2. Заблокировать учетные записи пользователей, что были подвержены атаке.	1. Требуется выполнить полный аудит рабочей станции на предмет внедрения вредоносного кода и подозрительных процессов с повышенными привилегиями. 2. Переустановить или восстановить операционную систему, а также проверить все критичные конфигурационные файлы на предмет несанкционированных изменений.
Выполнение	Создание вредоносных заданий в планировщике задач путем подмены легитимных заданий, свидетельствующее о применении техники T1053, эксплуатирующей уязвимость CVE-2023-20135. Эксплуатация	1. изолировать затронутое устройство от сети и провести анализ журналов установки. 2. Все обнаруженные вредоносные задания должны быть удалены с сохранением копий для последующего анализа.	1. Провести анализ системы на предмет несанкционированных изменений, используя инструменты контроля целостности. 2. Восстановить исходные конфигурации планировщика задач из

Продолжение таблицы 52

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
	уязвимости может позволить выполнить произвольный код, а создание задачи обеспечивает закрепление в системе и автоматизированное выполнение кода.		доверенной резервной копии. 3. Провести полную проверку системы на предмет других следов компрометации
Повышение привилегий	Подмена системных файлов операционной системы Windows путем применения символьной ссылки, свидетельствует о применении техники T1068, эксплуатирующей уязвимость CVE-2024-30088, связана с ошибками синхронизации при использовании общего ресурса. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии.	1. Ограничить права локальных пользователей через групповые политики. 2. Изолировать затронутые системы от сети и провести анализ процессов с повышенными привилегиями. 3. Запретить выполнение скриптов из временных каталогов. 4. Заблокировать все компрометированные учетные записи и завершить подозрительные процессы.	1. Установить чистый образ ОС с последующим применением всех актуальных обновлений безопасности. 2. Настроить мониторинг попыток несанкционированного доступа к объектам ядра с помощью инструментов типа Linux Event Forwarding. 3. Восстановить все пользовательские данные из резервных копий.
Обнаружение	Сбор сведений о системе, необходимых для заключительного воздействия, что свидетельствует о применении техники T1082, эксплуатирующую уязвимость CVE-2020-25668, связанную с использованием памяти после ее освобождения. Эксплуатация уязвимости	1. Изолировать затронутый узел от сети или ограничить доступ к виртуальным консолям и провести анализ запущенных процессов. 2. Проверить активные процессы на аномальные операции чтения из /proc. 3. Проанализировать журналы ядра на предмет попыток обхода	1. Для восстановления системы рекомендуется переустановить или обновить ядро, а также проверить все критичные конфигурационные файлы на предмет несанкционированных изменений. 2. Восстановить все пользовательские данные из резервных копий.

Продолжение таблицы 52

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
	может позволить нарушителю получить доступ к конфиденциальной информации.	ограничений. 4. Собрать дампы памяти подозрительных процессов для последующего анализа. 5. Исследовать символьные ссылки в /proc на предмет манипуляций.	
Воздействие	Подмена критических данных в runtime (учетные записи, конфигурации, сессионные токены) посредством подмены символьных ссылок (для доступа к файлам конфигурации) и манипуляции с динамической памятью, что позволяет изменять данные непосредственно в работающих процессах без их перезапуска. Эти действия свидетельствуют о применении подтехники T1565.002, эксплуатирующую уязвимость CVE-2020-28007, связанную с отслеживанием символьных ссылок. Эксплуатация уязвимости может позволить нарушителю повысить привилегии в системе путем создания специально сформированной символической ссылки на	1. Перевести систему в аварийный режим с минимальным набором сервисов. 2. Немедленная изоляция затронутых систем от сети. 3. Проверка целостности файлов конфигурации и сравнение с эталонными копиями.	1. Провести полный аудит системы, включая проверку всех изменений, внесенных через уязвимость. 2. Все модифицированные системные файлы должны быть восстановлены из проверенных резервных копий или переустановлены из официальных репозиториев 3. Провести аудит прав доступа к лог-директории и внедрить систему мониторинга создания символических ссылок в защищенных директориях 4. Внедрить механизмы контроля целостности критических системных файлов и настроить мониторинг изменений в системных директориях

Продолжение таблицы 52

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
	файл и перезаписи его с правами приложения.		

Таблица 53 – Организационно-правовой регламент вектора атаки CAPEC-140

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Первоначальный Доступ	обхода промежуточных форм аутентификации посредством манипулирования параметрами формы, что свидетельствует о применении техники T1659, эксплуатирующей уязвимость CVE-2023-31127, связанную с отсутствием процедуры аутентификации, позволяющая нарушителю перехватить сеанс пользователя.	1. Обновить и перезапустить сетевые службы и СУБД, чтобы исключить возможность сканирования и манипуляции данными. 2. При обнаружении аномальных временных задержек в системных журналах или SIEM-системе необходимо немедленно изолировать затронутые узлы. 3. Проверить целостность политик прав доступа и лишить подверженные атаке процессы прав доступа.	1 Внедрить строгий контроль временных параметров обработки запросов, включая внедрение механизмов синхронизации, воизбежание повторной попытки доступа. 2. Провести аудит активных сессий и принудительно обновить учетные данные доступа. 3. Восстановление данных из проверенных резервных копий и анализ журналов транзакций на предмет несанкционированных изменений.
Обход защиты	Маскировка под легитимного пользователя посредством подделки метаданных сессии и манипуляции токенами доступа, что свидетельствует о применении техники T1036, эксплуатирующую уязвимость CVE-2021-	1. Обновление сигнатуры IPS/IDS. 2. Изолировать скомпрометированные узлы от сети. 3. Проверить целостность процессов и файлов средств защиты информации, в случае нарушения – восстановить	1. Реализация решений типа IDS/IPS с поведенческим анализом для мониторинга на предмет аномальных действий. 2. Анализ запущенных процессов и открытых сессий. 3. Восстановление систем

Продолжение таблицы 53

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
	25735 компонента kube-apiserver программного средства управления кластерами виртуальных машин доменной сети, позволяющая нарушителю нарушить целостность данных, а также вызвать отказ в обслуживании.	из доверенных источников.	из проверенных резервных копий.
Обнаружение	Множественная отправка специально сформированных UDP-запросов к сетевым службам, вызывающие состояние гонки с легитимными дейтаграммами в обработке пакетов посредством эксплуатации уязвимости протокола TLS, что не отслеживает текущее состояние соединения из-за чего Hello-сообщения клиентов могут быть перезаписаны в любое время, в том числе после установления соединения. Данный инцидент свидетельствует о применении техники T1046, эксплуатирующей уязвимость CVE-2024-22590.	1. Изолировать подозрительные узлы и провести анализ сетевого трафика. 2. Проверить журналы сетевых устройств и систем мониторинга на предмет других признаков компрометации. 3. Уязвимые сервисы должны быть временно отключены или защищены дополнительными мерами аутентификации.	1. Реализовать сегментацию сети с применением микросегментации и строгих правил межсегментного взаимодействия 2. Настройка IDS/IPS для блокировки подозрительной сетевой активности 3. Ограничить время ответа на сетевые запросы
Воздействие	Обходить валидацию многоэтапных форм через инъекцию вредоносных	1. Заблокировать скомпрометированные учетные записи	1. Зафиксировать все изменения для последующего

Продолжение таблицы 53

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
	объектов сериализации, с целью изменения критических параметров после их проверки и сохранения некорректных данных в финальной форме, что свидетельствует о применении подтехники T1565.002, эксплуатирующей уязвимость CVE-2022-15041.	пользователей и применить криптографические механизмы проверки подлинности данных операционной системы (хеш-суммы, цифровые подписи). 2. Внедрение решений класса DLP с возможностью детектирования аномальных изменений данных 3. Реализовать WORM-хранилища для критичных данных, для установления факта НСД	расследования. 2. Запустить процедуру проверки целостности всех критических данных. 3. Восстановить данные из резервных копий.

Таблица 54 – Организационно-правовой регламент вектора атаки CAPEC-696

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Первоначальный Доступ	Подключение к внутренним ресурсам корпоративной сети из внешних источников с использованием техники T1133, эксплуатирующей уязвимость CVE-2019-12674 в механизме сессий для обхода аутентификации в Cisco FTD.	1. Немедленное отключение компрометированных удаленных сессий и блокировка IP-адресов источника атаки 2. Приостановка работы уязвимых экземпляров Cisco FTD с последующей изоляцией от сети 3. Аудит журналов аутентификации и мониторинг активных	1. Обновление Cisco FTD до версии с устраненной уязвимостью 2. Пересмотр и ужесточение политик доступа к внешним сервисам 3. Проверка целостности файловой системы и восстановление измененных файлов из резервных копий 4. Ротация учетных данных

Продолжение таблицы 54

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
		сессий на предмет подозрительной активности 4. Временное отключение многоэкземплярного режима работы FTD	всех пользователей с доступом к удаленным сервисам 5. Внедрение многофакторной аутентификации для всех внешних сервисов
Обнаружение	Обход изоляции процессов и чтение памяти других приложений через использование утилит Tasklist, Get-Process (Windows) или ps (Linux/Mac) для сбора информации о запущенных процессах посредством применения техники T1057, эксплуатирующей уязвимость CVE-2017-5753.	1. Немедленная изоляция затронутых рабочих станций от сети 2. Провести анализ журналов системы на предмет аномальных временных характеристик выполнения процессов, которые могут свидетельствовать об эксплуатации CVE-2017-5753 2. Принудительное выключение и блокировка подозрительных процессов	1. Установить патчи операционной системы, устраняющие уязвимость CVE-2017-5753 2. Настройка механизмов изоляции процессов и ограничение прав доступа к информации о выполняемых процессах 3. настроить системы мониторинга на детектирование аномальных паттернов доступа к информации о процессах
Повышение привилегий	Внешний вызов и использование исполняемых файлов spoolsv или connhost, которые являются легитимными приложениями Windows. Этот запрос ищет случаи вызова пользователем любого из этих исполняемых файлов, свидетельствуя потенциально вредоносной о применении техники	1. Немедленная изоляция затронутых рабочих станций от сети 2. Отозвать все подозрительные повышенные привилегии 3. Анализ дампов памяти на предмет следов эксплуатации и блокировка исполняемых файлов, созданных через эксплойт 4. Удаление всех временных файлов	1. Восстановить оригинальные настройки безопасности 2. Отключить неиспользуемые службы LSA и ограничить доступ к критическим системным компонентам через политики групповых ограничений 3. Провести аудит всех критических операций, выполненных в период потенциальной

Продолжение таблицы 54

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
	T1068, эксплуатирующей CVE-2023-21608.		компрометации
Выполнение	Вызов сбоев системы через внедрение вредоносного кода в интерпретаторы команд и скриптов посредством техники T1059, эксплуатирующей CVE-2023-1637.	1. Немедленное завершение подозрительных процессов интерпретаторов 2. Блокировка выполнения скриптов из временных каталогов 3. Аудит журналов выполнения команд и системных вызовов на предмет аномальных операций с MSR-регистрами 4. Отключение уязвимых функций управления питанием	1. Обновление ядра Linux до версии с устраненной уязвимостью 2. Внедрение механизмов контроля целостности системных интерпретаторов 3. Настройкаойка AppLocker или аналогичных решений с политиками "белого списка" для разрешенных командных интерпретаторов 4. Полная проверка антивирусными средствами
Сбор данных	Обход ограничения доступа к конфиденциальной информации, посредством применения вредоносных скриптов для мониторинга и перехвата временных файлов в момент их обработки, что свидетельствует о применении техники T1119, эксплуатирующей уязвимость CVE-2022-23824	1. Немедленная изоляция затронутых рабочих станций или блокировка исходящего трафика с затронутых узлов 2. Удаление подозрительных архивных файлов 3. Временное отключение автоматизированных задач обработки данных	1. Заменить центральный процессор рабочей станции, на такой, что лишен данной уязвимости 2. Установка всех патчей для библиотек обработки архивов 3. Ограничение прав доступа к временным каталогам 4. Внедрение DLP-систем с детектированием массового сбора данных 5. Полная проверка антивирусными средствами

ЗАКЛЮЧЕНИЕ

В ходе проведенного исследования была достигнутая поставленая цель, а именно повышение защищенности корпоративных сетей от сетевых атак класса «Манипулирование временем и состоянием», благодаря полученным в ходе исследований следующим результатам:

– произведена агрегация сведений об атаках класса «Манипулирование временем и состоянием», паспортизация соответствующих шаблонов атак CAPEC и уязвимостей операционных систем CVE (посредством базы данных уязвимостей ФСТЭК), аккумулирующая их статистические и экспертные метрики;

– построен лес древовидных графов с корнями в виде шаблонов атак, имеющих отношение к CAPEC-172, и вершинами в качестве эксплуатируемых уязвимостей CVE, основанием которому стала связь шаблонов атак CPAEC, релевантных им типам программных ошибок CWE и, им соответствующих, уязвимостей CVE;

– выполнены оценки рисков нарушения информационной безопасности посредством кибератак класса «Манипулирование временем и состоянием» на уязвимости с учетом специфики используемых злоумышленником сценариев;

– разработан комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Манипулирование временем и состоянием» на уязвимости АИС;

Полученные оценки рисков успешной реализации рассматриваемого множества атак открывают перспективу их регулирования в целях повышения защищенности атакуемых объектов.

Проведенное исследование показывает, что повышение безопасности корпоративных сетей от кибератак класса «Манипулирование временем и состоянием» требует комплексного подхода, включающего оценку и регулирование рисков успешности кибератак. Предложенная в данной работе методология оценки

рисков позволяет количественно оценить вероятность и потенциальный ущерб от таких атак, а также определить наиболее эффективные меры противодействия.

Разработанная в ходе данного исследования методология использует аналитические и практические подходы, что делает её применимой для решения широкого спектра задач информационной безопасности. Это обеспечивает высокий уровень точности в оценке рисков и позволяет выявлять узкие места в защите корпоративных систем ещё до возникновения инцидентов.

Таким образом, использованная в данной работе методология оценки и регулирования рисков успешности кибератак класса «Манипулирование временем и состоянием» является эффективным инструментом обеспечения безопасности корпоративных сетей. Реализация предложенных мер безопасности позволяет повысить устойчивость сетей к подобным атакам и минимизировать связанные с ними риски.

Дальнейшие исследования в этой области могут быть сосредоточены на разработке более совершенных методов оценки и регулирования рисков, а также на изучении новых типов кибератак и разработке соответствующих мер противодействия.

СПИСОК ЛИТЕРАТУРЫ

1 Эпидемии в телекоммуникационных сетях / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 1). – Текст: непосредственный.

2 Атакуемые взвешенные сети / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сете-вых войн»; вып. 2). – Текст: непосредственный.

3 Социальные сети и деструктивный контент / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 3). – Текст: непосредственный.

4 Социальные сети и риск-мониторинг / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2019. – 284 с. (Серия «Теория сетевых войн»; вып. 4). – Текст: непосредственный.

5 Социальные сети и психологическая безопасность / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2020. – 284 с. (Серия «Теория сетевых войн»; вып. 5). – Текст: непосредственный.

6 Сетео-информационная эпидемиология / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2021. – 284 с. (Серия «Теория сетевых войн»; вып. 6). – Текст: непосредственный.

7 Картография защищаемого киберпространства / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2022. – 372 с. (Серия «Теория сетевых войн»; вып. 7). – Текст: непосредственный.

8 Организационно-правовая защита сетей / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2023. – 228 с. (Серия «Теория сетевых войн»; вып. 8). – Текст: непосредственный.

9 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть I) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю.

Мирошниченко, А.А. Остапенко, А.С. Кривошеин // Информация и безопасность. 2023. – Т. 26. Вып. 3. – С. 329-340,

10 The Common Attack Pattern Enumeration and Classification (CAPEC) – Электрон. дан. – Режим доступа: https://capec.mitre.org/ (дата обращения 15.09.2024)

11 NIST Information Technology National Vulnerability Database. URL: https://nvd.nist.gov/vuln. – Текст: непосредственный.

12 База данных угроз безопасности информации – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/threat (дата обращения 15.09.2024)

13 MITRE ATT&CK – Электрон. дан. – Режим доступа: https://attack.mitre.org/matrices/enterprise – Текст: электронный.

14 CWE – Common Weakness Enumeration – Электрон. дан. – Режим доступа: https://cwe.mitre.org/index.html – Текст: электронный.

15 Каталог известных эксплуатируемых уязвимостей (CISA KEV) – Электрон. дан. – Режим доступа: https://www.cisa.gov/known-vulnerabilities-catalog – Текст: электронный.

16 Общая система оценки уязвимостей (CVSS). – Электрон. дан. – Режим доступа: https://www.first.org/cvss/specificationdocument – Текст: электронный.

17 Common Vulnerability Scoring System v3.1. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v3.1/. – Текст: электронный.

18 Common Vulnerability Scoring System v4.0. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v4.0/. – Текст: электронный.

19 Exploit Prediction Scoring System (EPSS). – Электрон. дан. – Режим доступа: https://www.first.org/epss – Текст: электронный.

20 OWASP Risk Rating. – Электрон. дан. – Режим доступа: https://owasp-riskrating.com/. – Текст: электронный.

21 26 SSVC Calculator. – Электрон. дан. – Режим доступа: https://www.cisa.gov/ssvc-calculator. – Текст: электронный.

22 Программа ScanOVAL для автоматизированных проверок наличия уязвимостей программного обеспечения. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/site/scanoval/. – Текст: электронный.

23 Система комплексного анализа защищенности "Сканер-ВС". – Электрон. дан. – Режим доступа: https://scaner-vs.ru/?ysclid=mcscdj5h2m908177562/. – Текст: электронный.

24 средство контроля и оценки защищенности информационной системы "MaxPatrol 8". – Электрон. дан. – Режим доступа: https://ptsecurity.com/ru-ru/products/mp8/. – Текст: электронный.

25 RedCheck – система контроля защищенности и соответствия стандартам ИБ (сканер безопасности). – Электрон. дан. – Режим доступа: https://www.altx-soft.ru/catalog/redcheck/redcheck/. – Текст: электронный.

26 XSpider. – Электрон. дан. – Режим доступа: https://ptsecurity.com/ru-ru/products/xspider/. – Текст: электронный.

27 Остапенко Г.А Методики и алгоритмы риск-анализа сценариев реализации атак / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, В.И. Белоножкин, П.Д. Федоров // Информация и безопасность. 2025. Т. 28. Вып. 1. С. 57-66. – Текст: непосредственный.

28 Остапенко А.Г. Проектная деятельность: научно-методическое развитие в направлении внедрения средств искусственного интеллекта для обеспечения организационно-правовой защиты корпоративных сетей / А.Г. Остапенко, Д.В. Щербакова, А.А. Остапенко, Д.А. Нархов // Информация и безопасность. 2023. – Т. 26.Вып. 3. – С. 447-454. – Текст: непосредственный.

29 Остапенко А.Г. Картографирование киберпространства и защита информации / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. С. 89-106. – Текст: непосредственный.

30 Остапенко Г.А. Нейросетевые задачи и компетенции проектной деятельности по созданию защищённых автоматизированных информационных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность. 2023. – Т. 26. Вып. 4. – С. 579-586. – Текст: непосредственный.

31 Остапенко Г.А. Методические рекомендации для осуществления проектной деятельности в сфере обеспечения информационной безопасности / Г.А.

Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А Старцев // Информация и безопасность. 2023. – Т. 26. Вып. 3. – С. 447-454. – Текст: непосредственный.

32 Олифер В., Олифер Н. Компьютерные сети. Принципы, технологии, протоколы: Учебник для вузов. 5-е изд. — СПб.: Питер, 2016. — 992 с.: ил. — (Серия «Учебник для вузов») . – Текст: непосредственный.

33 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть II) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. – Т. 26. Вып. 3. – С. 341-358. – Текст: непосредственный.

34 Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, Д.С. Покудин, Н.Н. Корвяков // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 239-246. – Текст: непосредственный.

35 Пекло А.Ю. Атаки типа «сетевая разведка»: риск-ландшафт и частная политика информационной безопасности предприятия / А.Ю. Пекло, Г.А. Остапенко, Д.В. Щербакова, А.А. Осталенко // Информация и безопасность. 2023. – Т. 26. Вып. 2. – С. 235-246. – Текст: непосредственный.

36 Хромых С.А. Сетевые атаки на уровне приложений: риск-ландшафт и частная политика информационной безопасности предприятия / С.А. Хромых, Г. А. Остапенко, Д. В. Щербакова, А. А. Остапенко // Информация и безопасность. 2023. – Т. 26. Вып. 2. – С. 261-276. – Текст: непосредственный.

37 Смирнов В.В. Кибератаки вида "анализ целевого объекта": риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / В.В. Смирнов, А.П. Васильченко, А.А. Остапенко, А.В. Гречишкин, С.С. Куликов, Д.Н. Рахманин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 273-284. – Текст: непосредственный.

38 Жидков Э.И. Кибератаки вида "социальная инженерия": риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / Э.И. Жидков, А.П.

Васильченко, А.А. Остапенко, А.С. Кольцов, Е.А. Шварцкопф, А.С. Щеголеватых // Информация и безопасность. 2024. Т. 27. № 2. С. 285-298. – Текст: непосредственный.

39 Сердечный А.Л. Риск-анализ и прогнозирование частоты и ущербности компьютерных атак / А.Л. Сердечный, А.С. Маликова, А.Г. Остапенко, М.Е. Волкова, Д.А. Нархов, А.Н. Бартенев. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 159-178. – Текст: непосредственный.

40 Кобцев О.Е. Сетевые атаки компьютерными вирусами: риск-ландшафт / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, В.Г. Юрасов, Д.С. Печкин // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 55 -66. – Текст: непосредственный.

41 Зорин В.А. Информационная безопасность и нейробиология социальной инженерии: когнитивные искажения, эмпатия / В.А. Зорин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 441-448. – Текст: непосредственный.

42 Кобцев О.Е. Сетевые атаки компьютерными вирусами: частная политика и регламенты информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, Ю.Г. Пастернак, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 67-80. – Текст: непосредственный.

43 Кобцев О.Е. Сетевые атаки компьютерными вирусами: частные инструкции информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, В.И. Белоножкин, К.А. Разинкин, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 81-90. – Текст: непосредственный.

44 Золотарев А.А. Сетевые атаки с помощью «сниффер-пакетов»: разработка частной политики информационной безопасности / А.А. Золотарев, Д.А. Нархов, А.Н. Мокроусов, В.И. Борисов, А.Е. Дешина, А.С. Пахомова, А.Ю. Егоров // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 91-98. – Текст: непосредственный.

45 Золотарев А.А. Сетевые атаки с помощью «сниффер-пакетов построение риск-ландшафта / А.А. Золотарев, Д.А.Нархов, М.И. Бочаров, А.И. Мордовин, Н.М.

Радько, О.В. Поздышева, А.Г. Краснобородкин // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 99-108. – Текст: непосредственный.

46 Громов Ю.Ю. Изучение возможности виртуализации технических средств защиты объектов с применением имитационного моделирования / Ю.Ю. Громов, П.И. Карасев, Ф.М. Пыршев // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 379-388. – Текст: непосредственный.

47 Сердечный А.Л. Информационное картографирование Blockchain-транзакций киберпреступников в экосистеме TON / А.Л. Сердечный, А.О. Абрамов, Е.А. Москалева // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 257-272. – Текст: непосредственный.

48 Сердечный А.Л. Информационная карта киберконфликта "палестина-израиль" / А.Л. Сердечный, А.Г. Остапенко // Информация и безопасность. 2023. Т. 26. № 4. С. 519-534. – Текст: непосредственный. – Текст: непосредственный.

49 Остапенко Г.А. Актуальность и целеполагание построения автоматизированного атласа кибератак в условиях цифровой трансформации / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко // Вопросы обеспечения безопасности в киберпространстве. Материалы II Всероссийской научно-технической конференции. Махачкала, 2024. С. 263-265. – Текст: непосредственный.

50 Остапенко А.Г. Нейросетевые компетенции и инструменты подготовки специалистов по защите информации / А.Г. Остапенко, Е.А. Москалева, А.П. Васильченко, А.А. Остапенко // Кибернетика и информационная безопасность «КИБ-2024»: Сб. науч. трудов Второй Всероссийской научно-технической конференции. Москва, 2024. С. 266-267. – Текст: непосредственный.

51 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 7-30. – Текст: непосредственный.

52 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть II) / Г.А. Остапенко, А.П. Васильченко,

А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 31-54. – Текст: непосредственный.

53 Остапенко Г.А. Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Н.Н. Корвяков, Д.С. Покудин, А.А. Ноздрюхин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 219-230. – Текст: непосредственный.

54 Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин, Н.Н. Корвяков, А.А. Ноздрюхин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 231-238. – Текст: непосредственный.

55 Остапенко А.А. Методики и алгоритмы риск-анализа успешности реализации массированных кибератак / А.А. Остапенко // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 401-420. – Текст: непосредственный.

56 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть I) / Д.В. Щербакова, А.Ю. Пекло, А.С. Кривошеин, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 185-196. – Текст: непосредственный.

57 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть II) / Д.В. Щербакова, А.Ю. Пекло, Д.С. Печкин, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 197-208. – Текст: непосредственный.

58 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть III) / Д.В. Щербакова, А.Ю. Пекло, Ю.В. Макаров, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 209-218. – Текст: непосредственный.

59 Пекло А.Ю. Атаки типа «сетевая разведка»: риск-ландшафт и частная политика информационной безопасности предприятия / А.Ю. Пекло, Г.А.

Остапенко, Д.В. Леа, А.А. Остапенко // Информация и безопасность. 2023. – Т. 26. Вып. 2. – С. 235-246. – Текст: непосредственный.

60 Остапенко Г.А. Матричная формализация целеполагания и результативности проектной деятельности в сфере защиты информации и обеспечения информационной безопасности / Г.А. Остапенко, В.И. Белоножкин, Н.И. Баранников, А.А. Остапенко, А.Г. Краснобородкин, Т.Ю. Мирошниченко // Информация и безопасность. 2022. Т. 25. Вып. 4. С. 475-484. – Текст: непосредственный.

61 Подтопельный В.В. Исследование специфики моделирования компьютерных атак с использованием марковских процессов принятий решений и Q-обуче-ния / В.В. Подтопельный // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 421 – 440. – Текст: непосредственный.

62 Зимницкий А.Г. Программно-технический комплекс выявления субъектов с повышенным риском девиантного поведения / А.Г. Зимницкий, А.А Остапенко // Информация и безопасность. 2022. Т. 25. № 4. С. 571 -582. – Текст: непосредственный.

63 Остапенко Г.А. Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей/ Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Н.Н. Корвяков [и другие] // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 219-230.

64 Остапенко Г.А. Нейросетевой сервис регламентации мер противодей¬ствия кибератакам (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, А.С. Кривошеин // Информация и без-опасность. 2024. Т. 27. Вып. 3. С. 319-336. – Текст: непосредственный.

65 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, Д.С. Печкин // Информация и без-опасность. 2024. Т. 27. Вып. 3. С. 337-378. – Текст: непосредственный.

66 Приказ Федеральной службы безопасности Российской Федерации от 19.06.2019 № 282 «Об утверждении Порядка, направленного на предотвращение несанкционированных изменений и ликвидации последствий компьютерных атак программных средств и компонентов программно-аппаратных комплексов для обработки и хранения информации в составе критической информационной инфраструктуры Российской Федерации». URL: http://www.consultant.ru/document/cons_doc_LAW_329009/. – Текст: электронный.

67 ГОСТ Р57429-2017. Служебная компьютерно-техническая экспертиза. Термины и определения. URL: https://docs.cntd.ru/document/1200144960 – Текст: элек-тронный.

68 Остапенко Г.А. Использование средств искусственного интеллекта в ходе исследовательского и учебного процессов при подготовке специалистов по защите информации / Г.А. Остапенко, А.О. Калашников, А.Г. Остапенко, Е.А. Москалева, Д.О. Карпеев, О.В. Поздышева, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 389-400. – Текст: непосредственный.

69 Avos ransomware group expands with new attack arsenal. – Электрон. дан. – Режим доступа: https://blog.talosintelligence.com/avoslocker-new-arsenal/. – Текст: электронный.

70 FireEye Threat Research. Demonstrating Hustle: A Case Study in Tracking FIN4. – Электрон. дан. – Режим доступа: https://www.fireeye.com/blog/threat-research/2015/07/demonstrating_hustle.html. – Текст: электронный.

71 FoggyWeb: Targeted NOBELIUM malware leads to persistent backdoor | Microsoft Security Blog. – Электрон. дан. – Режим доступа: https://www.microsoft.com/en-us/security/blog/2021/09/27/foggyweb-targeted-nobelium-malware-leads-to-persistent-backdoor/. – Текст: электронный.

72 The Impact of Versa Director Zero-Day Exploitation. – Электрон. дан. – Режим доступа: https://blog.lumen.com/uncovering-the-versa-director-zero-day-exploitation/. – Текст: электронный.

73 Operation Dust Storm. – Электрон. дан. – Режим доступа: https://s7d2.scene7.com/is/content/cylance/prod/cylance-web/en-us/resources/knowledge-center/resource-library/reports/Op_Dust_Storm_Report.pdf. – Текст: электронный.

74 Canadian Centre for Cyber Security. Cyber Activity Impacting Cisco ASA VPNs. – Электрон. дан. – Режим доступа: https://www.cyber.gc.ca/en/news-events/cyber-activity-impacting-cisco-asa-vpns. – Текст: электронный.

75 Huntress. LightSpy Malware Variant Targeting macOS. 2020. – Электрон. дан. – Режим доступа: https://www.huntress.com/blog/lightspy-malware-variant-targeting-macos. – Текст: электронный.

76 Weathering the storm: In the midst of a Typhoon.. – Электрон. дан. – Режим доступа: https://blog.talosintelligence.com/salt-typhoon-analysis/ – Текст: электронный.

77 APT41 Targeting U.S. State Government Networks | Mandiant | Google Cloud Blog. – Электрон. дан. – Режим доступа: https://cloud.google.com/blog/topics/threat-intelligence/apt41-us-state-governments/. – Текст: электронный.

78 Privileges and Credentials: Phished at the Request of Counsel | Mandiant | Google Cloud Blog. – Электрон. дан. – Режим доступа: https://cloud.google.com/blog/topics/threat-intelligence/phished-at-the-request-of-counsel/. – Текст: электронный.

79 SecurityScorecard Threat Intelligence. Daggerfly Espionage: Updated Toolset. – Электрон. дан. – Режим доступа: https://www.security.com/threat-intelligence/daggerfly-espionage-updated-toolset – Текст: электронный.

80 The five-day job: A BlackByte ransomware intrusion case study | Microsoft Security Blog. – Электрон. дан. – Режим доступа: https://www.microsoft.com/en-us/security/blog/2023/07/06/the-five-day-job-a-blackbyte-ransomware-intrusion-case-study/. – Текст: электронный.

81 APT3 Uncovered: The code evolution of Pirpi. – Электрон. дан. – Режим доступа: https://recon.cx/2017/montreal/resources/slides/RECON-MTL-2017-evolution_of_pirpi.pdf. – Текст: электронный.

82 APT38: Un-usual Suspects. Retrieved November 17, 2024. – Электрон. дан. – Режим доступа: https://www.mandiant.com/sites/default/files/2021-09/rpt-apt38-2018-web_v5-1.pdf. – Текст: электронный.

83 MoustachedBouncer: Espionage against foreign diplomats in Belarus. – Электрон. дан. – Режим доступа: https://www.welivesecurity.com/en/eset-research/moustachedbouncer-espionage-against-foreign-diplomats-in-belarus/. – Текст: электронный.

84 WIN32/INDUSTROYER A new threat for industrial control systems. – Электрон. дан. – Режим доступа: https://www.welivesecurity.com/wp-content/uploads/2017/06/Win32_Industroyer.pdf. – Текст: электронный.

85 OutSteel, SaintBot Delivered by Spear Phishing Attacks Targeting Ukraine. – Электрон. дан. – Режим доступа: https://unit42.paloaltonetworks.com/ukraine-targeted-outsteel-saintbot/. – Текст: электронный.

86 Exbyte: BlackByte Ransomware Attackers Deploy New Exfiltration Tool | Symantec Enterprise Blogs. – Электрон. дан. – Режим доступа: https://www.security.com/threat-intelligence/blackbyte-exbyte-ransomware. – Текст: электронный.

87 A Slice of 2017 Sofacy Activity | Securelist. – Электрон. дан. – Режим доступа: https://securelist.com/a-slice-of-2017-sofacy-activity/83930/. – Текст: электронный.

88 Bad Rabbit ransomware | Securelist. – Электрон. дан – Режим доступа: https://securelist.com/bad-rabbit-ransomware/82851/. – Текст: электронный.

89 Cyber Activity Impacting CISCO ASA VPNs. – Электрон. дан – Режим доступа: – Canadian Centre for Cyber Security https://www.cyber.gc.ca/en/news-events/cyber-activity-impacting-cisco-asa-vpns. – Текст: электронный.

ПРИЛОЖЕНИЕ А

Таблица А 1 – Паспорт CAPEC-25

<table>
<tr><td>Идентификатор системы CAPEC</td><td colspan="2">CAPEC-25: Принудительная взаимоблокировка</td></tr>
<tr><td>Описание вектора атаки</td><td colspan="2">Злоумышленник инициирует и использует состояние взаимоблокировки в целевом программном обеспечении для создания ситуации «отказ в обслуживании». Взаимоблокировка может возникнуть, когда два или более конкурирующих процесса ожидают завершения друг друга, и, таким образом, ни одно из них не завершается. Обнаружение состояния взаимоблокировки может быть затруднительным.</td></tr>
<tr><td>Тип атаки</td><td colspan="2">Манипулирование временем и состоянием</td></tr>
<tr><td rowspan="6">Соотношение типа ошибки CWE и статуса типа ошибки CWE</td><td>CWE-412: Блокировка с неограниченным внешним доступом</td><td rowspan="5">Разрешён для использования в реальных уязвимостях</td></tr>
<tr><td>CWE-567: Несинхронизированный доступ к совместно используемым данным в многопоточном контексте</td></tr>
<tr><td>CWE-667: Недостаточная блокировка</td></tr>
<tr><td>CWE-833: Зависание</td></tr>
<tr><td>CWE-835: Выполнение цикла с недоступным условием выхода (бесконечный цикл)</td></tr>
<tr><td>CWE-662: Неправильная синхронизация</td><td>Не рекомендован для использования в реальных уязвимостях</td></tr>
</table>

Таблица А 2 – Паспорт CAPEC-27

<table>
<tr><td>Идентификатор системы CAPEC</td><td colspan="2">CAPEC-27: Использование состояния гонки через символьные ссылки</td></tr>
<tr><td>Описание вектора атаки</td><td colspan="2">Эта атака использует символьные ссылки для записи в конфиденциальные файлы. Злоумышленник может создать символьную ссылку на целевой файл, к которому у него нет прямого доступа. Когда привилегированная программа пытается создать временный файл с тем же именем, что и символьная ссылка, она на самом деле записывает данные в целевой файл, на который указывает символьная ссылка злоумышленника. Если злоумышленнику удается вставить вредоносное содержимое во временный файл, то это содержимое будет записано в конфиденциальный файл с помощью символьной ссылки. Состояние гонки возникает, потому что система сначала проверяет наличие временного файла, а затем создает его. Злоумышленник обычно создает символьную ссылку в интервале между проверкой и созданием временного файла.</td></tr>
<tr><td>Тип атаки</td><td colspan="2">Манипулирование временем и состоянием</td></tr>
<tr><td rowspan="4">Соотношение типа ошибки CWE и статуса типа ошибки CWE</td><td>CWE-367: Ситуация гонки Time-of-check Time-of-use (TOCTOU)</td><td rowspan="3">Разрешён для использования в реальных уязвимостях</td></tr>
<tr><td>CWE-61: Отслеживание символьных ссылок UNIX</td></tr>
<tr><td>CWE-667: Недостаточная блокировка</td></tr>
<tr><td>CWE-662: Неправильная синхронизация</td><td>Не рекомендован для использования в реальных уязвимостях</td></tr>
</table>

Таблица А 3 – Паспорт CAPEC-140

Идентификатор системы CAPEC	CAPEC-140: Обход промежуточных форм в наборах с несколькими формами	
Описание вектора атаки	Некоторые веб-приложения требуют от пользователей предоставления информации через последовательный набор веб-форм. Это часто делается, если необходимо собрать большое количество информации или если данные из предыдущих форм используются для предварительного заполнения полей или определения, какую дополнительную информацию нужно собрать. Злоумышленник, знающий имена различных форм в последовательности, может вручную ввести имя более поздней формы и перейти к ней, минуя предыдущие формы. Это может привести к неполному сбору информации, неверным предположениям о данных, предоставленных злоумышленником, или другим проблемам, которые могут нарушить работу приложения.	
Тип атаки	Манипулирование временем и состоянием	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-372: Неполное распознавание внутреннего состояния	Не рекомендуется

Таблица А 4 – Паспорт CAPEC-696

Идентификатор системы CAPEC	CAPEC-696: Инъекция значения загрузки	
Описание вектора атаки	Злоумышленник использует аппаратную уязвимость в реализации процессора, связанную с транзитным выполнением инструкций, при которой неисправная или поддерживаемая загрузочная инструкция временно передаёт данные, контролируемые злоумышленником, из микроархитектурных буферов. Провоцируя отказ страницы или вмешательство микрокода во время выполнения инструкций жертвы, злоумышленник может заставить легитимные процессы жертвы работать с данными, находящимися под контролем злоумышленника и хранящимися в микроархитектурных буферах. После этого злоумышленник может использовать существующие фрагменты кода и методы анализа побочных каналов, чтобы раскрыть секретные данные жертвы, которые ещё не были сброшены из микроархитектурного состояния, или перехватить управление потоком системы.	
Тип атаки	Манипулирование временем и состоянием	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-226: Наличие критичной информации в итоговой версии ПО	Разрешён для использования в реальных уязвимостях

ПРИЛОЖЕНИЕ Б

Таблица Б 1 – Паспорт CVE-2019-11485

Идентификатор уязвимости	CVE-2019-11485
Описание уязвимости	Уязвимость службы регистрации ошибок apport операционной системы Ubuntu связана с блокировкой с неограниченным внешним доступом. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-412
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:L
Уровень опасности уязвимости	Низкий уровень опасности (базовая оценка CVSS 2.0 составляет 1,7) Низкий уровень опасности (базовая оценка CVSS 3.0 составляет 3,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 2 – Паспорт CVE-2023-31082

Идентификатор уязвимости	CVE-2023-31082
Описание уязвимости	Уязвимость функции gsmld_write() в модуле drivers/tty/n_gsm.c драйвера N_GSM ядра операционной системы Linux связана с использованием некорректного типа блокировки. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-667
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	0

Таблица Б 3 – Паспорт CVE-2023-44374

Идентификатор уязвимости	CVE-2023-44374
Описание уязвимости	Уязвимость микропрограммного обеспечения промышленных коммутаторов Siemens SCALANCE связана с несинхронизированным доступом к совместно используемым данным в многопоточном контексте. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, повысить свои привилегии
Идентификатор типа ошибки	CWE-567
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 4 – Паспорт CVE-2021-1622

Идентификатор уязвимости	CVE-2021-1622
Описание уязвимости	Уязвимость службы Common Open Policy Service (COPS) операционных систем Cisco IOS XE связана с ошибками при обработке пакетов COPS. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-833
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,3) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 5 – Паспорт CVE-2022-4269

Идентификатор уязвимости	CVE-2022-4269
Описание уязвимости	Уязвимость подсистемы Traffic Control Subsystem ядра операционной системы Linux связана с некорректной зачисткой или освобождением ресурсов. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-833
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 6 – Паспорт CVE-2023-0160

Идентификатор уязвимости	CVE-2023-0160
Описание уязвимости	Уязвимость функции sock_hash_delete_elem() в модуле net/core/sock_map.c ядра операционной системы Linux связана с некорректной сериализацией ресурса htab->buckets[i].lock. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-833
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 7 – Паспорт CVE-2023-34324

Идентификатор уязвимости	CVE-2023-34324
Описание уязвимости	Уязвимость функции xen_free_irq() модуля drivers/xen/events/events_base.c гипервизора Xen ядра операционной системы Linux связана с возникновением взаимной блокировки. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-833
Базовый вектор уязвимости	AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,1) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 8 – Паспорт CVE-2024-0641

Идентификатор уязвимости	CVE-2024-0641
Описание уязвимости	Уязвимость функции tipc_crypto_key_revoke модуля net/tipc/crypto.c ядра операционной системы Linux связана с возникновением взаимной блокировки. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-833
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 9 – Паспорт CVE-2024-0639

Идентификатор уязвимости	CVE-2024-0639
Описание уязвимости	Уязвимость функции sctp_auto_asconf_init (net/sctp/socket.c) ядра операционной системы Linux связана с возникновением взаимной блокировки. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-833
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 10 – Паспорт CVE-2020-36775

Идентификатор уязвимости	CVE-2020-36775
Описание уязвимости	Уязвимость функции f2fs_write_compressed_pages() в модуле fs/f2fs/compress.c файловой системы f2fs ядра операционной системы Linux связана с некорректной зачисткой или освобождением ресурсов. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-833
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 11 – паспорт CVE-2021-47038

Идентификатор уязвимости	CVE-2021-47038
Описание уязвимости	Уязвимость функция hci_conn_get_phy драйвера Bluetooth ядра операционной системы Linux связана с зависанием. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-833
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 12 – Паспорт CVE-2023-52456

Идентификатор уязвимости	CVE-2023-52456
Описание уязвимости	Уязвимость функции imx_uart_stop_tx() в модуле drivers/tty/serial/imx.c драйвера последовательных устройств Motorolla IMX ядра операционной системы Linux связана с бесконечным циклом. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-833
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 13 – Паспорт CVE-2024-26650

Идентификатор уязвимости	CVE-2024-26650
Описание уязвимости	Уязвимость функции p2sb_bar() в модуле drivers/platform/x86/p2sb.c ядра операционной системы Linux связана с зависанием из-за повторной блокировки ресурса. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-833
Базовый вектор уязвимости	AV:L/AC:L/PR:H/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 14 – Паспорт CVE-2024-26624

Идентификатор уязвимости	CVE-2024-26624
Описание уязвимости	Уязвимость функции unix_state_double_lock() в модуле net/unix/af_unix.c реализации сокетов AF_UNIX ядра операционной системы Linux связана с нарушением механизма синхронизации. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-833
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 15 – Паспорт CVE-2024-26605

Идентификатор уязвимости	CVE-2024-26605
Описание уязвимости	Уязвимость функции pcie_aspm_pm_state_change() драйвера Qualcomm устройств PCIe ядра операционной системы Linux связана с некорректной сериализацией ресурсов. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-833
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 16 – Паспорт CVE-2024-36976

Идентификатор уязвимости	CVE-2024-36976
Описание уязвимости	Уязвимость функции log_ctrl() в модуле drivers/media/v4l2-core/v4l2-ctrls-core.c видео драйвера ядра операционной системы Linux связана с взаимной блокировкой потоков выполнения. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-833
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 17 – Паспорт CVE-2024-45003

Идентификатор уязвимости	CVE-2024-45003
Описание уязвимости	Уязвимость функции dispose_list в компоненте vfs ядра операционной системы Linux связана с некорректной зачисткой или освобождением ресурсов. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-833
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 18 – Паспорт CVE-2023-45232

Идентификатор уязвимости	CVE-2023-45232
Описание уязвимости	Уязвимость компонента IPv6 Options Header Handler библиотеки Tianocore EDK2 связана с переполнением буфера. Эксплуатация уязвимости позволяет нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 19 – Паспорт CVE-2024-26603

Идентификатор уязвимости	CVE-2024-26603
Описание уязвимости	Уязвимость функции restore_fpregs_from_user() в модуле arch/x86/kernel/fpu/signal.c драйвера FPU ядра операционной системы Linux связана с недостаточным контролем допустимости пользовательских данных. Эксплуатация уязвимости может позволить нарушителю оказать воздействие на конфиденциальность, целостность и доступность защищаемой информации
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 20 – Паспорт CVE-2024-1931

Идентификатор уязвимости	CVE-2024-1931
Описание уязвимости	Уязвимость DNS-сервера Unbound связана с выполнением цикла с недоступным условием выхода. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 21 – Паспорт CVE-2023-0437

Идентификатор уязвимости	CVE-2023-0437
Описание уязвимости	Уязвимость функции bson_utf8_validate() драйвера системы управления базами данных MongoDB C-Driver связана с циклом с недостижимым условием выхода. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 22 – Паспорт CVE-2024-2757

Идентификатор уязвимости	CVE-2024-2757
Описание уязвимости	Уязвимость функции mb_encode_mimeheader() интерпретатора языка программирования PHP связана с неконтролируемым расходом ресурсов. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	1

Таблица Б 23 – Паспорт CVE-2024-24786

Идентификатор уязвимости	CVE-2024-24786
Описание уязвимости	Уязвимость функции protojson.Unmarshal() пакета golang-google-protobuf языка программирования Golang связана с бесконечный цикл при анмаршалинге определенных форм JSON. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,4) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 24 – Паспорт CVE-2024-4854

Идентификатор уязвимости	CVE-2024-4854
Описание уязвимости	Уязвимость диссекторов MONGO и ZigBee TLV анализатора трафика компьютерных сетей Wireshark связана с выполнением цикла с недоступным условием выхода. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, вызвать отказ в обслуживании путем отправки специально созданных пакетов
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 25 – Паспорт CVE-2024-36288

Идентификатор уязвимости	CVE-2024-36288
Описание уязвимости	Уязвимость функции gss_read_proxy_verf() в модуле net/sunrpc/auth_gss/svcauth_gss.c реализации протокола Remote Procedure Call (RPC) ядра операционной системы Linux связана с недостаточным выделением памяти для операции. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 26 – Паспорт CVE-2023-50120

Идентификатор уязвимости	CVE-2023-50120
Описание уязвимости	Уязвимость функции av1_uvlc() мультимедийной платформы GPAC связана с бесконечным циклом в функции av1_uvlc в media_tools/av_parsers.c. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,9) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 27 – Паспорт CVE-2024-35982

Идентификатор уязвимости	CVE-2024-35982
Описание уязвимости	Уязвимость компонента batman-adv ядра операционной системы Linux связана с ошибками бесконечного цикла при попытке изменить размер локального TT. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 28 – Паспорт CVE-2022-48840

Идентификатор уязвимости	CVE-2022-48840
Описание уязвимости	Уязвимость функции iavf_shutdown() в компоненте iavf ядра операционной системы Linux связана с добавлением цикла ожидания в начало iavf_remove(), чтобы гарантировать, что инициализация порта завершена до отмены регистрации сетевого устройства. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 29 – Паспорт CVE-2022-48862

Идентификатор уязвимости	CVE-2022-48862
Описание уязвимости	Уязвимость функции vhost_iotlb_add_range_ctx() в компоненте vhost ядра операционной системы Linux связана с ошибкой записи iotlb в vhost_iotlb_add_range_ctx() размер диапазона может стать равным 0. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 30 – Паспорт CVE-2024-45506

Идентификатор уязвимости	CVE-2024-45506
Описание уязвимости	Уязвимость серверного программного обеспечения HAProxy связана с входом в бесконечный цикл при подаче определенных входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 31 – Паспорт CVE-2024-31949

Идентификатор уязвимости	CVE-2024-31949
Описание уязвимости	Уязвимость компонента Dynamic Capability Handler программного средства реализации сетевой маршрутизации на Unix-подобных системах FRRouting связана с выполнением цикла с недоступным условием выхода. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 32 – Паспорт CVE-2024-8088

Идентификатор уязвимости	CVE-2024-8088
Описание уязвимости	Уязвимость модуля zipfile интерпретатора языка программирования Python связана с циклом с недостижимым условием выхода. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-835
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:R/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,4) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 33 – Паспорт CVE-2019-15031

Идентификатор уязвимости	CVE-2019-15031
Описание уязвимости	Уязвимость компонента arch/powerpc/kernel/process.c ядра операционной системы Linux (микропроцессорная RISC-архитектура PowerPC) связана с отсутствием защиты служебных данных. Эксплуатация уязвимости может позволить нарушителю оказать воздействие на конфиденциальность и доступность защищаемой информации в результате запуска транзакции с помощью команды tbegin и последующему обращению к векторным регистрам
Идентификатор типа ошибки	CWE-662
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:L
Уровень опасности уязвимости	Низкий уровень опасности (базовая оценка CVSS 2.0 составляет 3,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 34 – Паспорт CVE-2020-12769

Идентификатор уязвимости	CVE-2020-12769
Описание уязвимости	Уязвимость компонента drivers/spi/spi-dw.c ядра операционных систем Linux существует из-за недостаточной проверки входных данных. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-662
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 35 – Паспорт CVE-2020-14059

Идентификатор уязвимости	CVE-2020-14059
Описание уязвимости	Уязвимость функции Ipc::Mem::PageStack::pop прокси-сервера Squid связана с ошибками синхронизации. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-662
Базовый вектор уязвимости	AV:N/AC:H/PR:L/UI:N/S:C/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,9) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 36 – Паспорт CVE-2021-29650

Идентификатор уязвимости	CVE-2021-29650
Описание уязвимости	Уязвимость подсистемы netfilter ядра операционной системы Linux связана с ошибками синхронизации. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-662
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,9) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 37 – Паспорт CVE-2020-25668

Идентификатор уязвимости	CVE-2020-25668
Описание уязвимости	Уязвимость подсистемы tty ядра операционной системы Linux связана с использованием памяти после ее освобождения. Эксплуатация уязвимости может позволить нарушителю получить доступ к конфиденциальной информации или вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-662
Базовый вектор уязвимости	AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,6) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 38 – Паспорт CVE-2022-39189

Идентификатор уязвимости	CVE-2022-39189
Описание уязвимости	Уязвимость функции kvm_steal_time_set_preempted() в модуле arch/x86/kvm/x86.c ядра операционной системы Linux связана с некорректным сообщением состояния виртуальных процессоров. Эксплуатация уязвимости может позволить нарушителю получить доступ к защищаемой информации
Идентификатор типа ошибки	CWE-662
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 39 – Паспорт CVE-2023-3389

Идентификатор уязвимости	CVE-2023-3389
Описание уязвимости	Уязвимость функции io_poll_update() в модуле io_uring/io_uring.c ядра операционной системы Linux связана с использованием ранее освобожденной памяти. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-662
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 40 – Паспорт CVE-2023-5088

Идентификатор уязвимости	CVE-2023-5088
Описание уязвимости	Уязвимость функции ide_dma_cb() эмулятора аппаратного обеспечения QEMU связана с ошибками синхронизации при обработке параметра DRQ_STAT. Эксплуатация уязвимости может позволить нарушителю получить доступ на чтение, изменение или удаление данных или вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-662
Базовый вектор уязвимости	AV:L/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,9) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 41 – Паспорт CVE-2024-26958

Идентификатор уязвимости	CVE-2024-26958
Описание уязвимости	Уязвимость функции nfs_direct_commit_schedule() в модуле fs/nfs/direct.c сетевой файловой системы Network File System (NFS) ядра операционной системы Linux связана с повторным использованием ранее освобожденной памяти. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-662
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 42 – Паспорт CVE-2024-7409

Идентификатор уязвимости	CVE-2024-7409
Описание уязвимости	Уязвимость эмулятора аппаратного обеспечения QEMU связана с ошибками синхронизации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-662
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 43 – Паспорт CVE-2020-15702

Идентификатор уязвимости	CVE-2020-15702
Описание уязвимости	Уязвимость службы регистрации ошибок Apport существует из-за недостаточной проверки состояния совместно используемого ресурса. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии и выполнить произвольный код
Идентификатор типа ошибки	CWE-367
Базовый вектор уязвимости	AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 44 – Паспорт CVE-2020-35508

Идентификатор уязвимости	CVE-2020-35508
Описание уязвимости	Уязвимость ядра операционной системы Linux связана с неправильной инициализацией идентификаторов процесса. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-367
Базовый вектор уязвимости	AV:L/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:L
Уровень опасности уязвимости	Низкий уровень опасности (базовая оценка CVSS 2.0 составляет 3,5) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 45 – Паспорт CVE-2021-35937

Идентификатор уязвимости	CVE-2021-35937
Описание уязвимости	Уязвимость менеджера RPM-пакетов RPM (RPM Package Manager) операционных систем Red Hat Enterprise Linux вызвана ситуацией гонки. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-367
Базовый вектор уязвимости	AV:L/AC:H/PR:H/UI:R/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 46 – Паспорт CVE-2021-3054

Идентификатор уязвимости	CVE-2021-3054
Описание уязвимости	Уязвимость веб-интерфейса операционных систем PAN-OS связана с ошибками синхронизации при использовании общего ресурса. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, повысить свои привилегии и выполнить произвольный код
Идентификатор типа ошибки	CWE-367
Базовый вектор уязвимости	AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8,5) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 47 – Паспорт CVE-2021-35090

Идентификатор уязвимости	CVE-2021-35090
Описание уязвимости	Уязвимость ядра микропрограммного обеспечения встраиваемых плат Qualcomm связана с ошибками синхронизации при использовании общего ресурса. Эксплуатация уязвимости может позволить нарушителю выполнить произвольный код
Идентификатор типа ошибки	CWE-367
Базовый вектор уязвимости	AV:L/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,2) Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 48 – Паспорт CVE-2022-23084

Идентификатор уязвимости	CVE-2022-23084
Описание уязвимости	Уязвимость функции nmreq_copyin() компонента netmap операционных систем FreeBSD связана с ошибками синхронизации при использовании общего ресурса. Эксплуатация уязвимости может позволить нарушителю выполнить произвольный код в контексте ядра
Идентификатор типа ошибки	CWE-367
Базовый вектор уязвимости	AV:L/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 49 – Паспорт CVE-2023-22397

Идентификатор уязвимости	CVE-2023-22397
Описание уязвимости	Уязвимость модуля Packet Forwarding Engine (PFE) операционных систем Juniper Networks Junos OS Evolved и Junos связана с ошибками синхронизации при использовании общего ресурса. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-367
Базовый вектор уязвимости	AV:A/AC:H/PR:N/UI:N/S:C/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 50 – Паспорт CVE-2023-20135

Идентификатор уязвимости	CVE-2023-20135
Описание уязвимости	Уязвимость функции проверки образа операционной системы Cisco IOS XR связана с ошибками синхронизации при использовании общего ресурса. Эксплуатация уязвимости может позволить нарушителю выполнить произвольный код в базовой операционной системе
Идентификатор типа ошибки	CWE-367
Базовый вектор уязвимости	AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 51 – Паспорт CVE-2024-35265

Идентификатор уязвимости	CVE-2024-35265
Описание уязвимости	Уязвимость службы мониторинга состояния безопасности Windows Perception Service операционных систем Windows связана с ошибками синхронизации при использовании общего ресурса («Ситуация гонки»). Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-367
Базовый вектор уязвимости	AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 52 – Паспорт CVE-2024-7348

Идентификатор уязвимости	CVE-2024-7348
Описание уязвимости	Уязвимость утилиты pg_dump системы управления базами данных PostgreSQL связана с разыменованием нулевого указателя из-за конкурентного доступа к ресурсу (состояние гонки). Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнять произвольный SQL-код от имени пользователя, запускающего pg_dump и при условии сохранения нарушителем открытой транзакции
Идентификатор типа ошибки	CWE-367
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 53 – Паспорт CVE-2024-38153

Идентификатор уязвимости	CVE-2024-38153
Описание уязвимости	Уязвимость ядра операционных систем Windows связана с ошибками синхронизации при использовании общего ресурса («Ситуация гонки»). Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-367
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 54 – Паспорт CVE-2024-30088

Идентификатор уязвимости	CVE-2024-30088
Описание уязвимости	Уязвимость ядра операционных систем Windows связана с ошибками синхронизации при использовании общего ресурса. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-367
Базовый вектор уязвимости	AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 55 – Паспорт CVE-2023-21215

Идентификатор уязвимости	CVE-2023-21215
Описание уязвимости	Уязвимость функции DevmemIntAcquireRemoteCtx() драйвера графического процессора PowerVR GPU операционных систем Android и ChromeOS связана с ошибками синхронизации при использовании общего ресурса («Ситуация гонки»). Эксплуатация уязвимости может позволить нарушителю выполнить произвольный код и повысить свои привилегии
Идентификатор типа ошибки	CWE-367
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 56 – Паспорт CVE-2024-27983

Идентификатор уязвимости	CVE-2024-27983
Описание уязвимости	Уязвимость функции node::http2::Http2Session::~Http2Session() HTTP/2-сервера программной платформы Node.js связана с неконтролируемым расходом ресурсов в результате некорректного определения окончания заголовка при обработке фреймов CONTINUATION. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-367
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	1

Таблица Б 57 – Паспорт CVE-2019-16775

Идентификатор уязвимости	CVE-2019-16775
Описание уязвимости	Уязвимость набора инструментов командной строки пакетных менеджеров NPM и Yarn связна с ошибками обработки ссылок. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, записывать произвольные файлы, путем создания символической ссылки на файлы вне каталога с модулями (thenode_modules) или посредством манипуляции с полем bin в package.json
Идентификатор типа ошибки	CWE-61
Базовый вектор уязвимости	AV:N/AC:H/PR:L/UI:R/S:C/C:H/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,1) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 58 – Паспорт CVE-2020-28007

Идентификатор уязвимости	CVE-2020-28007
Описание уязвимости	Уязвимость агента пересылки сообщений Exim связана с отслеживаниеи символьных ссылок. Эксплуатация уязвимости может позволить нарушителю повысить привилегии в системе путем создания специально сформированной символической ссылки на файл и перезаписи его с провами приложения
Идентификатор типа ошибки	CWE-61
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,2) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 59 – Паспорт CVE-2021-31997

Идентификатор уязвимости	CVE-2021-31997
Описание уязвимости	Уязвимость реализации сценария postorius-permissions.sh веб-интерфейса для доступа к Mailman архивам Postorius связана с отслеживанием символьных ссылок. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-61
Базовый вектор уязвимости	AV:L/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 60 – Паспорт CVE-2021-23177

Идентификатор уязвимости	CVE-2021-23177
Описание уязвимости	Уязвимость библиотеки архивирования libarchive связана с отслеживанием символьных ссылок. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии с помощь открытия атукуемым специально сформированного архива
Идентификатор типа ошибки	CWE-61
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,2) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 61 – Паспорт CVE-2021-31566

Идентификатор уязвимости	CVE-2021-31566
Описание уязвимости	Уязвимость библиотеки архивирования libarchive связана с отслеживанием символьных ссылок. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии с помощью создания специально сформированной ссылки на вредоносный файл
Идентификатор типа ошибки	CWE-61
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,2) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 62 – Паспорт CVE-2023-6597

Идентификатор уязвимости	CVE-2023-6597
Описание уязвимости	Уязвимость интерпретатора языка программирования Python связана с ошибками при обработке символических ссылок. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии с помощью специально созданной символической ссылки
Идентификатор типа ошибки	CWE-61
Базовый вектор уязвимости	AV:L/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,2) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,4)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 63 – Паспорт CVE-2024-25952

Идентификатор уязвимости	CVE-2024-25952
Описание уязвимости	Уязвимость операционной системы PowerScale OneFS связана с отслеживанием символьных ссылок. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании и оказать воздействие на целостность защищаемой информации
Идентификатор типа ошибки	CWE-61
Базовый вектор уязвимости	AV:L/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,9) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 64 – Паспорт CVE-2024-25953

Идентификатор уязвимости	CVE-2024-25953
Описание уязвимости	Уязвимость операционной системы PowerScale OneFS связана с отслеживанием символьных ссылок. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании и оказать воздействие на целостность защищаемой информации
Идентификатор типа ошибки	CWE-61
Базовый вектор уязвимости	AV:L/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,9) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 65 – Паспорт CVE-2022-23824

Идентификатор уязвимости	CVE-2022-23824
Описание уязвимости	Уязвимость реализации механизма Indirect Branch Prediction Barrier (IBPB) микропрограммного обеспечения процессоров AMD связана с некорректной очисткой стека RAS (Return Address Stack). Эксплуатация уязвимости может позволить нарушителю получить несанкционированный доступ к защищаемой информации, используя побочный канал
Идентификатор типа ошибки	CWE-226
Базовый вектор уязвимости	AV:L/AC:H/PR:L/UI:N/S:C/C:H/I:N/A:N
Уровень опасности уязвимости	Низкий уровень опасности (базовая оценка CVSS 2.0 составляет 3,8) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 66 – Паспорт CVE-2023-1637

Идентификатор уязвимости	CVE-2023-1637
Описание уязвимости	Уязвимость функции управления питанием ядра операционных систем Linux связана с использованием скрытых временных каналов для передачи данных при обработке регистров (model-specific register (MSR)). Эксплуатация уязвимости может позволить нарушителю получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-226
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0

Таблица Б 67 – Паспорт CVE-2023-3006

Идентификатор уязвимости	CVE-2023-3006
Описание уязвимости	Уязвимость ядра операционной системы Linux связана с ошибками межграничного удаления критичных данных. Эксплуатация уязвимости может позволить нарушителю получить доступ к защищаемой информации
Идентификатор типа ошибки	CWE-226
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6) Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	0